ISACA®
Trust in, and value from, information systems

# COBIT®




# *Process Assessment Model (PAM): Using COBIT® 5*

COBIT® 5
AN ISACA® FRAMEWORK

Personal Copy of: Mr. Jorge Diab Maluf Filho

**ISACA®**
With more than 100,000 constituents in 180 countries, ISACA (*www.isaca.org*) is a leading global provider of knowledge, certifications, community, advocacy and education on information systems (IS) assurance and security, enterprise governance and management of IT, and IT-related risk and compliance. Founded in 1969, the non-profit, independent ISACA hosts international conferences, publishes the *ISACA® Journal*, and develops international IS auditing and control standards, which help its constituents ensure trust in, and value from, information systems. It also advances and attests IT skills and knowledge through the globally respected Certified Information Systems Auditor® (CISA®), Certified Information Security Manager® (CISM®), Certified in the Governance of Enterprise IT® (CGEIT®) and Certified in Risk and Information Systems Control™ (CRISC™) designations.

ISACA continually updates and expands the practical guidance and product family based on the COBIT® framework. COBIT helps IT professionals and enterprise leaders fulfil their IT governance and management responsibilities, particularly in the areas of assurance, security, risk and control, and deliver value to the business.

**Disclaimer**
ISACA has designed and created *COBIT® Process Assessment Model (PAM): Using COBIT® 5* (the 'Work') primarily as an educational resource for governance of enterprise IT (GEIT), assurance, risk and security professionals. ISACA makes no claim that use of any of the Work will assure a successful outcome. The Work should not be considered inclusive of all proper information, procedures and tests or exclusive of other information, procedures and tests that are reasonably directed to obtaining the same results. In determining the propriety of any specific information, procedure or test, readers should apply their own professional judgement to the specific circumstances presented by the particular systems or information technology environment.

**Copyright**
© 2013 ISACA. All rights reserved. For usage guidelines see *www.isaca.org/COBITuse.*

**ISACA**
3701 Algonquin Road, Suite 1010
Rolling Meadows, IL 60008 USA
Phone: +1.847.253.1545
Fax: +1.847.253.1443
Email: *info@isaca.org*
Web site: *www.isaca.org*

Feedback: *www.isaca.org/cobit*
Participate in the ISACA Knowledge Center: *www.isaca.org/knowledge-center*
Follow ISACA on Twitter: *https://twitter.com/ISACANews*
Join the COBIT conversation on Twitter: #COBIT
Join ISACA on LinkedIn: ISACA (Official), *http://linkd.in/ISACAOfficial*
Like ISACA on Facebook: *www.facebook.com/ISACAHQ*

*COBIT® Process Assessment Model (PAM): Using COBIT® 5*
ISBN 978-1-60420-264-9
Print run 4



Personal Copy of: Mr. Jorge Diab Maluf Filho

# ACKNOWLEDGEMENTS


## ISACA wishes to recognise:

**Development Team**
Gary Allan Banister, CGEIT, CGMA, FCMA, Austria
Barry D. Lewis, CISM, CGEIT, CRISC, CISSP, Cerberus ISC Inc., Canada

**Expert Reviewers**
David Cau, ISO, ITIL, MSP, Prince2, France
Sushil Chatterji, CGEIT, Edutech Enterprises, Singapore
Stuart Cooke, Independent Consultant, UK
James Doss, ITIL Expert, TOGAF 9, PMP, SSGB, EMCCA, EMCISA, Oracle DBA, ITValueQuickStart.com, UK
Kate Gentles, ITValueQuickStart.com, UK
Ferdinand Glatzl, cert. ITSM-Practitioner (Release and Control), BAWAG P.S.K., Austria
Debra Mallette, CISA, CGEIT, CSSBB, Kaiser Permanente, USA
Wil Nixon, CISA, Canada
Max Shanahan, CISA, CGEIT, FCPA, MACS, MIIA (Aust.), Max Shanahan & Associates, Australia
Roger Southgate, CISA, CISM, UK
Greet Volders, CGEIT, Voquals N.V., Belgium

**ISACA Board of Directors**
Gregory T. Grocholski, CISA, The Dow Chemical Co., USA, International President
Allan Boardman, CISA, CISM, CGEIT, CRISC, ACA, CA (SA), CISSP, Morgan Stanley, UK, Vice President
Juan Luis Carselle, CISA, CGEIT, CRISC, Wal-Mart, Mexico, Vice President
Christos K. Dimitriadis, Ph.D., CISA, CISM, CRISC, INTRALOT S.A., Greece, Vice President
Ramses Gallego, CISM, CGEIT, CCSK, CISSP, SCPM, 6 Sigma, Quest Software, Spain, Vice President
Tony Hayes, CGEIT, AFCHSE, CHE, FACS, FCPA, FIIA, Queensland Government, Australia, Vice President
Jeff Spivey, CRISC, CPP, PSP, Security Risk Management Inc., USA, Vice President
Marc Vael, Ph.D., CISA, CISM, CGEIT, CRISC, CISSP, Valuendo, Belgium, Vice President
Kenneth L. Vander Wal, CISA, CPA, Ernst & Young LLP (retired), USA, Past International President
Emil D'Angelo, CISA, CISM, Bank of Tokyo-Mitsubishi UFJ Ltd. (retired), USA, Past International President
John Ho Chi, CISA, CISM, CRISC, CBCP, CFE, Ernst & Young LLP, Singapore, Director
Krysten McCabe, CISA, The Home Depot, USA, Director
Jo Stewart-Rattray, CISA, CISM, CGEIT, CRISC, CSEPS, BRM Holdich, Australia, Director

**Knowledge Board**
Marc Vael, Ph.D., CISA, CISM, CGEIT, CRISC, CISSP, Valuendo, Belgium, Chairman
Rosemary M. Amato, CISA, CMA, CPA, Deloitte Touche Tohmatsu Ltd., The Netherlands
Steven A. Babb, CGEIT, CRISC, Betfair, UK
Thomas E. Borton, CISA, CISM, CRISC, CISSP, Cost Plus, USA
Phil J. Lageschulte, CGEIT, CPA, KPMG LLP, USA
Jamie Pasfield, CGEIT, ITIL V3, MSP, PRINCE 2, Pfizer, USA
Salomon Rico, CISA, CISM, CGEIT, Deloitte LLP, Mexico

**Framework Committee**
Steven A. Babb, CGEIT, CRISC, Betfair, UK, Chairman
Charles Betz, Enterprise Management Associates, USA
David Cau, ISO, ITIL, MSP, Prince2, France
Sushil Chatterji, CGEIT, Edutech Enterprises, Singapore
Frank J. Cindrich, CGEIT, CIPP, CIPP/G, Deloitte & Touche LLP, USA
Jimmy Heschl, CISA, CISM, CGEIT, ITIL Expert, bwin.party digital entertainment plc, Austria
Anthony P. Noble, CISA, Viacom, USA
Andre Pitkowski, CGEIT, CRISC, APIT Informatica, Brazil
Paras Kesharichand Shah, CISA, CGEIT, CRISC, CA, Australia




Personal Copy of: Mr. Jorge Diab Maluf Filho

## Acknowledgements *(cont.)*

**ISACA and IT Governance Institute® (ITGI®) Affiliates and Sponsors**
Information Security Forum
Institute of Management Accountants Inc.
ISACA chapters
ITGI France
ITGI Japan
Norwich University
Socitum Performance Management Group
Solvay Brussels School of Economics and Management
Strategic Technology Management Institute (STMI) of the National University of Singapore
University of Antwerp Management School

ASIS International
Hewlett-Packard
IBM
Symantec Corp.



Personal Copy of: Mr. Jorge Diab Maluf Filho

# Table of Contents

**1.0 Introduction** ..... 7
1.1 Purpose ..... 7
1.2 Scope ..... 7
1.3 Assessment Domain ..... 7
1.4 Normative References ..... 7
1.5 The COBIT 5 Process Assessment Model ..... 7
1.6 Comparison of the COBIT 4.1 PAM to the COBIT 5 PAM ..... 8
1.7 Terms and Definitions ..... 9

**2.0 Overview of the COBIT 5 Process Assessment Model** ..... 11
2.1 Introduction ..... 11
2.2 The Process Dimension—COBIT 5 Processes ..... 11
2.3 The Capability Dimension ..... 13
2.4 Assessment Indicators ..... 14
2.5 Rating Scale ..... 14

**3.0 Process Dimension and Process Performance Indicators** ..... 15
3.1 Evaluate, Direct and Monitor (EDM) ..... 17
3.2 Align, Plan and Organise (APO) ..... 29
3.3 Build, Acquire and Implement (BAI) ..... 65
3.4 Deliver, Service and Support (DSS) ..... 91
3.5 Monitor, Evaluate and Assess (MEA) ..... 105

**4.0 Process Capability Indicators** ..... 115
4.1 Level 1—Performed Process ..... 115
4.2 Level 2—Managed Process ..... 115
4.3 Level 3—Established Process ..... 117
4.4 Level 4—Predictable Process ..... 120
4.5 Level 5—Optimising Process ..... 121

**Appendix A. Conformity of the COBIT 5 Process Assessment Model** ..... 125
A.1 Introduction ..... 125
A.2 Requirements for Process Assessment Models (From ISO/IEC 15504-2) ..... 125

**Appendix B. Generic and Level 1 Output Work Products** ..... 127
B.1 Generic Work Products (GWPs) ..... 127
B.2 Level 1 Output Work Products ..... 130



Personal Copy of: Mr. Jorge Diab Maluf Filho

**Page intentionally left blank**



Personal Copy of: Mr. Jorge Diab Maluf Filho

# 1.0 Introduction

## 1.1 Purpose

This publication outlines a process assessment model (PAM) based on COBIT 5 that is compliant with International Organization for Standardization (ISO)/International Electrotechnical Commission (IEC) 15504.

The model is the basis for the assessment of an enterprise's IT process capabilities against COBIT 5 and a training and certification programme for assessors. The assessment process is evidenced-based to enable a reliable, consistent and repeatable assessment process in the area of governance and management of IT.

The assessment model enables assessments by enterprises to support process improvement. Guidance is given in a separate assessor guide on a scoping approach to select the processes to be assessed, including the use of ISACA's published COBIT 5 mappings to determine the processes to be assessed. These mappings include:
- Linking enterprise goals to enterprise-related IT goals
- Linking enterprise-related IT goals to IT processes
- A diagnostic tool for selecting scoping areas

## 1.2 Scope

This document defines the COBIT 5 PAM that supports the performance of an assessment by providing indicators for guidance on the interpretation of the process purposes and outcomes as defined in COBIT 5 and the process attributes as defined in ISO/IEC 15504-2.

The COBIT 5 PAM is composed of a set of indicators of process performance and process capability. The indicators are used as a basis for collecting the objective evidence that enables an assessor to assign ratings.

## 1.3 Assessment Domain

The COBIT 5 process assessment covers the assessment of those processes required for governance and management of IT and related services as described in COBIT 5.

## 1.4 Normative References

The following documents are referenced in this publication:
- ISACA, COBIT 5, USA, 2012
- ISO/IEC 15504-1:2004, *Information technology—Process assessment—Part 1: Concepts and vocabulary*
- ISO/IEC 15504-2:2003, *Information technology—Process assessment—Part 2: Performing an assessment*

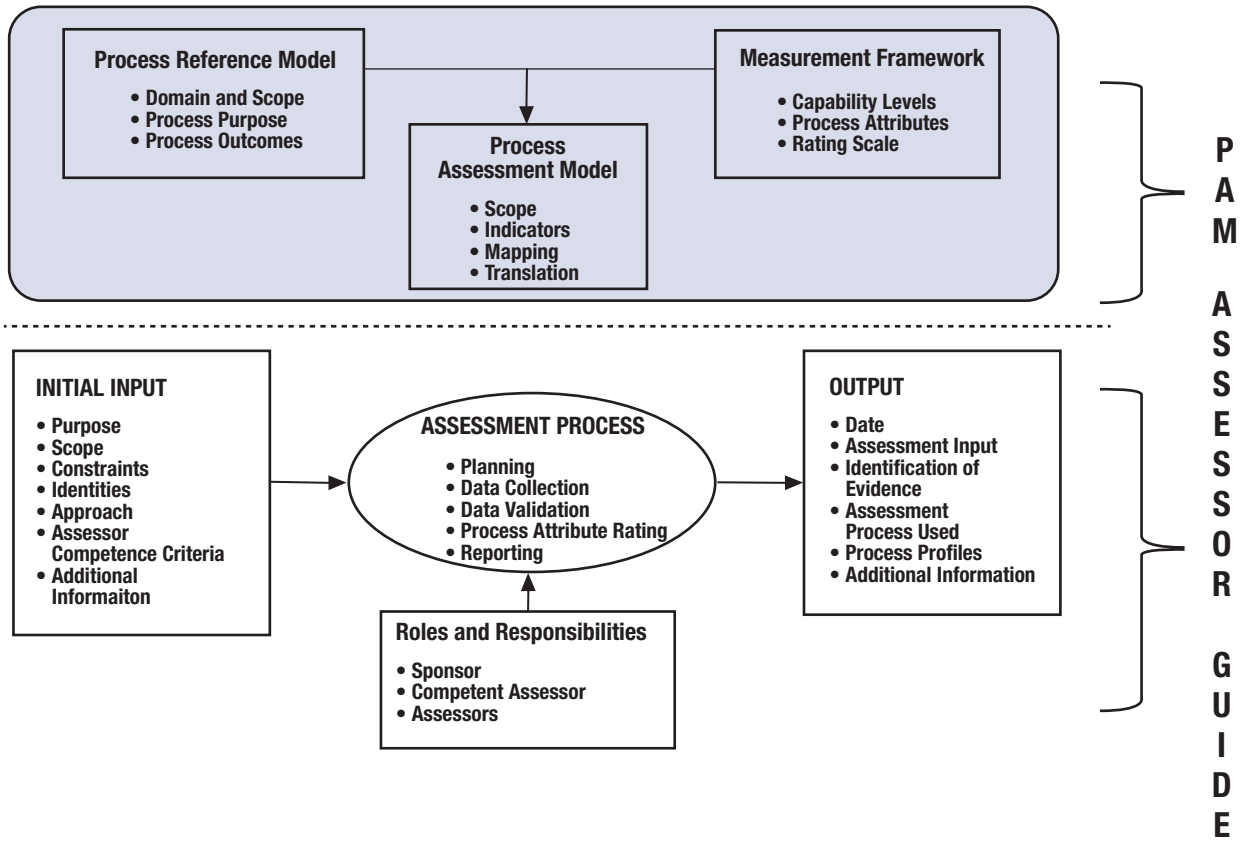
## 1.5 The COBIT 5 Process Assessment Model

A crucial component of the COBIT assessment programme is the COBIT PAM, as shown in **figure 1**. It provides the basis for:
- The process reference model, which defines level 1 base requirements
- Determining the capability levels (the measurement framework)



Personal Copy of: Mr. Jorge Diab Maluf Filho

**Figure 1—The COBIT PAM and the Assessor Guide**




Source: This figure is reproduced from ISO/IEC 15504-2, with the permission of ISO/IEC at *www.iso.org*. Copyright remains with ISO/IEC.

The PAM combines COBIT 5 process details with ISO/IEC 15504-2 and provides the basis for a robust, dependable assessment approach.

*COBIT® Assessor Guide: Using COBIT 5* is a companion publication that describes in detail how to undertake an assessment based on ISO/IEC 15504-2.

*COBIT® Self-assessment Guide: Using COBIT 5* is an alternative assessment guide describing a less rigorous approach, as a simpler entry point to this type of assessment activity.

## 1.6 Comparison of the COBIT 4.1 PAM to the COBIT 5 PAM

One of the primary differences between the COBIT 4.1 PAM and the COBIT 5 PAM concerns the distinction made between governance and management. COBIT 5 is based on a revised process reference model with a new governance domain and several new and modified processes that now cover enterprise activities end-to-end—i.e., business and IT functional areas.

In COBIT 5 every enterprise is expected to implement a number of governance processes and a number of management processes. All processes require 'planning', 'building', 'running' and 'monitoring'. The COBIT 5 process reference model subdivides the IT-related practices and activities of the enterprise into two main areas—governance and management—with management further divided into domains of processes.

Adding the governance domain gives COBIT 5 one more domain than COBIT 4.1. COBIT 5 has a governance domain with five new governance processes and four management domains with thirty-two management processes.

COBIT 5 incorporates ISACA's Val IT 2.0 and Risk IT processes into the framework, making it a more comprehensive version than COBIT 4.1. Figures 15 and 16 in *COBIT® 5: Enabling Processes* outline where each Val IT and Risk IT practice can be found. In addition, COBIT 5 adds the stakeholder needs concept to the goals cascade, which relates directly to a set of generic enterprise goals. The COBIT 5 goals cascade translates stakeholder needs into specific, attainable and customised goals within the context of the enterprise and IT-related goals, and an enabler model provides the framework for linking these goals to enabler goals.



Personal Copy of: Mr. Jorge Diab Maluf Filho

There are several new and modified processes that reflect current thinking, in particular:
- APO03 Manage enterprise architecture.
- APO04 Manage innovation.
- APO05 Manage portfolio.
- APO06 Manage budget and costs.
- APO08 Manage relationships.
- APO13 Manage security.
- BAI05 Manage organisational change enablement.
- BAI08 Manage knowledge.
- BAI09 Manage assets.
- DSS05 Manage security services.
- DSS06 Manage business process controls.

COBIT 5 follows the same goal and metric concepts as COBIT 4.1, Val IT and Risk IT, but these are renamed enterprise goals, IT-related goals and process goals reflecting an enterprise-level view. COBIT 5 also provides a revised goals cascade based on enterprise goals driving IT-related goals and then being supported by critical processes. In addition, COBIT 5 provides examples of goals and metrics at the enterprise and process levels. This is a change from COBIT 4.1, Val IT and Risk IT; COBIT 5 goes one level lower to the management practice level and provides inputs and outputs. Finally, COBIT 5 provides inputs and outputs for every management practice, whereas COBIT 4.1 provided these only at the process level.

## 1.7 Terms and Definitions

For the purposes of this document, the terms and definitions given in ISO/IEC 15504-1 apply. Key definitions include:
- **Attribute indicator**—An assessment indicator that supports the judgement of the extent of achievement of a specific process attribute (ISO/IEC 15504:1, 3.16)
- **Base practice**—An activity that, when consistently performed, contributes to achieving a specific process purpose (ISO/IEC 15504:1, 3.17)
- **Capability dimension**—The set of elements in a process assessment model explicitly related to the Measurement Framework for Process Capability (ISO/IEC 15504:1, 3.18)
- **Capability indicator**—An assessment indicator that supports the judgement of the process capability of a specific process (ISO/IEC 15504:1, 3.19)
- **Generic practice**—An activity that, when consistently performed, contributes to the achievement of a specific process attribute (ISO/IEC 15504:1, 3.22)
- **Performance indicator**—An assessment indicator that supports the judgement of the process performance of a specific process (ISO/IEC 15504:1, 3 26)
  **Note:** A performance indicator is an attribute indicator for Process Attribute 1.1 for a specific process. (ISO/IEC 15504:2)
- **Process assessment model**—A model suitable for the purpose of assessing process capability, based on one or more process reference models (ISO/IEC 15504:1, 3.33)
- **Process attribute**—A measurable characteristic of process capability applicable to any process (ISO/IEC 15504:1, 3.31)
- **Process attribute rating**—A judgement of the degree of achievement of the process attribute for the assessed process (ISO/IEC 15504:1, 3.32)
- **Process capability**—A characterisation of the ability of a process to meet current or projected business goals (ISO/IEC 15504:1, 3.33)
- **Process capability level**—A point on the six-point ordinal scale (of process capability) that represents the capability of the process, each level building on the capability of the level below (ISO/IEC 15504:1, 3.36)
- **Process capability level rating**—A representation of the achieved process capability level derived from the process attribute ratings for an assessed process (ISO/IEC 15504:1, 3.37)
- **Process outcome**—An observable result of a process (ISO/IEC 15504:1, 3.44)
  **Note:** An outcome is an artefact, a significant change of state or the meeting of specified constraints.
- **Process purpose**—The high-level measurable objectives of performing the process and the likely outcomes of effective implementation of the process (ISO/IEC 15504:1, 3.47)
- **Process reference model**—A model composed of definitions of processes in a life cycle described in terms of process purpose and outcomes, together with an architecture describing the relationships amongst the processes (ISO/IEC 15504:1, 3.48)
- **Work product**—An artefact associated with the execution of a process (ISO/IEC 15504:1, 3.55)



Personal Copy of: Mr. Jorge Diab Maluf Filho

**Page intentionally left blank**



Personal Copy of: Mr. Jorge Diab Maluf Filho

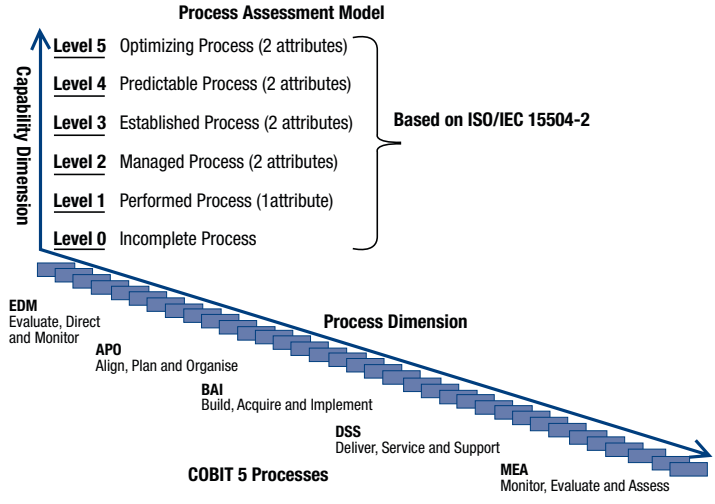
# 2.0 Overview of the COBIT 5 Process Assessment Model

## 2.1 Introduction

The process assessment model is a two-dimensional model of process capability, as shown in **figure 2**. In one dimension, the process dimension, the processes are defined and classified into process categories. In the other dimension, the capability dimension, a set of process attributes grouped into capability levels is defined. The process attributes provide the measurable characteristics of process capability.

The process assessment model defined in this document conforms to ISO/IEC 15504-2 requirements for a process assessment model and can be used as the basis for conducting an assessment of the capability of each COBIT 5 process.

**Figure 2—Overview of the Process Assessment Model (PAM)**



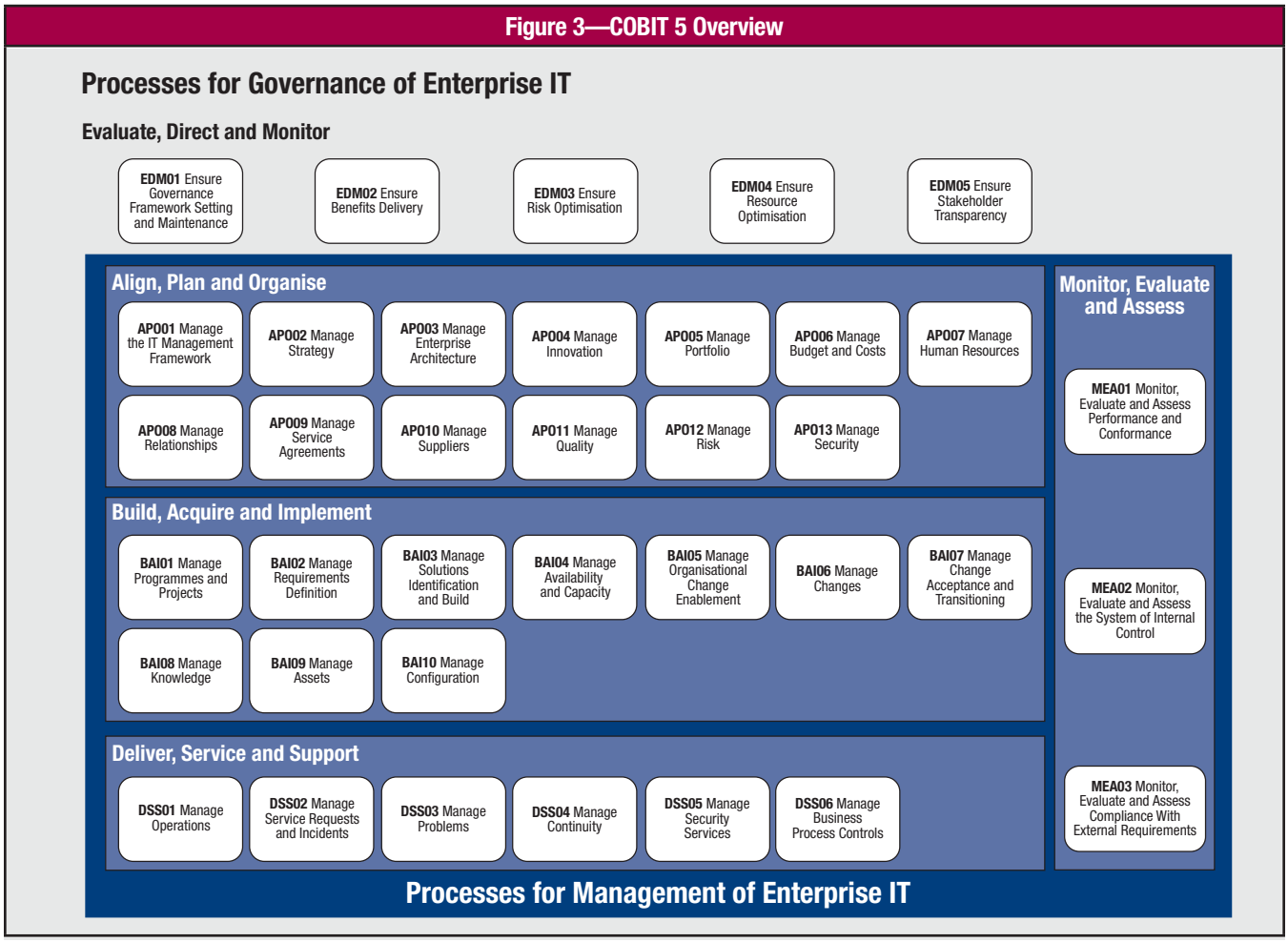

Source: This figure is adapted from ISO/IEC 15504-2:2003 with the permission of ISO at *www.iso.org*. Copyright remains with ISO.

## 2.2 The Process Dimension—COBIT 5 Processes

The process dimension uses COBIT 5 as the process reference model. COBIT 5 provides definitions of processes in a life cycle (the process reference model), together with an architecture describing the relationships amongst the processes.

The COBIT 5 process reference model (PRM) is composed of 37 processes describing a life cycle for governance and management of enterprise IT, as shown in **figure 3**.

**Figure 3—COBIT 5 Overview**






Personal Copy of: Mr. Jorge Diab Maluf Filho

The COBIT 5 process reference model subdivides the processes of enterprise IT into two main areas of activity—governance and management—divided into domains of processes:

- **Governance**—This domain contains five governance processes; within each process, evaluate, direct and monitor (EDM) practices are defined.
- **Management**—This area contains four domains that are in line with the responsibility areas of plan, build, run and monitor (PBRM), and they provide end-to-end coverage of IT. Each domain contains a number of processes, as in COBIT 4.1 and previous versions. Although most of the processes require 'planning', 'building', 'running' and 'monitoring' activities within the process or within the specific issue being addressed—e.g., quality, security—they are placed in domains in line with what is generally the most relevant area of activity when regarding IT at the enterprise level.

The domains are:

- **Evaluate, Direct and Monitor (EDM)**—These governance processes deal with the stakeholder governance objectives—value delivery, risk optimisation and resource optimisation—and include practices and activities aimed at evaluating strategic options, providing direction to IT and monitoring the outcome.
- **Align, Plan and Organise (APO)**—Provides direction to solution delivery (BAI) and service delivery and support (DSS). This domain covers strategy and tactics, and concerns identifying the best way IT can contribute to the achievement of the business objectives. The realisation of the strategic vision needs to be planned, communicated and managed for different perspectives. A proper organisation, as well as technological infrastructure, should be put in place.
- **Build, Acquire and Implement (BAI)**—Provides the solutions and passes them on to be turned into services. To realise the IT strategy, IT solutions need to be identified, developed or acquired, as well as implemented and integrated into the business process. Changes in and maintenance of existing systems are also covered by this domain, to ensure that the solutions continue to meet business objectives.
- **Deliver, Service and Support (DSS)**—Receives the solutions and makes them usable for end users. This domain is concerned with the actual delivery and support of required services, which include service delivery, management of security and continuity, service support for users, and management of data and operational facilities.
- **Monitor, Evaluate and Assess (MEA)**—Monitors all processes to ensure that the direction provided is followed. All IT processes need to be regularly assessed over time for their quality and compliance with control requirements. This domain addresses performance management, monitoring of internal control, regulatory compliance and governance.

Across the five domains there are 37 defined IT processes. The COBIT 5 processes are as follows:

- EDM01 Ensure governance framework setting and maintenance.
- EDM02 Ensure benefits delivery.
- EDM03 Ensure risk optimisation.
- EDM04 Ensure resource optimisation.
- EDM05 Ensure stakeholder transparency.
- APO01 Manage the IT management framework.
- APO02 Manage strategy.
- APO03 Manage enterprise architecture.
- APO04 Manage innovation.
- APO05 Manage portfolio.
- APO06 Manage budget and costs.
- APO07 Manage human resources.
- APO08 Manage relationships.
- APO09 Manage service agreements.
- APO10 Manage suppliers.
- APO11 Manage quality.
- APO12 Manage risk.
- APO13 Manage security.
- BAI01 Manage programmes and projects.
- BAI02 Manage requirements definition.
- BAI03 Manage solutions identification and build.
- BAI04 Manage availability and capacity.
- BAI05 Manage organisational change enablement.
- BAI06 Manage changes.
- BAI07 Manage change acceptance and transitioning.
- BAI08 Manage knowledge.
- BAI09 Manage assets.
- BAI10 Manage configuration.



Personal Copy of: Mr. Jorge Diab Maluf Filho

- DSS01 Manage operations.
- DSS02 Manage service requests and incidents.
- DSS03 Manage problems.
- DSS04 Manage continuity.
- DSS05 Manage security services.
- DSS06 Manage business process controls.
- MEA01 Monitor, evaluate and assess performance and conformance.
- MEA02 Monitor, evaluate and assess the system of internal control.
- MEA03 Monitor, evaluate and assess compliance with external requirements.

## 2.3 The Capability Dimension

The capability dimension provides a measure of a process's capability to meet an enterprise's current or projected business goals for the process.

The process capability is expressed in terms of process attributes grouped into capability levels, as shown in **figure 4**. The capability level of a process is determined on the basis of the achievement of specific process attributes according to ISO/IEC 15504-2:2003.

**Figure 4—Capability Levels and Process Attributes**

| Process Attribute ID | Capability Levels and Process Attributes |
|---|---|
| | **Level 0: Incomplete process** |
| | **Level 1: Performed process** |
| **PA 1.1** | Process performance |
| | **Level 2: Managed process** |
| **PA 2.1** | Performance management |
| **PA 2.2** | Work product management |
| | **Level 3: Established process** |
| **PA 3.1** | Process definition |
| **PA 3.2** | Process deployment |
| | **Level 4: Predictable process** |
| **PA 4.1** | Process measurement |
| **PA 4.2** | Process control |
| | **Level 5: Optimizing process** |
| **PA 5.1** | Process innovation |
| **PA 5.2** | Process optimization |

Source: This figure is adapted from ISO/IEC 15504-2:2003 with the permission of ISO at *www.iso.org*. Copyright remains with ISO.

The rating scale involves six capability levels as follows.

- **Level 0 Incomplete process**—The process is not implemented or fails to achieve its process purpose. At this level, there is little or no evidence of any systematic achievement of the process purpose.
- **Level 1 Performed process (one attribute)**—The implemented process achieves its process purpose.
- **Level 2 Managed process (two attributes)**—The previously described performed process is now implemented in a managed fashion (planned, monitored and adjusted) and its work products are appropriately established, controlled and maintained.
- **Level 3 Established process (two attributes)**—The previously described managed process is now implemented using a defined process that is capable of achieving its process outcomes.
- **Level 4 Predictable process (two attributes)**—The previously described established process now operates within defined limits to achieve its process outcomes.
- **Level 5 Optimizing process (two attributes)**—The previously described predictable process is continuously improved to meet relevant current and projected business goals.



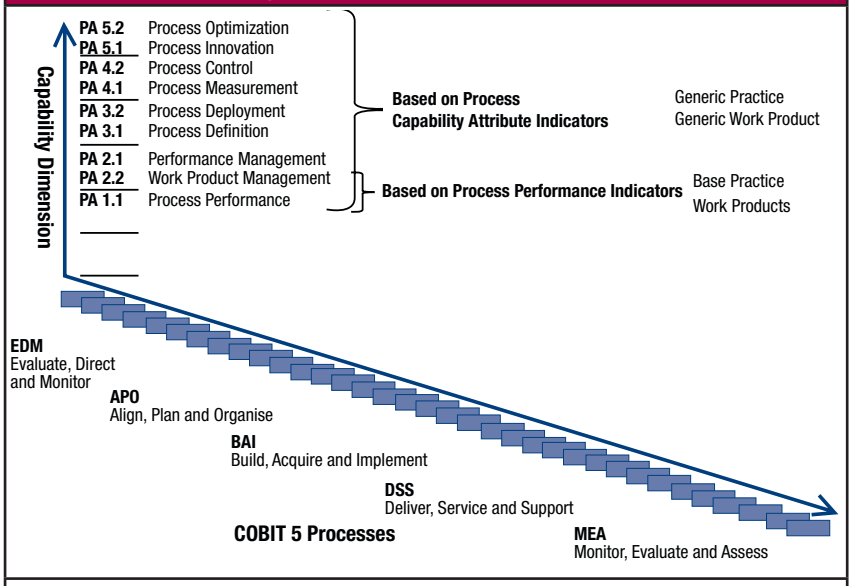
Personal Copy of: Mr. Jorge Diab Maluf Filho

## 2.4 Assessment Indicators

Assessment indicators, shown in **figure 5**, are used to assess whether process attributes have been achieved. There are two types of assessment indicators:
- Process capability attribute indicators, which apply to capability levels 1 to 5
- Process performance indicators, which apply exclusively to capability level 1

Process performance indicators (base practices and work products) are specific for each process and are used to determine whether a process is at capability level 1. These performance indicators consist of base practices and work products and are exclusive to level 1. The base practices and work products for each COBIT 5 process are shown in section 3.0. These are based on COBIT 5 content.

**Figure 5—Assessment Indicators**




Source: This figure is adapted from ISO/IEC 15504-2:2003 with the permission of ISO at *www.iso.org*. Copyright remains with ISO.

The process capability attribute indicators are generic for each process attribute for capability levels 1 to 5. Level 1, however, has only a single generic practice indicator for capability that aligns directly to the achievement of the specific performance indicators outlined in the process reference model in section 3.0.

The process capability attribute indicators used in the COBIT 5 process capability assessment are:
- Generic practice (GP)
- Generic work product (GWP)

These are shown in section 4.0.

## 2.5 Rating Scale

Each attribute is rated using a standard rating scale defined in the ISO/IEC 15504 standard. These ratings consist of:
- **N**—Not achieved. There is little or no evidence of achievement of the defined attribute in the assessed process.
- **P**—Partially achieved. There is some evidence of an approach to, and some achievement of, the defined attribute in the assessed process. Some aspects of achievement of the attribute may be unpredictable.
- **L**—Largely achieved. There is evidence of a systematic approach to, and significant achievement of, the defined attribute in the assessed process. Some weakness related to this attribute may exist in the assessed process.
- **F**—Fully achieved. There is evidence of a complete and systematic approach to, and full achievement of, the defined attribute in the assessed process. No significant weaknesses related to this attribute exist in the assessed process.

There is a need to ensure a consistent degree of interpretation when deciding which rating to assign. The table in **figure 6** describes the rating in terms of the percentage achieved.

**Figure 6—Rating Levels**

| Abbreviation | Description | % Achieved |
|---|---|---|
| N | Not achieved | 0 to 15% achievement |
| P | Partially achieved | >15% to 50% achievement |
| L | Largely achieved | >50% to 85% achievement |
| F | Fully achieved | >85% to 100% achievement |

Source: This figure is reproduced from ISO/IEC 15504-2:2003, with the permission of ISO/IEC at *www.iso.org*. Copyright remains with ISO/IEC.

The assessor uses these scales to determine the level of capability achieved. Applied consistently, these criteria allow each assessment to be based on a structured degree of formality and enable the comparison of assessments across an organisation or even across different enterprises.



Personal Copy of: Mr. Jorge Diab Maluf Filho

# 3.0 Process Dimension and Process Performance Indicators

This section defines the processes and the process performance indicators, also known as the process dimension, of the process assessment model. The processes in the process dimension can be directly mapped to the processes defined in the process reference model.

The individual processes are described in terms of process name, purpose and outcomes (Os), based on COBIT 5. In addition, the process dimension of the process assessment model provides information in the form of:
- Base practices (BPs) for the process, providing a definition of the tasks and activities needed to accomplish the process purpose and fulfil the process outcomes. Each BP is explicitly associated to a process outcome. These have been derived directly from COBIT 5 process reference guide process outcomes goals.
- Input and output work products (WPs) associated with each process and related to one or more of its outcomes
- Characteristics associated with each WP

The process purposes, Os, BPs and WPs associated with the processes are included in this section. The WPs are defined in appendix B, section B.2.

The BPs and WPs constitute the set of indicators of process performance. The associated WPs listed in this clause may be used when reviewing potential inputs and outputs of an organisation's process implementation.

The associated WPs provide objective guidance to look for potential inputs and outputs, and objective evidence to support the assessment of a particular process. A documented assessment process and the assessor judgement are needed to ensure that process context (application domain, business purpose, development methodology, size of the enterprise, etc.) is explicitly considered when using this information.

This list of WPs should not be considered a checklist of what each organisation must have, but rather as an example and starting point for considering whether, given the context, the WPs are necessary and contribute to the intended purpose of the process.

It should be noted that WPs for some processes provide higher capability requirements for other processes. This will result in a progressive implementation of processes. The initial focus on any process assessment would be the core (sometimes called primary) processes, which are primarily part of the BAI and DSS domains. Processes in the APO and MEA domains will be required to support improvement in the capability of these core processes past level 1. An example is APO01 *Manage the IT management framework*, which is required as part of establishing the IT process framework, to document roles and responsibilities required by processes at capability level 2.

The COBIT 5 inputs and outputs are the process work products/artefacts considered necessary to support operation of the process. They enable key decisions, provide a record and audit trail of process activities, and enable follow-up in the event of an incident. They are defined at the key governance/management practice level, may include some work products used only within the process, and are often essential inputs to other processes. While input and output processes are shown and are used to help ensure appropriate operation of the process, output work products can be considered the most important aspect.

The following section deals with the PRM, which is specifically developed for level 1 performance objectives. Levels 2 through 5 are less specific and are indicated as GWPs.

## Inputs and Outputs

The detailed process descriptions contain—at the level of the governance and management practices—inputs and outputs. In general, each output is sent to one or a limited number of destinations, typically another COBIT process practice. That output then becomes an input to its destination. However, there are a number of outputs that have many destinations, e.g., all COBIT processes, or all processes within a domain. For readability reasons, these outputs are NOT listed as inputs in these processes. A complete list of such outputs is included in **figure 7**.

For some inputs/outputs, the destination 'internal' is mentioned. This means that the input/output is between activities within the same process.



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Figure 7—Outputs | | |
|---|---|---|
| **Outputs to all Processes** | | |
| **Practice Work Product** | **Output Description** | **Destination** |
| APO13-WP3 | Information security risk treatment plan | All EDM; All APO; All BAI; All DSS; All MEA |
| **Outputs to all Governance Processes** | | |
| **Practice Work Product** | **Output Description** | **Destination** |
| EDM01-WP1 | Enterprise governance guiding principles | All EDM |
| EDM01-WP2 | Decision-making model | All EDM |
| EDM01-WP3 | Authority levels | All EDM |
| EDM01-WP4 | Enterprise governance communications | All EDM |
| EDM01-WP6 | Feedback on governance effectiveness and performance | All EDM |
| **Outputs to all Management Processes** | | |
| **Practice Work Product** | **Output Description** | **Destination** |
| APO01-WP3 | Communication ground rules | All APO; All BAI; All DSS; All MEA |
| APO01-WP6 | IT-related policies | All APO; All BAI; All DSS; All MEA |
| APO01-WP7 | Communication on IT objectives | All APO; All BAI; All DSS; All MEA |
| APO01-WP14 | Process improvement opportunities | All APO; All BAI; All DSS; All MEA |
| APO02-WP14 | Communication package | All APO; All BAI; All DSS; All MEA |
| APO11-WP4 | Quality management standards | All APO; All BAI; All DSS; All MEA |
| APO11-WP9 | Process quality of service goals and metrics | All APO; All BAI; All DSS; All MEA |
| APO11-WP12 | Communications on continual improvement and best practices | All APO; All BAI; All DSS; All MEA |
| APO11-WP13 | Examples of good practice to be shared | All APO; All BAI; All DSS; All MEA |
| APO11-WP14 | Quality review benchmark results | All APO; All BAI; All DSS; All MEA |
| MEA01-WP3 | Monitoring targets | All APO; All BAI; All DSS; All MEA |
| MEA01-WP5 | Performance reports | All APO; All BAI; All DSS; All MEA |
| MEA01-WP6 | Remedial actions and assignments | All APO; All BAI; All DSS; All MEA |
| MEA02-WP1 | Results of internal control monitoring and reviews | All APO; All BAI; All DSS; All MEA |
| MEA02-WP2 | Results of benchmarking and other evaluations | All APO; All BAI; All DSS; All MEA |
| MEA02-WP4 | Self-assessment plans and criteria | All APO; All BAI; All DSS; All MEA |
| MEA02-WP6 | Results of reviews of self-assessments | All APO; All BAI; All DSS; All MEA |
| MEA02-WP7 | Control deficiencies | All APO; All BAI; All DSS; All MEA |
| MEA02-WP8 | Remedial actions | All APO; All BAI; All DSS; All MEA |
| MEA02-WP11 | Assurance plans | All APO; All BAI; All DSS; All MEA |
| MEA02-WP16 | Refined scope | All APO; All BAI; All DSS; All MEA |
| MEA02-WP17 | Assurance review results | All APO; All BAI; All DSS; All MEA |
| MEA02-WP18 | Assurance review report | All APO; All BAI; All DSS; All MEA |
| MEA03-WP4 | Communications of changed compliance requirements | All APO; All BAI; All DSS; All MEA |



Personal Copy of: Mr. Jorge Diab Maluf Filho

# 3.1 Evaluate, Direct and Monitor (EDM)

**01** Ensure governance framework setting and maintenance.

**02** Ensure benefits delivery.

**03** Ensure risk optimisation.

**04** Ensure resource optimisation.

**05** Ensure stakeholder transparency.



Personal Copy of: Mr. Jorge Diab Maluf Filho

**Page intentionally left blank**



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | EDM01 | |
|---|---|---|
| **Process Name** | **Ensure Governance Framework Setting and Maintenance** | |
| **Process Description** | Analyse and articulate the requirements for the governance of enterprise IT, and put in place and maintain effective enabling structures, principles, processes and practices, with clarity of responsibilities and authority to achieve the enterprise's mission, goals and objectives. | |
| **Process Purpose Statement** | Provide a consistent approach integrated and aligned with the enterprise governance approach. To ensure that IT-related decisions are made in line with the enterprise's strategies and objectives, ensure that IT-related processes are overseen effectively and transparently, compliance with legal and regulatory requirements is confirmed, and the governance requirements for board members are met. | |
| **Outcomes (Os)** | | |
| **Number** | **Description** | |
| EDM01-O1 | Strategic decision-making model for IT is effective and aligned with the enterprise's internal and external environment and stakeholder requirements. | |
| EDM01-O2 | The governance system for IT is implemented in the enterprise. | |
| EDM01-O3 | Assurance is obtained that the governance system for IT is operating effectively. | |
| **Base Practices (BPs)** | | |
| **Number** | **Description** | **Supports** |
| EDM01-BP1 | **Evaluate the governance system.**<br>Continually identify and engage with the enterprise's stakeholders, document an understanding of the requirements, and make judgement on the current and future design of governance of enterprise IT. | EDM01-O1 |
| EDM01-BP2 | **Direct the governance system.**<br>Inform leadership and obtain their support, buy-in and commitment. Guide the structures, processes and practices for the governance of IT in line with agreed-on governance design principles, decision-making models and authority levels. Define the information required for informed decision making. | EDM01-O2 |
| EDM01-BP3 | **Monitor the governance system.**<br>Monitor the effectiveness and performance of the enterprise's governance of IT. Assess whether the governance system and implemented mechanisms (including structures, principles and processes) are operating effectively and provide appropriate oversight of IT. | EDM01-O3 |
| **Work Products (WPs)** | | |
| **Inputs** | | |
| **Number** | **Description** | **Supports** |
| MEA03-WP4 | Communications of changed compliance requirements | EDM01-BP1<br>EDM01-O1 |
| Outside COBIT | • Business environment trends<br>• Regulations<br>• Governance/decision-making model<br>• Constitution/bylaws/statutes of organisation | |
| MEA01-WP5 | Performance reports | EDM01-BP3<br>EDM01-O3 |
| MEA01-WP7 | Status and results of actions | |
| MEA02-WP1 | Results of internal control monitoring and reviews | |
| MEA02-WP2 | Results of benchmarking and other evaluations | |
| MEA02-WP6 | Results of reviews of self-assessments | |
| MEA02-WP11 | Assurance plans | |
| MEA03-WP6 | Compliance confirmations | |
| MEA03-WP7 | Compliance assurance reports | |
| MEA03-WP8 | Reports of non-compliance issues and root causes | |
| Outside COBIT | • Obligations<br>• Audit reports | |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | EDM01 *(cont.)* | | |
|---|---|---|---|
| **Process Name** | **Ensure Governance Framework Setting and Maintenance** | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| EDM01-WP1 | Enterprise governance guiding principles | All EDM<br>AP001.01<br>AP001.03 | EDM01-BP1<br>EDM01-01 |
| EDM01-WP2 | Decision-making model | All EDM<br>AP001.01 | |
| EDM01-WP3 | Authority levels | All EDM<br>AP001.02 | |
| EDM01-WP4 | Enterprise governance communications | All EDM<br>AP001.04 | EDM01-BP2<br>EDM01-02 |
| EDM01-WP5 | Reward system approach | AP007.03<br>AP007.04 | |
| EDM01-WP6 | Feedback on governance effectiveness and performance | All EDM<br>AP001.07 | EDM01-BP3<br>EDM01-03 |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | EDM02 | | |
|---|---|---|---|
| **Process Name** | **Ensure Benefits Delivery** | | |
| **Process Description** | Optimise the value contribution to the business from the business processes, IT services and IT assets resulting from investments made by IT at acceptable costs. | | |
| **Process Purpose Statement** | Secure optimal value from IT-enabled initiatives, services and assets; cost-efficient delivery of solutions and services; and a reliable and accurate picture of costs and likely benefits so that business needs are supported effectively and efficiently. | | |
| **Outcomes (Os)** | | | |
| **Number** | **Description** | | |
| EDM02-O1 | The enterprise is securing optimal value from its portfolio of approved IT-enabled initiatives, services and assets. | | |
| EDM02-O2 | Optimal value is derived from IT investment through effective value management practices in the enterprise. | | |
| EDM02-O3 | Individual IT-enabled investments contribute optimal value. | | |
| **Base Practices (BPs)** | | | |
| **Number** | **Description** | | **Supports** |
| EDM02-BP1 | **Evaluate value optimisation.**<br>Continually evaluate the portfolio of IT-enabled investments, services and assets to determine the likelihood of achieving enterprise objectives and delivering value at a reasonable cost. Identify and make judgement on any changes in direction that need to be given to management to optimise value creation. | | EDM02-01 |
| EDM02-BP2 | **Direct value optimisation.**<br>Direct value management principles and practices to enable optimal value realisation from IT-enabled investments throughout their full economic life cycle. | | EDM02-02 |
| EDM02-BP3 | **Monitor value optimisation.**<br>Monitor the key goals and metrics to determine the extent to which the business is generating the expected value and benefits to the enterprise from IT-enabled investments and services. Identify significant issues and consider corrective actions. | | EDM02-03 |
| **Work Products (WPs)** | | | |
| **Inputs** | | | |
| **Number** | **Description** | | **Supports** |
| APO02-WP12 | Strategic road map | | EDM02-BP1<br>EDM02-01 |
| APO05-WP5 | Investment return expectations | | |
| APO05-WP8 | Selected programmes with return on investment (ROI) milestones | | |
| APO05-WP11 | Benefit results and related communications | | |
| BAI01-WP14 | Stage-gate review results | | |
| APO05-WP9 | Investment portfolio performance reports | | EDM02-BP3<br>EDM02-03 |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| EDM02-WP1 | Evaluation of strategic alignment | APO02.04<br>APO05.03 | EDM02-BP1<br>EDM02-01 |
| EDM02-WP2 | Evaluation of investment and services portfolios | APO05.03<br>APO05.04<br>APO06.02 | |
| EDM02-WP3 | Investment types and criteria | APO05.01<br>APO05.03 | EDM02-BP2<br>EDM02-02 |
| EDM02-WP4 | Requirements for stage-gate reviews | BAI01.01 | |
| EDM02-WP5 | Feedback on portfolio and programme performance | APO05.04<br>APO06.05<br>BAI01.06 | EDM02-BP3<br>EDM02-03 |
| EDM02-WP6 | Actions to improve value delivery | EDM05.01<br>APO05.04<br>APO06.02<br>BAI01.01 | |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

**Page intentionally left blank**



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | EDM03 | | |
|---|---|---|---|
| **Process Name** | **Ensure Risk Optimisation** | | |
| **Process Description** | Ensure that the enterprise's risk appetite and tolerance are understood, articulated and communicated, and that risk to enterprise value related to the use of IT is identified and managed. | | |
| **Process Purpose Statement** | Ensure that IT-related enterprise risk does not exceed risk appetite and risk tolerance, the impact of IT risk to enterprise value is identified and managed, and the potential for compliance failures is minimised. | | |
| **Outcomes (Os)** | | | |
| **Number** | **Description** | | |
| EDM03-O1 | Risk thresholds are defined and communicated and key IT-related risk is known. | | |
| EDM03-O2 | The enterprise is managing critical IT-related enterprise risk effectively and efficiently. | | |
| EDM03-O3 | IT-related enterprise risk does not exceed risk appetite and the impact of IT risk to enterprise value is identified and managed. | | |
| **Base Practices (BPs)** | | | |
| **Number** | **Description** | | **Supports** |
| EDM03-BP1 | **Evaluate risk management.**<br>Continually examine and make judgement on the effect of risk on the current and future use of IT in the enterprise. Consider whether the enterprise's risk appetite is appropriate and that risk to enterprise value related to the use of IT is identified and managed. | | EDM03-01/02 |
| EDM03-BP2 | **Direct risk management.**<br>Direct the establishment of risk management practices to provide reasonable assurance that IT risk management practices are appropriate to ensure that the actual IT risk does not exceed the board's risk appetite. | | EDM03-02/03 |
| EDM03-BP3 | **Monitor risk management.**<br>Monitor the key goals and metrics of the risk management processes and establish how deviations or problems will be identified, tracked and reported for remediation. | | |
| **Work Products (WPs)** | | | |
| **Inputs** | | | |
| **Number** | **Description** | | **Supports** |
| APO12-WP3 | Emerging risk issues and factors | | EDM03-BP1<br>EDM03-01/02 |
| Outside COBIT | Enterprise risk management principles | | |
| APO12-WP8 | Aggregated risk profile, including status of risk management actions | | EDM03-BP2<br>EDM03-02/03 |
| Outside COBIT | Enterprise risk management (ERM) profiles and mitigation plans | | |
| APO12-WP6 | Risk analysis results | | EDM03-BP3<br>EDM03-02/03 |
| APO12-WP9 | Risk analysis and risk profile reports for stakeholders | | |
| APO12-WP10 | Results of third-party risk assessments | | |
| APO12-WP11 | Opportunities for acceptance of greater risk | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| EDM03-WP1 | Risk appetite guidance | APO12.03 | EDM03-BP1<br>EDM03-01/02 |
| EDM03-WP2 | Approved risk tolerance levels | APO12.03 | |
| EDM03-WP3 | Evaluation of risk management activities | APO12.01 | |
| EDM03-WP4 | Risk management policies | APO12.01 | EDM03-BP2<br>EDM03-02/03 |
| EDM03-WP5 | Key objectives to be monitored for risk management | APO12.01 | |
| EDM03-WP6 | Approved process for measuring risk management | APO12.01 | |
| EDM03-WP7 | Remedial actions to address risk management deviations | APO12.06 | EDM03-BP2<br>EDM03-02/03 |
| EDM03-WP8 | Risk management issues for the board | EDM05.01 | |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

**Page intentionally left blank**



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | EDM04 | | |
|---|---|---|---|
| **Process Name** | **Ensure Resource Optimisation** | | |
| **Process Description** | Ensure that adequate and sufficient IT-related capabilities (people, process and technology) are available to support enterprise objectives effectively at optimal cost. | | |
| **Process Purpose Statement** | Ensure that the resource needs of the enterprise are met in the optimal manner, IT costs are optimised, and there is an increased likelihood of benefit realisation and readiness for future change. | | |
| **Outcomes (Os)** | | | |
| **Number** | **Description** | | |
| EDM04-O1 | The resource needs of the enterprise are met with optimal capabilities. | | |
| EDM04-O2 | Resources are allocated to best meet enterprise priorities within budget constraints. | | |
| EDM04-O3 | Optimal use of resources is achieved throughout their full economic life cycles. | | |
| **Base Practices (BPs)** | | | |
| **Number** | **Description** | | **Supports** |
| EDM04-BP1 | **Evaluate resource management.**<br>Continually examine and make judgement on the current and future need for IT-related resources, options for resourcing (including sourcing strategies), and allocation and management principles to meet the needs of the enterprise in the optimal manner. | | EDM04-01 |
| EDM04-BP2 | **Direct resource management.**<br>Ensure the adoption of resource management principles to enable optimal use of IT resources throughout their full economic life cycle. | | EDM04-02/03 |
| EDM04-BP3 | **Monitor resource management.**<br>Monitor the key goals and metrics of the resource management processes and establish how deviations or problems will be identified, tracked and reported for remediation. | | |
| **Work Products (WPs)** | | | |
| **Inputs** | | | |
| **Number** | **Description** | | **Supports** |
| APO02-WP8 | Gaps and changes required to realise target capability | | EDM04-BP1<br>EDM04-01 |
| APO07-WP6 | Skills development plans | | |
| APO10-WP6 | Decision results of supplier evaluations | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| EDM04-WP1 | Guiding principles for allocation of resources and capabilities | APO02.01<br>APO07.01<br>BAI03.11 | EDM04-BP1<br>EDM04-01 |
| EDM04-WP2 | Guiding principles for enterprise architecture | APO03.01 | |
| EDM04-WP3 | Approved resources plan | APO02.05<br>APO07.01<br>APO09.02 | |
| EDM04-WP4 | Communication of resourcing strategies | APO02.06<br>APO07.05<br>APO09.02 | EDM04-BP2<br>EDM04-02/03 |
| EDM04-WP5 | Assigned responsibilities for resource management | APO01.02<br>DSS06.03 | |
| EDM04-WP6 | Principles for safeguarding resources | APO01.04 | |
| EDM04-WP7 | Feedback on allocation and effectiveness of resources and capabilities | EDM05.01<br>APO02.05<br>APO07.05<br>APO09.05 | EDM04-BP3<br>EDM04-02/03 |
| EDM04-WP8 | Remedial actions to address resource management deviations | APO02.05<br>APO07.01<br>APO07.03<br>APO09.04 | |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

**Page intentionally left blank**



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | EDM05 | | |
|---|---|---|---|
| **Process Name** | **Ensure Stakeholder Transparency** | | |
| **Process Description** | Ensure that enterprise IT performance and conformance measurement and reporting are transparent, with stakeholders approving the goals and metrics and the necessary remedial actions. | | |
| **Process Purpose Statement** | Make sure that the communication to stakeholders is effective and timely and the basis for reporting is established to increase performance, identify areas for improvement, and confirm that IT-related objectives and strategies are in line with the enterprise's strategy. | | |
| **Outcomes (Os)** | | | |
| **Number** | **Description** | | |
| EDM05-O1 | Stakeholder reporting is in line with stakeholder requirements. | | |
| EDM05-O2 | Reporting is complete, timely and accurate. | | |
| EDM05-O3 | Communication is effective and stakeholders are satisfied. | | |
| **Base Practices (BPs)** | | | |
| **Number** | **Description** | | **Supports** |
| EDM05-BP1 | **Evaluate stakeholder reporting requirements.** Continually examine and make judgement on the current and future requirements for stakeholder communication and reporting, including both mandatory reporting requirements (e.g., regulatory) and communication to other stakeholders. Establish the principles for communication. | | EDM05-01/02 |
| EDM05-BP2 | **Direct stakeholder communication and reporting.** Ensure the establishment of effective stakeholder communication and reporting, including mechanisms for ensuring the quality and completeness of information, oversight of mandatory reporting, and creating a communication strategy for stakeholders. | | EDM05-02/03 |
| EDM05-BP3 | **Monitor stakeholder communication.** Monitor the effectiveness of stakeholder communication. Assess mechanisms for ensuring accuracy, reliability, and effectiveness, and ascertain whether the requirements of different stakeholders are met. | | |
| **Work Products (WPs)** | | | |
| **Inputs** | | | |
| **Number** | **Description** | | **Supports** |
| EDM02-WP6 | Actions to improve value delivery | | EDM05-BP1<br>EDM05-01/02 |
| EDM03-WP8 | Risk management issues for the board | | |
| EDM04-WP7 | Feedback on allocation and effectiveness of resources and capabilities | | |
| MEA02-WP16 | Refined scope | | |
| APO12-WP9 | Risk analysis and risk profile reports for stakeholders | | EDM05-BP2<br>EDM05-02/03 |
| MEA02-WP17 | Assurance review results | | EDM05-BP3<br>EDM05-02/03 |
| MEA02-WP18 | Assurance review report | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| EDM05-WP1 | Evaluation of enterprise reporting requirements | MEA01.01 | EDM05-BP1<br>EDM05-01/02 |
| EDM05-WP2 | Reporting and communications principles | MEA01.01 | |
| EDM05-WP3 | Rules for validating and approving mandatory reports | MEA01.01<br>MEA03.04 | EDM05-BP2<br>EDM05-02/03 |
| EDM05-WP4 | Escalation guidelines | MEA01.05 | |
| EDM05-WP5 | Assessment of reporting effectiveness | MEA01.01<br>MEA03.04 | EDM05-BP3<br>EDM05-02/03 |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

**Page intentionally left blank**



Personal Copy of: Mr. Jorge Diab Maluf Filho

# 3.2 Align, Plan and Organise (APO)

**01** Manage the IT management framework.

**02** Manage strategy.

**03** Manage enterprise architecture.

**04** Manage innovation.

**05** Manage portfolio.

**06** Manage budget and costs.

**07** Manage human resources.

**08** Manage relationships.

**09** Manage service agreements.

**10** Manage suppliers.

**11** Manage quality.

**12** Manage risk.

**13** Manage security.



Personal Copy of: Mr. Jorge Diab Maluf Filho

**Page intentionally left blank**



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | AP001 | |
|---|---|---|
| Process Name | Manage the IT Management Framework | |
| Process Description | Clarify and maintain the governance of enterprise IT mission and vision. Implement and maintain mechanisms and authorities to manage information and the use of IT in the enterprise in support of governance objectives in line with guiding principles and policies. | |
| Process Purpose Statement | Provide a consistent management approach to enable the enterprise governance requirements to be met, covering management processes, organisational structures, roles and responsibilities, reliable and repeatable activities, and skills and competencies. | |
| Outcomes (Os) | | |
| Number | Description | |
| AP001-01 | An effective set of policies is defined and maintained. | |
| AP001-02 | Everyone is aware of the policies and how they should be implemented. | |
| Base Practices (BPs) | | |
| Number | Description | Supports |
| AP001-BP1 | **Define the organisational structure.**<br>Establish an internal and extended organisational structure that reflects business needs and IT priorities. Put in place the required management structures (e.g., committees) that enable management decision making to take place in the most effective and efficient manner. | AP001-01 |
| AP001-BP2 | **Establish roles and responsibilities.**<br>Establish, agree on and communicate roles and responsibilities of IT personnel, as well as other stakeholders with responsibilities for enterprise IT, that clearly reflect overall business needs and IT objectives and relevant personnel's authority, responsibilities and accountability. | AP001-01/02 |
| AP001-BP3 | **Maintain the enablers of the management system.**<br>Maintain the enablers of the management system and control environment for enterprise IT, and ensure that they are integrated and aligned with the enterprise's governance and management philosophy and operating style. These enablers include the clear communication of expectations/requirements. The management system should encourage cross-divisional co- operation and teamwork, promote compliance and continuous improvement, and handle process deviations (including failure). | AP001-01 |
| AP001-BP4 | **Communicate management objectives and direction.**<br>Communicate awareness and understanding of IT objectives and direction to appropriate stakeholders and users throughout the enterprise. | AP001-02 |
| AP001-BP5 | **Optimise the placement of the IT function.**<br>Position the IT capability in the overall organisational structure to reflect an enterprise model relevant to the importance of IT within the enterprise, specifically its criticality to enterprise strategy and the level of operational dependence on IT. The reporting line of the CIO should be commensurate with the importance of IT within the enterprise. | AP001-01/02 |
| AP001-BP6 | **Define information (data) and system ownership.**<br>Define and maintain responsibilities for ownership of information (data) and information systems. Ensure that owners make decisions about classifying information and systems and protecting them in line with this classification. | AP001-02 |
| AP001-BP7 | **Manage continual improvement of processes.**<br>Assess, plan and execute the continual improvement of processes and their maturity to ensure that they are capable of delivering against enterprise, governance, management and control objectives. Consider COBIT process implementation guidance, emerging standards, compliance requirements, automation opportunities, and the feedback of process users, the process team and other stakeholders. Update the process and consider impacts on process enablers. | AP001-01 |
| AP001-BP8 | **Maintain compliance with policies and procedures.**<br>Put in place procedures to maintain compliance with and performance measurement of policies and other enablers of the control framework, and enforce the consequences of non-compliance or inadequate performance. Track trends and performance and consider these in the future design and improvement of the control framework. | AP001-01 |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | APO01 *(cont.)* | |
|---|---|---|
| **Process Name** | **Manage the IT Management Framework** | |
| **Work Products (WPs)** | | |
| **Inputs** | | |
| **Number** | **Description** | **Supports** |
| EDM01-WP1 | Enterprise governance guiding principles | APO01-BP1<br>APO01-01 |
| EDM01-WP2 | Decision-making model | |
| APO03-WP5 | Process architecture model | |
| EDM01-WP3 | Authority levels | APO01-BP2<br>APO01-01/02 |
| EDM04-WP5 | Assigned responsibilities for resource management | |
| APO07-WP5 | Skills and competencies matrix | |
| APO07-WP6 | Skills development plans | |
| APO11-WP1 | Quality management system (QMS) roles, responsibilities and decision rights | |
| APO13-WP2 | ISMS scope statement | |
| DSS06-WP4 | Allocated roles and responsibilities | |
| DSS06-WP5 | Allocated levels of authority | |
| EDM01-WP1 | Enterprise governance guiding principles | APO01-BP3<br>APO01-01 |
| APO02-WP12 | Strategic road map | |
| APO12-WP3 | Emerging risk issues and factors | |
| APO12-WP6 | Risk analysis results | |
| EDM01-WP4 | Enterprise governance communications | APO01-BP4<br>APO01-02 |
| EDM04-WP6 | Principles for safeguarding resources | |
| APO12-WP14 | Risk impact communication | |
| BAI08-WP1 | Communications on value of knowledge | |
| DSS04-WP1 | Policy and objectives for business continuity | |
| DSS05-WP1 | Malicious software prevention policy | |
| DSS05-WP3 | Connectivity security policy | |
| DSS05-WP5 | Security policies for endpoint devices | |
| Outside COBIT | • Enterprise operating model<br>• Enterprise strategy | APO01-BP5<br>APO01-01/02 |
| EDM01-WP6 | Feedback on governance effectiveness and performance | APO01-BP7<br>APO01-01 |
| MEA03-WP3 | Updated policies, principles, procedures and standards | |
| DSS01-WP7 | Environmental policies | APO01-BP8<br>APO01-01 |
| MEA03-WP3 | Updated policies, principles, procedures and standards | |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | APO01 *(cont.)* | | |
|---|---|---|---|
| **Process Name** | **Manage the IT Management Framework** | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| APO01-WP1 | Definition of organisational structure and functions | APO03.02 | APO01-BP1<br>APO01-01 |
| APO01-WP2 | Enterprise operational guidelines | APO03.02 | |
| APO01-WP3 | Communication ground rules | All APO<br>All BAI<br>All DSS<br>All MEA | |
| APO01-WP4 | Definition of IT-related roles and responsibilities | DSS05.04 | APO01-BP2<br>APO01-01/02 |
| APO01-WP5 | Definition of supervisory practices | APO07.01 | |
| APO01-WP6 | IT-related policies | All APO<br>All BAI<br>All DSS<br>All MEA | APO01-BP3<br>APO01-01 |
| APO01-WP7 | Communication on IT objectives | All APO<br>All BAI<br>All DSS<br>All MEA | APO01-BP4<br>APO01-02 |
| APO01-WP8 | Evaluation of options for IT organisation | APO03.02 | APO01-BP5<br>APO01-01/02 |
| APO01-WP9 | Defined operational placement of IT function | APO03.02 | |
| APO01-WP10 | Data classification guidelines | APO03.02<br>BAI02.01<br>DSS05.02<br>DSS06.01 | APO01-BP6<br>APO01-02 |
| APO01-WP11 | Data security and control guidelines | BAI02.01 | |
| APO01-WP12 | Data integrity procedures | BAI02.01<br>DSS06.01 | |
| APO01-WP13 | Process capability assessments | MEA01.03 | APO01-BP7<br>APO01-01 |
| APO01-WP14 | Process improvement opportunities | All APO<br>All BAI<br>All DSS<br>All MEA | |
| APO01-WP15 | Performance goals and metrics for process improvement tracking | MEA01.02 | |
| APO01-WP16 | Non-compliance remedial actions | MEA01.05 | APO01-BP8<br>APO01-01 |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

**Page intentionally left blank**



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | AP002 | |
|---|---|---|
| **Process Name** | **Manage Strategy** | |
| **Process Description** | Provide a holistic view of the current business and IT environment, the future direction, and the initiatives required to migrate to the desired future environment. Leverage enterprise architecture building blocks and components, including externally provided services and related capabilities to enable nimble, reliable and efficient response to strategic objectives. | |
| **Process Purpose Statement** | Align strategic IT plans with business objectives. Clearly communicate the objectives and associated accountabilities so they are understood by all, with the IT strategic options identified, structured and integrated with the business plans. | |
| **Outcomes (Os)** | | |
| **Number** | **Description** | |
| AP002-01 | All aspects of the IT strategy are aligned with the enterprise strategy. | |
| AP002-02 | The IT strategy is cost-effective, appropriate, realistic, achievable, enterprise-focussed and balanced. | |
| AP002-03 | Clear and concrete short-term goals can be derived from, and traced back to, specific long-term initiatives, and can then be translated into operational plans. | |
| AP002-04 | IT is a value driver for the enterprise. | |
| AP002-05 | There is awareness of the IT strategy and a clear assignment of accountability for delivery. | |
| **Base Practices (BPs)** | | |
| **Number** | **Description** | **Supports** |
| AP002-BP1 | **Understand enterprise direction.**<br>Consider the current enterprise environment and business processes, as well as the enterprise strategy and future objectives. Consider also the external environment of the enterprise (industry drivers, relevant regulations, basis for competition). | AP002-01/02 |
| AP002-BP2 | **Assess the current environment, capabilities and performance.**<br>Assess the performance of current internal business and IT capabilities and external IT services, and develop an understanding of the enterprise architecture in relation to IT. Identify issues currently being experienced and develop recommendations in areas that could benefit from improvement. Consider service provider differentiators and options and the financial impact and potential costs and benefits of using external services. | |
| AP002-BP3 | **Define the target IT capabilities.**<br>Define the target business and IT capabilities and required IT services. This should be based on the understanding of the enterprise environment and requirements; the assessment of the current business process and IT environment and issues; and consideration of reference standards, best practices and validated emerging technologies or innovation proposals. | AP002-03 |
| AP002-BP4 | **Conduct a gap analysis.**<br>Identify the gaps between the current and target environments and consider the alignment of assets (the capabilities that support services) with business outcomes to optimise investment in and utilisation of the internal and external asset base. Consider the critical success factors to support strategy execution. | |
| AP002-BP5 | **Define the strategic plan and road map.**<br>Create a strategic plan that defines, in co-operation with relevant stakeholders, how IT-related goals will contribute to the enterprise's strategic goals. Include how IT will support IT-enabled investment programmes, business processes, IT services and IT assets. Direct IT to define the initiatives that will be required to close the gaps, the sourcing strategy, and the measurements to be used to monitor achievement of goals, then prioritise the initiatives and combine them in a high-level road map. | AP002-04 |
| AP002-BP6 | **Communicate the IT strategy and direction.**<br>Create awareness and understanding of the business and IT objectives and direction, as captured in the IT strategy, through communication to appropriate stakeholders and users throughout the enterprise. | AP002-05 |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | APO02 *(cont.)* | |
|---|---|---|
| **Process Name** | **Manage Strategy** | |
| **Work Products (WPs)** | | |
| **Inputs** | | |
| **Number** | **Description** | **Supports** |
| EDM04-WP1 | Guiding principles for allocation of resources and capabilities | APO02-BP1<br>APO02-01/02 |
| APO04-WP3 | Innovation opportunities linked to business drivers | |
| Outside COBIT | Enterprise strategy and enterprise strengths, weaknesses, opportunities, threats (SWOT) analysis | |
| APO06-WP14 | Cost optimisation opportunities | APO02-BP2<br>APO02-01/02 |
| APO08-WP9 | Definition of potential improvement projects | |
| APO09-WP1 | Identified gaps in IT services to the business | |
| APO09-WP7 | Improvement action plans and remediations | |
| APO12-WP3 | Emerging risk issues and factors | |
| APO12-WP6 | Risk analysis results | |
| APO12-WP8 | Aggregated risk profile, including status of risk management actions | |
| APO12-WP12 | Project proposals for reducing risk | |
| BAI04-WP5 | Prioritised improvements | |
| BAI04-WP6 | Performance and capacity plans | |
| BAI04-WP9 | Corrective actions | |
| BAI09-WP3 | Results of fit-for-purpose reviews | |
| BAI09-WP9 | Results of cost optimisation reviews | |
| BAI09-WP10 | Opportunities to reduce asset costs or increase value | |
| APO04-WP8 | Results and recommendations from proof-of-concept initiatives | APO02-BP3<br>APO02-03 |
| APO04-WP9 | Analysis of rejected initiatives | |
| EDM02-WP1 | Evaluation of strategic alignment | APO02-BP4<br>APO02-03 |
| APO04-WP10 | Assessments of using innovative approaches | |
| APO05-WP5 | Investment return expectations | |
| BAI01-WP11 | Results of programme goal achievement monitoring | |
| BAI01-WP14 | Stage-gate review results | |
| BAI01-WP31 | Post-implementation review results | |
| EDM04-WP3 | Approved resources plan | APO02-BP5<br>APO02-04 |
| EDM04-WP7 | Feedback on allocation and effectiveness of resources and capabilities | |
| EDM04-WP8 | Remedial actions to address resource management deviations | |
| APO03-WP1 | Defined scope of architecture | |
| APO03-WP3 | Architecture concept business case and value proposition | |
| APO03-WP6 | Information architecture model | |
| APO03-WP7 | High-level implementation and migration strategy | |
| APO03-WP8 | Transition architectures | |
| APO05-WP3 | Feedback on strategy and goals | |
| APO05-WP4 | Funding options | |
| APO06-WP5 | Budget allocations | |
| APO06-WP6 | IT budget and plan | |
| APO06-WP7 | Budget communications | |
| APO13-WP4 | Information security business cases | |
| BAI09-WP13 | Action plan to adjust licence numbers and allocations | |
| DSS04-WP6 | Approved strategic options | |
| EDM04-WP4 | Communication of resourcing strategies | APO02-BP6<br>APO02-05 |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | APO02 *(cont.)* | | |
|---|---|---|---|
| **Process Name** | **Manage Strategy** | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| APO02-WP1 | Sources and priorities for changes | Internal | APO02-BP1<br>APO02-01/02 |
| APO02-WP2 | Baseline of current capabilities | Internal | APO02-BP2<br>APO02-01/02 |
| APO02-WP3 | Gaps and risk related to current capabilities | APO12.01 | |
| APO02-WP4 | Capability SWOT analysis | Internal | |
| APO02-WP5 | High-level IT-related goals | Internal | APO02-BP3<br>APO02-03 |
| APO02-WP6 | Required business and IT capabilities | Internal | |
| APO02-WP7 | Proposed enterprise architecture changes | APO03.03 | |
| APO02-WP8 | Gaps and changes required to realise target capability | EDM04.01<br>APO13.02<br>BAI03.11 | APO02-BP4<br>APO02-03 |
| APO02-WP9 | Value benefit statement for target environment | BAI03.11 | |
| APO02-WP10 | Definition of strategic initiatives | APO05.01 | APO02-BP5<br>APO02-04 |
| APO02-WP11 | Risk assessment initiatives | APO05.01<br>APO12.01 | |
| APO02-WP12 | Strategic road map | EDM02.01<br>APO01.03<br>APO03.01<br>APO05.01<br>APO08.01 | |
| APO02-WP13 | Communication plan | Internal | APO02-BP6<br>APO02-05 |
| APO02-WP14 | Communication package | All APO<br>All BAI<br>All DSS<br>All MEA | |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

**Page intentionally left blank**



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | AP003 | |
|---|---|---|
| **Process Name** | **Manage Enterprise Architecture** | |
| **Process Description** | Establish a common architecture consisting of business process, information, data, application and technology architecture layers for effectively and efficiently realising enterprise and IT strategies by creating key models and practices that describe the baseline and target architectures. Define requirements for taxonomy, standards, guidelines, procedures, templates and tools, and provide a linkage for these components. Improve alignment, increase agility, improve quality of information and generate potential cost savings through initiatives such as re-use of building block components. | |
| **Process Purpose Statement** | Represent the different building blocks that make up the enterprise and their inter-relationships as well as the principles guiding their design and evolution over time, enabling a standard, responsive and efficient delivery of operational and strategic objectives. | |
| **Outcomes (Os)** | | |
| **Number** | **Description** | |
| AP003-01 | The architecture and standards are effective in supporting the enterprise. | |
| AP003-02 | A portfolio of enterprise architecture services supports agile enterprise change. | |
| AP003-03 | Appropriate and up-to-date domain and/or federated architectures exist that provide reliable architecture information. | |
| AP003-04 | A common enterprise architecture framework and methodology as well as an integrated architecture repository are used to enable re-use efficiencies across the enterprise. | |
| **Base Practices (BPs)** | | |
| **Number** | **Description** | **Supports** |
| AP003-BP1 | **Develop the enterprise architecture vision.**<br>The architecture vision provides a first-cut, high-level description of the baseline and target architectures, covering the business, information, data, application and technology domains. The architecture vision provides the sponsor with a key tool to sell the benefits of the proposed capability to stakeholders within the enterprise. The architecture vision describes how the new capability will meet enterprise goals and strategic objectives and address stakeholder concerns when implemented. | AP003-01/03 |
| AP003-BP2 | **Define reference architecture.**<br>The reference architecture describes the current and target architectures for the business, information, data, application and technology domains. | |
| AP003-BP3 | **Select opportunities and solutions.**<br>Rationalise the gaps between baseline and target architectures, taking both business and technical perspectives, and logically group them into project work packages. Integrate the project with any related IT-enabled investment programmes to ensure that the architectural initiatives are aligned with and enable these initiatives as part of overall enterprise change. Make this a collaborative effort with key enterprise stakeholders from business and IT to assess the enterprise's transformation readiness, and identify opportunities, solutions and all implementation constraints. | AP003-01/02 |
| AP003-BP4 | **Define architecture implementation.**<br>Create a viable implementation and migration plan in alignment with the programme and project portfolios. Ensure that the plan is closely co-ordinated to ensure that value is delivered and the required resources are available to complete the necessary work. | AP003-04 |
| AP003-BP5 | **Provide enterprise architecture services.**<br>The provision of enterprise architecture services within the enterprise includes guidance to and monitoring of implementation projects, formalising ways of working through architecture contracts, and measuring and communicating architecture's value-add and compliance monitoring. | |
| **Work Products (WPs)** | | |
| **Inputs** | | |
| **Number** | **Description** | **Supports** |
| EDM04-WP2 | Guiding principles for enterprise architecture | AP003-BP1<br>AP003-01/03 |
| AP002-WP12 | Strategic road map | |
| Outside COBIT | Enterprise strategy | |
| AP001-WP1 | Definition of organisational structure and functions | AP003-BP2<br>AP003-01/03 |
| AP001-WP2 | Enterprise operational guidelines | |
| AP001-WP8 | Evaluation of options for IT organisation | |
| AP001-WP9 | Defined operational placement of IT function | |
| AP001-WP10 | Data classification guidelines | |
| Outside COBIT | Enterprise strategy | |
| AP002-WP7 | Proposed enterprise architecture changes | AP003-BP3<br>AP003-01/02 |
| Outside COBIT | • Enterprise strategies<br>• Enterprise drivers | |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | APO03 *(cont.)* | | |
|---|---|---|---|
| **Process Name** | **Manage Enterprise Architecture** | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| APO03-WP1 | Defined scope of architecture | APO02.05 | APO03-BP1<br>APO03-01/03 |
| APO03-WP2 | Architecture principles | BAI02.01<br>BAI03.01<br>BAI03.02 | |
| APO03-WP3 | Architecture concept business case and value proposition | APO02.05<br>APO05.03 | |
| APO03-WP4 | Baseline domain descriptions and architecture definition | APO13.02<br>BAI02.01<br>BAI03.01<br>BAI03.02 | APO03-BP2<br>APO03-01/03 |
| APO03-WP5 | Process architecture model | APO01.01 | |
| APO03-WP6 | Information architecture model | APO02.05<br>BAI02.01<br>BAI03.02<br>DSS05.03<br>DSS05.04<br>DSS05.06 | |
| APO03-WP7 | High-level implementation and migration strategy | APO02.05 | APO03-BP3<br>APO03-01/02 |
| APO03-WP8 | Transition architectures | APO02.05 | |
| APO03-WP9 | Resource requirements | BAI01.02 | APO03-BP4<br>APO03-04 |
| APO03-WP10 | Implementation phase descriptions | BAI01.01<br>BAI01.02 | |
| APO03-WP11 | Architecture governance requirements | BAI01.01 | |
| APO03-WP12 | Solution development guidance | BAI02.01<br>BAI02.02<br>BAI03.02 | APO03-BP5<br>APO03-04 |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | AP004 | |
|---|---|---|
| **Process Name** | **Manage Innovation** | |
| **Process Description** | Maintain an awareness of information technology and related service trends, identify innovation opportunities, and plan how to benefit from innovation in relation to business needs. Analyse what opportunities for business innovation or improvement can be created by emerging technologies, services or IT-enabled business innovation, as well as through existing established technologies and by business and IT process innovation. Influence strategic planning and enterprise architecture decisions. | |
| **Process Purpose Statement** | Achieve competitive advantage, business innovation, and improved operational effectiveness and efficiency by exploiting information technology developments. | |
| **Outcomes (Os)** | | |
| **Number** | **Description** | |
| AP004-01 | Enterprise value is created through the qualification and staging of the most appropriate advances and innovations in technology, IT methods and solutions. | |
| AP004-02 | Enterprise objectives are met with improved quality benefits and/or reduced cost as a result of the identification and implementation of innovative solutions. | |
| AP004-03 | Innovation is promoted and enabled and forms part of the enterprise culture. | |
| **Base Practices (BPs)** | | |
| **Number** | **Description** | **Supports** |
| AP004-BP1 | **Create an environment conducive to innovation.**<br>Create an environment that is conducive to innovation, considering issues such as culture, reward, collaboration, technology forums, and mechanisms to promote and capture employee ideas. | AP004-03 |
| AP004-BP2 | **Maintain an understanding of the enterprise environment.**<br>Work with relevant stakeholders to understand their challenges. Maintain an adequate understanding of enterprise strategy and the competitive environment or other constraints so that opportunities enabled by new technologies can be identified. | AP004-02 |
| AP004-BP3 | **Monitor and scan the technology environment.**<br>Perform systematic monitoring and scanning of the enterprise's external environment to identify emerging technologies that have the potential to create value (e.g., by realising the enterprise strategy, optimising costs, avoiding obsolescence and better enabling enterprise and IT processes). Monitor the marketplace, competitive landscape, industry sectors, and legal and regulatory trends to be able to analyse emerging technologies or innovation ideas in the enterprise context. | AP004-01 |
| AP004-BP4 | **Assess the potential of emerging technologies and innovation ideas.**<br>Analyse identified emerging technologies and/or other IT innovation suggestions. Work with stakeholders to validate assumptions on the potential of new technologies and innovation. | AP004-01/02 |
| AP004-BP5 | **Recommend appropriate further initiatives.**<br>Evaluate and monitor the results of proof-of-concept initiatives and, if favourable, generate recommendations for further initiatives and gain stakeholder support. | |
| AP004-BP6 | **Monitor the implementation and use of innovation.**<br>Monitor the implementation and use of emerging technologies and innovations during integration, adoption and for the full economic life cycle to ensure that the promised benefits are realised and to identify lessons learned. | AP004-03 |
| **Work Products (WPs)** | | |
| **Inputs** | | |
| **Number** | **Description** | **Supports** |
| Outside COBIT | Enterprise strategy and enterprise SWOT analysis | AP004-BP2<br>AP004-02 |
| | Emerging technologies | AP004-BP3<br>AP004-01 |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | APO04 *(cont.)* | | |
|---|---|---|---|
| **Process Name** | **Manage Innovation** | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| APO04-WP1 | Innovation plan | Internal | APO04-BP1<br>APO04-03 |
| APO04-WP2 | Recognition and reward programme | APO07.04 | |
| APO04-WP3 | Innovation opportunities linked to business drivers | APO02.01 | APO04-BP2<br>APO04-02 |
| APO04-WP4 | Research analyses of innovation possibilities | BAI03.01 | APO04-BP3<br>APO04-01 |
| APO04-WP5 | Evaluations of innovation ideas | BAI03.01 | APO04-BP4<br>APO04-01/02 |
| APO04-WP6 | Proof-of-concept scope and outline business case | APO05.03<br>APO06.02 | |
| APO04-WP7 | Test results from proof-of-concept initiatives | Internal | |
| APO04-WP8 | Results and recommendations from proof-of-concept initiatives | APO02.03<br>BAI03.09 | APO04-BP5<br>APO04-01/02 |
| APO04-WP9 | Analysis of rejected initiatives | APO02.03<br>BAI03.08 | |
| APO04-WP10 | Assessments of using innovative approaches | APO02.04<br>BAI03.02 | APO04-BP6<br>APO04-03 |
| APO04-WP11 | Evaluation of innovation benefits | APO05.04 | |
| APO04-WP12 | Adjusted innovation plans | Internal | |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | AP005 | |
|---|---|---|
| **Process Name** | **Manage Portfolio** | |
| **Process Description** | Execute the strategic direction set for investments in line with the enterprise architecture vision and the desired characteristics of the investment and related services portfolios, and consider the different categories of investments and the resources and funding constraints. Evaluate, prioritise and balance programmes and services, managing demand within resource and funding constraints, based on their alignment with strategic objectives, enterprise worth and risk. Move selected programmes into the active services portfolio for execution. Monitor the performance of the overall portfolio of services and programmes, proposing adjustments as necessary in response to programme and service performance or changing enterprise priorities. | |
| **Process Purpose Statement** | Optimise the performance of the overall portfolio of programmes in response to programme and service performance and changing enterprise priorities and demands. | |
| **Outcomes (Os)** | | |
| **Number** | **Description** | |
| AP005-01 | An appropriate investment mix is defined and aligned with enterprise strategy. | |
| AP005-02 | Sources of investment funding are identified and available. | |
| AP005-03 | Programme business cases are evaluated and prioritised before funds are allocated. | |
| AP005-04 | A comprehensive and accurate view of the investment portfolio performance exists. | |
| AP005-05 | Investment programme changes are reflected in the relevant IT service, asset and resource portfolios. | |
| AP005-06 | Benefits have been realised due to benefit monitoring. | |
| **Base Practices (BPs)** | | |
| **Number** | **Description** | **Supports** |
| AP005-BP1 | **Establish the target investment mix.**<br>Review and ensure clarity of the enterprise and IT strategies and current services. Define an appropriate investment mix based on cost, alignment with strategy, and financial measures such as cost and expected ROI over the full economic life cycle, degree of risk, and type of benefit for the programmes in the portfolio. Adjust the enterprise and IT strategies where necessary. | AP005-01 |
| AP005-BP2 | **Determine the availability and sources of funds.**<br>Determine potential sources of funds, different funding options and the implications of the funding source on the investment return expectations. | AP005-02 |
| AP005-BP3 | **Evaluate and select programmes to fund.**<br>Based on the overall investment portfolio mix requirements, evaluate and prioritise programme business cases, and decide on investment proposals. Allocate funds and initiate programmes. | AP005-03 |
| AP005-BP4 | **Monitor, optimise and report on investment portfolio performance.**<br>On a regular basis, monitor and optimise the performance of the investment portfolio and individual programmes throughout the entire investment life cycle. | AP005-04 |
| AP005-BP5 | **Maintain portfolios.**<br>Maintain portfolios of investment programmes and projects, IT services and IT assets. | AP005-05 |
| AP005-BP6 | **Manage benefits achievement.**<br>Monitor the benefits of providing and maintaining appropriate IT services and capabilities, based on the agreed-on and current business case. | AP005-04/06 |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | APO05 *(cont.)* | |
|---|---|---|
| **Process Name** | **Manage Portfolio** | |
| **Work Products (WPs)** | | |
| **Inputs** | | |
| **Number** | **Description** | **Supports** |
| EDM02-WP3 | Investment types and criteria | APO05-BP1<br>APO05-01 |
| APO02-WP10 | Definition of strategic initiatives | |
| APO02-WP11 | Risk assessment initiatives | |
| APO02-WP12 | Strategic road map | |
| APO06-WP4 | Prioritisation and ranking of IT initiatives | |
| APO09-WP2 | Definitions of standard services | |
| BAI03-WP17 | Service definitions | |
| EDM02-WP1 | Evaluation of strategic alignment | APO05-BP3<br>APO05-03 |
| EDM02-WP2 | Evaluation of investment and services portfolios | |
| EDM02-WP3 | Investment types and criteria | |
| APO03-WP3 | Architecture concept business case and value proposition | |
| APO04-WP6 | Proof-of-concept scope and outline business case | |
| APO06-WP5 | Budget allocations | |
| APO06-WP6 | IT budget and plan | |
| APO06-WP7 | Budget communications | |
| APO09-WP1 | Identified gaps in IT services to the business | |
| APO09-WP4 | SLAs | |
| BAI01-WP2 | Programme concept business case | |
| BAI01-WP3 | Programme mandate and brief | |
| BAI01-WP4 | Programme benefit realisation plan | |
| EDM02-WP2 | Evaluation of investment and services portfolios | APO05-BP4<br>APO05-04 |
| EDM02-WP5 | Feedback on portfolio and programme performance | |
| EDM02-WP6 | Actions to improve value delivery | |
| APO04-WP11 | Evaluation of innovation benefits | |
| BAI01-WP14 | Stage-gate review results | |
| BAI01-WP34 | Communication of programme retirement and ongoing accountabilities | APO05-BP5<br>APO05-05 |
| BAI03-WP18 | Updated service portfolio | |
| BAI01-WP8 | Programme budget and benefits register | APO05-BP6<br>APO05-04/06 |
| BAI01-WP10 | Results of benefit realisation monitoring | |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | APO05 *(cont.)* | | |
|---|---|---|---|
| **Process Name** | **Manage Portfolio** | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| APO05-WP1 | Defined investment mix | Internal | APO05-BP1<br>APO05-01 |
| APO05-WP2 | Identified resources and capabilities required to support strategy | Internal | |
| APO05-WP3 | Feedback on strategy and goals | APO02.05 | |
| APO05-WP4 | Funding options | APO02.05 | APO05-BP2<br>APO05-02 |
| APO05-WP5 | Investment return expectations | EDM02.01<br>APO02.04<br>APO06.02<br>BAI01.06 | |
| APO05-WP6 | Programme business case | APO06.02<br>BAI01.02 | APO05-BP3<br>APO05-03 |
| APO05-WP7 | Business case assessments | APO06.02<br>BAI01.06 | |
| APO05-WP8 | Selected programmes with return on investment (ROI) milestones | EDM02.01<br>BAI01.04 | |
| APO05-WP9 | Investment portfolio performance reports | EDM02.03<br>APO09.04<br>BAI01.06<br>MEA01.03 | APO05-BP4<br>APO05-04 |
| APO05-WP10 | Updated portfolios of programmes, services and assets | APO09.02<br>BAI01.01 | APO05-BP5<br>APO05-05 |
| APO05-WP11 | Benefit results and related communications | EDM02.01<br>APO09.04<br>BAI01.06 | APO05-BP6<br>APO05-04/06 |
| APO05-WP12 | Corrective actions to improve benefit realisation | APO09.04<br>BAI01.06 | |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

**Page intentionally left blank**



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | AP006 | |
|---|---|---|
| **Process Name** | **Manage Budget and Costs** | |
| **Process Description** | Manage the IT-related financial activities in both the business and IT functions, covering budget, cost and benefit management, and prioritisation of spending through the use of formal budgeting practices and a fair and equitable system of allocating costs to the enterprise. Consult stakeholders to identify and control the total costs and benefits within the context of the IT strategic and tactical plans, and initiate corrective action where needed. | |
| **Process Purpose Statement** | Foster partnership between IT and enterprise stakeholders to enable the effective and efficient use of IT-related resources and provide transparency and accountability of the cost and business value of solutions and services. Enable the enterprise to make informed decisions regarding the use of IT solutions and services. | |
| **Outcomes (Os)** | | |
| **Number** | **Description** | |
| AP006-01 | A transparent and complete budget for IT accurately reflects planned expenditures. | |
| AP006-02 | The allocation of IT resources for IT initiatives is prioritised based on enterprise needs. | |
| AP006-03 | Costs for services are allocated in an equitable way. | |
| AP006-04 | Budgets can be accurately compared to actual costs. | |
| **Base Practices (BPs)** | | |
| **Number** | **Description** | **Supports** |
| AP006-BP1 | **Manage finance and accounting.**<br>Establish and maintain a method to account for all IT-related costs, investments and depreciation as an integral part of the enterprise financial systems and chart of accounts to manage the investments and costs of IT. Capture and allocate actual costs, analyse variances between forecasts and actual costs, and report using the enterprise's financial measurement systems. | AP006-01 |
| AP006-BP2 | **Prioritise resource allocation.**<br>Implement a decision-making process to prioritise the allocation of resources and rules for discretionary investments by individual business units. Include the potential use of external service providers and consider the buy, develop and rent options. | AP006-02 |
| AP006-BP3 | **Create and maintain budgets.**<br>Prepare a budget reflecting the investment priorities supporting strategic objectives based on the portfolio of IT-enabled programmes and IT services. | AP006-01/04 |
| AP006-BP4 | **Model and allocate costs.**<br>Establish and use an IT costing model based on the service definition, ensuring that allocation of costs for services is identifiable, measurable and predictable, to encourage the responsible use of resources including those provided by service providers. Regularly review and benchmark the appropriateness of the cost/chargeback model to maintain its relevance and appropriateness to the evolving business and IT activities. | AP006-03 |
| AP006-BP5 | **Manage costs.**<br>Implement a cost management process comparing actual costs to budgets. Costs should be monitored and reported and, in the case of deviations, identified in a timely manner and their impact on enterprise processes and services assessed. | AP006-04 |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | APO06 *(cont.)* | | |
|---|---|---|---|
| **Process Name** | **Manage Budget and Costs** | | |
| **Work Products (WPs)** | | | |
| **Inputs** | | | |
| **Number** | **Description** | | **Supports** |
| BAI09-WP1 | Asset register | | APO06-BP1<br>APO06-01 |
| EDM02-WP2 | Evaluation of investment and services portfolios | | APO06-BP2<br>APO06-02 |
| EDM02-WP6 | Actions to improve value delivery | | |
| APO04-WP6 | Proof-of-concept scope and outline business case | | |
| APO05-WP5 | Investment return expectations | | |
| APO05-WP6 | Programme business case | | |
| APO05-WP7 | Business case assessments | | |
| EDM02-WP5 | Feedback on portfolio and programme performance | | APO06-BP5<br>APO06-04 |
| BAI01-WP4 | Programme benefit realisation plan | | |
| BAI01-WP8 | Programme budget and benefits register | | |
| BAI01-WP10 | Results of benefit realisation monitoring | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| APO06-WP1 | Accounting processes | Internal | APO06-BP1<br>APO06-01 |
| APO06-WP2 | IT costs classification scheme | Internal | |
| APO06-WP3 | Financial planning practices | Internal | |
| APO06-WP4 | Prioritisation and ranking of IT initiatives | APO05.01 | APO06-BP2<br>APO06-02 |
| APO06-WP5 | Budget allocations | APO02.05<br>APO05.03<br>APO07.05<br>BAI03.11 | |
| APO06-WP6 | IT budget and plan | APO02.05<br>APO05.03<br>APO07.01<br>BAI03.11 | APO06-BP3<br>APO06-01/04 |
| APO06-WP7 | Budget communications | APO02.05<br>APO05.03<br>APO07.01<br>BAI03.11 | |
| APO06-WP8 | Categorised IT costs | Internal | APO06-BP4<br>APO06-03 |
| APO06-WP9 | Cost allocation model | Internal | |
| APO06-WP10 | Cost allocation communications | Internal | |
| APO06-WP11 | Operational procedures | Internal | |
| APO06-WP12 | Cost data collection method | Internal | APO06-BP5<br>APO06-04 |
| APO06-WP13 | Cost consolidation method | Internal | |
| APO06-WP14 | Cost optimisation opportunities | APO02.02 | |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | AP007 | |
|---|---|---|
| **Process Name** | **Manage Human Resources** | |
| **Process Description** | Provide a structured approach to ensure optimal structuring, placement, decision rights and skills of human resources. This includes communicating the defined roles and responsibilities, learning and growth plans, and performance expectations, supported with competent and motivated people. | |
| **Process Purpose Statement** | Optimise human resources capabilities to meet enterprise objectives. | |
| **Outcomes (Os)** | | |
| **Number** | **Description** | |
| AP007-01 | The IT organisational structure and relationships are flexible and responsive. | |
| AP007-02 | Human resources are effectively and efficiently managed. | |
| **Base Practices (BPs)** | | |
| **Number** | **Description** | **Supports** |
| AP007-BP1 | **Maintain adequate and appropriate staffing.**<br>Evaluate staffing requirements on a regular basis or upon major changes to the enterprise or operational or IT environments to ensure that the enterprise has sufficient human resources to support enterprise goals and objectives. Staffing includes both internal and external resources. | AP007-01/02 |
| AP007-BP2 | **Identify key IT personnel.**<br>Identify key IT personnel while minimising reliance on a single individual performing a critical job function through knowledge capture (documentation), knowledge sharing, succession planning and staff backup. | AP007-01 |
| AP007-BP3 | **Maintain the skills and competencies of personnel.**<br>Define and manage the skills and competencies required of personnel. Regularly verify that personnel have the competencies to fulfil their roles on the basis of their education, training and/or experience, and verify that these competencies are being maintained, using qualification and certification programmes where appropriate. Provide employees with ongoing learning and opportunities to maintain their knowledge, skills and competencies at a level required to achieve enterprise goals. | AP007-02 |
| AP007-BP4 | **Evaluate employee job performance.**<br>Perform timely performance evaluations on a regular basis against individual objectives derived from the enterprise's goals, established standards, specific job responsibilities, and the skills and competency framework. Employees should receive coaching on performance and conduct whenever appropriate. | AP007-02 |
| AP007-BP5 | **Plan and track the usage of IT and business human resources.**<br>Understand and track the current and future demand for business and IT human resources with responsibilities for enterprise IT. Identify shortfalls and provide input into sourcing plans, enterprise and IT recruitment processes sourcing plans, and business and IT recruitment processes. | AP007-01/02 |
| AP007-BP6 | **Manage contract staff.**<br>Ensure that consultants and contract personnel who support the enterprise with IT skills know and comply with the organisation's policies and meet agreed-on contractual requirements. | AP007-02 |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | APO07 *(cont.)* | |
|---|---|---|
| **Process Name** | **Manage Human Resources** | |
| **Work Products (WPs)** | | |
| **Inputs** | | |
| **Number** | **Description** | **Supports** |
| EDM04-WP1 | Guiding principles for allocation of resources and capabilities | APO07-BP1<br>APO07-01/02 |
| EDM04-WP3 | Approved resources plan | |
| EDM04-WP8 | Remedial actions to address resource management deviations | |
| APO01-WP5 | Definition of supervisory practices | |
| APO06-WP6 | IT budget and plan | |
| APO06-WP7 | Budget communications | |
| Outside COBIT | • Enterprise goals and objectives<br>• Enterprise HR policies and procedures | |
| EDM01-WP5 | Reward system approach | APO07-BP3<br>APO07-02 |
| EDM04-WP8 | Remedial actions to address resource management deviations | |
| BAI08-WP3 | Published knowledge repositories | |
| BAI08-WP5 | Knowledge awareness and training schemes | |
| DSS04-WP14 | Training requirements | |
| DSS04-WP15 | Monitoring results of skills and competencies | |
| Outside COBIT | Enterprise goals and objectives | |
| EDM01-WP5 | Reward system approach | APO07-BP4<br>APO07-02 |
| APO04-WP2 | Recognition and reward programme | |
| BAI05-WP7 | Aligned HR performance objectives | |
| BAI05-WP14 | HR performance review results | |
| DSS06-WP6 | Allocated access rights | |
| Outside COBIT | Enterprise goals and objectives | |
| EDM04-WP4 | Communication of resourcing strategies | APO07-BP5<br>APO07-01/02 |
| EDM04-WP7 | Feedback on allocation and effectiveness of resources and capabilities | |
| APO06-WP5 | Budget allocations | |
| BAI01-WP9 | Resource requirements and roles | |
| BAI01-WP28 | Project resource requirements | |
| Outside COBIT | • Current and future portfolios<br>• Enterprise organisation structure | |
| BAI01-WP9 | Resource requirements and roles | APO07-BP6<br>APO07-02 |
| BAI01-WP28 | Project resource requirements | |
| BAI01-WP34 | Communication of programme retirement and ongoing accountabilities | |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | APO07 *(cont.)* | | |
|---|---|---|---|
| **Process Name** | **Manage Human Resources** | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| APO07-WP1 | Staffing requirement evaluations | Internal | APO07-BP1<br>APO07-01/02 |
| APO07-WP2 | Competency and career development plans | Internal | |
| APO07-WP3 | Personnel sourcing plans | Internal | |
| APO07-WP4 | List of key personnel | Internal | APO07-BP2<br>APO07-01 |
| APO07-WP5 | Skills and competencies matrix | APO01.02<br>BAI01.02<br>BAI01.04 | APO07-BP3<br>APO07-02 |
| APO07-WP6 | Skills development plans | EDM04.01<br>APO01.02 | |
| APO07-WP7 | Review reports | Internal | |
| APO07-WP8 | Personnel goals | Internal | APO07-BP4<br>APO07-02 |
| APO07-WP9 | Performance evaluations | Internal | |
| APO07-WP10 | Improvement plans | Internal | |
| APO07-WP11 | Inventory of business and IT human resources | BAI01.04 | APO07-BP5<br>APO07-01/02 |
| APO07-WP12 | Resourcing shortfall analyses | BAI01.06 | |
| APO07-WP13 | Resource utilisation records | BAI01.06 | |
| APO07-WP14 | Contract staff policies | Internal | APO07-BP6<br>APO07-02 |
| APO07-WP15 | Contract agreements | Internal | |
| APO07-WP16 | Contract agreement reviews | Internal | |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

**Page intentionally left blank**



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | AP008 | |
|---|---|---|
| **Process Name** | **Manage Relationships** | |
| **Process Description** | Manage the relationship between the business and IT in a formalised and transparent way that ensures a focus on achieving a common and shared goal of successful enterprise outcomes in support of strategic goals and within the constraint of budgets and risk tolerance. Base the relationship on mutual trust, using open and understandable terms and common language and a willingness to take ownership and accountability for key decisions. | |
| **Process Purpose Statement** | Create improved outcomes, increased confidence, and trust in IT and effective use of resources. | |
| **Outcomes (Os)** | | |
| **Number** | **Description** | |
| AP008-01 | Business strategies, plans and requirements are well understood, documented and approved. | |
| AP008-02 | Good relationships exist between the enterprise and IT. | |
| AP008-03 | Business stakeholders are aware of technology-enabled opportunities. | |
| **Base Practices (BPs)** | | |
| **Number** | **Description** | **Supports** |
| AP008-BP1 | **Understand business expectations.**<br>Understand current business issues and objectives and business expectations for IT. Ensure that requirements are understood, managed and communicated, and their status agreed on and approved. | AP008-01 |
| AP008-BP2 | **Identify opportunities, risk and constraints for IT to enhance the business.**<br>Identify potential opportunities for IT to be an enabler of enhanced enterprise performance. | AP008-02 |
| AP008-BP3 | **Manage the business relationship.**<br>Manage the relationship with customers (business representatives). Ensure that relationship roles and responsibilities are defined and assigned, and communication is facilitated. | AP008-03 |
| AP008-BP4 | **Co-ordinate and communicate.**<br>Work with stakeholders and co-ordinate the end-to-end delivery of IT services and solutions provided to the business. | AP008-02/03 |
| AP008-BP5 | **Provide input to the continual improvement of services.**<br>Continually improve and evolve IT-enabled services and service delivery to the enterprise to align with changing enterprise and technology requirements. | |
| **Work Products (WPs)** | | |
| **Inputs** | | |
| **Number** | **Description** | **Supports** |
| AP002-WP12 | Strategic road map | AP008-BP1<br>AP008-01 |
| AP009-WP1 | Identified gaps in IT services to the business | AP008-BP2<br>AP008-02 |
| AP009-WP6 | Service level performance reports | |
| AP009-WP7 | Improvement action plans and remediations | |
| AP011-WP11 | Root causes of quality delivery failures | |
| DSS02-WP5 | Classified and prioritised incidents and service requests | AP008-BP3<br>AP008-03 |
| DSS02-WP11 | Closed service requests and incidents | |
| DSS02-WP12 | User confirmation of satisfactory fulfilment or resolution | |
| DSS02-WP13 | Incident status and trends report | |
| DSS02-WP14 | Request fulfilment status and trends report | |
| AP009-WP4 | SLAs | AP008-BP4<br>AP008-02/03 |
| AP012-WP14 | Risk impact communication | |
| BAI05-WP10 | Operation and use plan | |
| BAI07-WP11 | Supplemental support plan | |
| BAI09-WP4 | Communication of planned maintenance downtime | |
| DSS03-WP9 | Communication of knowledge learned | |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | APO08 *(cont.)* | | |
|---|---|---|---|
| **Process Name** | **Manage Relationships** | | |
| **Work Products (WPs)** | | | |
| **Inputs** | | | |
| **Number** | **Description** | | **Supports** |
| APO09-WP3 | Service catalogues | | APO08-BP5<br>APO08-02/03 |
| APO11-WP5 | Customer requirements for quality management | | |
| APO11-WP7 | Review results of quality of service, including customer feedback | | |
| APO11-WP8 | Results of quality reviews and audits | | |
| APO11-WP10 | Results of solution and service delivery quality monitoring | | |
| BAI03-WP15 | Maintenance plan | | |
| BAI05-WP11 | Success measures and results | | |
| BAI07-WP11 | Supplemental support plan | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| APO08-WP1 | Clarified and agreed-on business expectations | Internal | APO08-BP1<br>APO08-01 |
| APO08-WP2 | Agreed-on next steps and action plans | Internal | APO08-BP2<br>APO08-02 |
| APO08-WP3 | Agreed-on key decisions | Internal | APO08-BP3<br>APO08-03 |
| APO08-WP4 | Complaint and escalation status | Internal | |
| APO08-WP5 | Communication plan | Internal | APO08-BP4<br>APO08-02/03 |
| APO08-WP6 | Communication packages | Internal | |
| APO08-WP7 | Customer responses | Internal | |
| APO08-WP8 | Satisfaction analyses | APO09.04 | APO08-BP5<br>APO08-02/03 |
| APO08-WP9 | Definition of potential improvement projects | APO02.02<br>BAI03.11 | |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | AP009 | |
|---|---|---|
| **Process Name** | **Manage Service Agreements** | |
| **Process Description** | Align IT-enabled services and service levels with enterprise needs and expectations, including identification, specification, design, publishing, agreement, and monitoring of IT services, service levels and performance indicators. | |
| **Process Purpose Statement** | Ensure that IT services and service levels meet current and future enterprise needs. | |
| **Outcomes (Os)** | | |
| **Number** | **Description** | |
| AP009-01 | The enterprise can effectively utilise IT services as defined in a catalogue. | |
| AP009-02 | Service agreements reflect enterprise needs and the capabilities of IT. | |
| AP009-03 | IT services perform as stipulated in service agreements. | |
| **Base Practices (BPs)** | | |
| **Number** | **Description** | **Supports** |
| AP009-BP1 | **Identify IT services.**<br>Analyse business requirements and the way in which IT-enabled services and service levels support business processes. Discuss and agree on potential services and service levels with the business, and compare them with the current service portfolio to identify new or changed services or service level options. | AP009-01 |
| AP009-BP2 | **Catalogue IT-enabled services.**<br>Define and maintain one or more service catalogues for relevant target groups. Publish and maintain live IT-enabled services in the service catalogues. | AP009-01 |
| AP009-BP3 | **Define and prepare service agreements.**<br>Define and prepare service agreements based on the options in the service catalogues. Include internal operational agreements. | AP009-01/02 |
| AP009-BP4 | **Monitor and report service levels.**<br>Monitor service levels, report on achievements and identify trends. Provide the appropriate management information to aid performance management. | AP009-03 |
| AP009-BP5 | **Review service agreements and contracts.**<br>Conduct periodic reviews of the service agreements and revise when needed. | AP009-03 |
| **Work Products (WPs)** | | |
| **Inputs** | | |
| **Number** | **Description** | **Supports** |
| EDM04-WP3 | Approved resources plan | AP009-BP2<br>AP009-01 |
| EDM04-WP4 | Communication of resourcing strategies | |
| AP005-WP10 | Updated portfolios of programmes, services and assets | |
| AP011-WP5 | Customer requirements for quality management | AP009-BP3<br>AP009-01/02 |
| EDM04-WP8 | Remedial actions to address resource management deviations | AP009-BP4<br>AP009-03 |
| AP005-WP9 | Investment portfolio performance reports | |
| AP005-WP11 | Benefit results and related communications | |
| AP005-WP12 | Corrective actions to improve benefit realisation | |
| AP008-WP8 | Satisfaction analyses | |
| AP011-WP8 | Results of quality reviews and audits | |
| AP011-WP10 | Results of solution and service delivery quality monitoring | |
| AP011-WP11 | Root causes of quality delivery failures | |
| DSS02-WP5 | Classified and prioritised incidents and service requests | |
| DSS02-WP11 | Closed service requests and incidents | |
| DSS02-WP13 | Incident status and trends report | |
| DSS02-WP14 | Request fulfilment status and trends report | |
| EDM04-WP7 | Feedback on allocation and effectiveness of resources and capabilities | AP009-BP5<br>AP009-03 |
| AP011-WP7 | Review results of quality of service, including customer feedback | |
| AP011-WP8 | Results of quality reviews and audits | |
| BAI04-WP2 | Evaluations against SLAs | |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | APO09 *(cont.)* | | |
|---|---|---|---|
| **Process Name** | **Manage Service Agreements** | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| APO09-WP1 | Identified gaps in IT services to the business | APO02.02<br>APO05.03<br>APO08.02 | APO09-BP1<br>APO09-01 |
| APO09-WP2 | Definitions of standard services | APO05.01 | |
| APO09-WP3 | Service catalogues | APO08.05 | APO09-BP2<br>APO09-01 |
| APO09-WP4 | SLAs | APO05.03<br>APO08.04<br>DSS01.02<br>DSS02.01<br>DSS02.02<br>DSS04.01<br>DSS05.02<br>DSS05.03 | APO09-BP3<br>APO09-01/02 |
| APO09-WP5 | OLAs | DSS01.02<br>DSS02.07<br>DSS04.03<br>DSS05.03 | |
| APO09-WP6 | Service level performance reports | APO08.02<br>MEA01.03 | APO09-BP4<br>APO09-03 |
| APO09-WP7 | Improvement action plans and remediations | APO02.02<br>APO08.02 | |
| APO09-WP8 | SLA revisions | Internal | APO09-BP5<br>APO09-03 |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | APO10 | |
|---|---|---|
| **Process Name** | **Manage Suppliers** | |
| **Process Description** | Manage IT-related services provided by all types of suppliers to meet enterprise requirements, including the selection of suppliers, management of relationships, management of contracts, and reviewing and monitoring of supplier performance for effectiveness and compliance. | |
| **Process Purpose Statement** | Minimise the risk associated with non-performing suppliers and ensure competitive pricing. | |
| **Outcomes (Os)** | | |
| **Number** | **Description** | |
| APO10-01 | Suppliers perform as agreed. | |
| APO10-02 | Supplier risk is assessed and properly addressed. | |
| APO10-03 | Supplier relationships are working effectively. | |
| **Base Practices (BPs)** | | |
| **Number** | **Description** | **Supports** |
| APO10-BP1 | **Identify and evaluate supplier relationships and contracts.** Identify suppliers and associated contracts and categorise them into type, significance and criticality. Establish supplier and contract evaluation criteria and evaluate the overall portfolio of existing and alternative suppliers and contracts. | APO10-03 |
| APO10-BP2 | **Select suppliers.** Select suppliers according to a fair and formal practice to ensure a viable best fit based on specified requirements. Requirements should be optimised with input from potential suppliers. | APO10-01/03 |
| APO10-BP3 | **Manage supplier relationships and contracts.** Formalise and manage the supplier relationship for each supplier. Manage, maintain and monitor contracts and service delivery. Ensure that new or changed contracts conform to enterprise standards and legal and regulatory requirements. Deal with contractual disputes. | APO10-03 |
| APO10-BP4 | **Manage supplier risk.** Identify and manage risk relating to suppliers' ability to continually provide secure, efficient and effective service delivery. | APO10-02 |
| APO10-BP5 | **Monitor supplier performance and compliance.** Periodically review the overall performance of suppliers, compliance to contract requirements, and value for money, and address identified issues. | APO10-01/03 |
| **Work Products (WPs)** | | |
| **Inputs** | | |
| **Number** | **Description** | **Supports** |
| Outside COBIT | Supplier contracts | APO10-BP1<br>APO10-03 |
| BAI02-WP5 | High-level acquisition/development plan | APO10-BP2<br>APO10-01/03 |
| BAI03-WP5 | Approved acquisition plan | APO10-BP3<br>APO10-03 |
| APO12-WP9 | Risk analysis and risk profile reports for stakeholders | |
| APO12-WP10 | Results of third-party risk assessments | APO10-BP4<br>APO10-02 |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | APO10 *(cont.)* | | |
|---|---|---|---|
| **Process Name** | **Manage Suppliers** | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| APO10-WP1 | Supplier significance and evaluation criteria | Internal | APO10-BP1<br>APO10-03 |
| APO10-WP2 | Supplier catalogue | BAI02.02 | |
| APO10-WP3 | Potential revisions to supplier contracts | Internal | |
| APO10-WP4 | Supplier requests for information (RFIs) and requests for proposals (RFPs) | BAI02.01<br>BAI02.02 | APO10-BP2<br>APO10-01/03 |
| APO10-WP5 | RFI and RFP evaluations | BAI02.02 | |
| APO10-WP6 | Decision results of supplier evaluations | EDM04.01<br>BAI02.02 | |
| APO10-WP7 | Supplier roles and responsibilities | Internal | APO10-BP3<br>APO10-03 |
| APO10-WP8 | Communication and review process | Internal | |
| APO10-WP9 | Results and suggested improvements | Internal | |
| APO10-WP10 | Identified supplier delivery risk | APO12.01<br>APO12.03<br>BAI01.01 | APO10-BP4<br>APO10-02 |
| APO10-WP11 | Identified contract requirements to minimise risk | Internal | |
| APO10-WP12 | Supplier compliance monitoring criteria | Internal | APO10-BP5<br>APO10-01/03 |
| APO10-WP13 | Supplier compliance monitoring review results | MEA01.03 | |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | APO11 | |
|---|---|---|
| **Process Name** | **Manage Quality** | |
| **Process Description** | Define and communicate quality requirements in all processes, procedures and the related enterprise outcomes, including controls, ongoing monitoring, and the use of proven practices and standards in continuous improvement and efficiency efforts. | |
| **Process Purpose Statement** | Ensure the consistent delivery of solutions and services to meet the quality requirements of the enterprise and satisfy stakeholder needs. | |
| **Outcomes (Os)** | | |
| **Number** | **Description** | |
| APO11-01 | Stakeholders are satisfied with the quality of solutions and services. | |
| APO11-02 | Project and service delivery results are predictable. | |
| APO11-03 | Quality requirements are implemented in all processes. | |
| **Base Practices (BPs)** | | |
| **Number** | **Description** | **Supports** |
| APO11-BP1 | **Establish a quality management system (QMS).**<br>Establish and maintain a QMS that provides a standard, formal and continuous approach to quality management for information, enabling technology and business processes that are aligned with business requirements and enterprise quality management. | APO11-03 |
| APO11-BP2 | **Define and manage quality standards, practices and procedures.**<br>Identify and maintain requirements, standards, procedures and practices for key processes to guide the enterprise in meeting the intent of the agreed-on QMS. This should be in line with the IT control framework requirements. Consider certification for key processes, organisation units, products or services. | |
| APO11-BP3 | **Focus quality management on customers.**<br>Focus quality management on customers by determining their requirements and ensuring alignment with the quality management practices. | APO11-01/02 |
| APO11-BP4 | **Perform quality monitoring, control and reviews.**<br>Monitor the quality of processes and services on an ongoing basis as defined by the QMS. Define, plan and implement measurements to monitor customer satisfaction with quality as well as the value the QMS provides. The information gathered should be used by the process owner to improve quality. | APO11-02/03 |
| APO11-BP5 | **Integrate quality management into solutions for development and service delivery.**<br>Incorporate relevant quality management practices into the definition, monitoring, reporting and ongoing management of solutions development and service offerings. | APO11-01/03 |
| APO11-BP6 | **Maintain continuous improvement.**<br>Maintain and regularly communicate an overall quality plan that promotes continuous improvement. This should include the need for, and benefits of, continuous improvement. Collect and analyse data about the QMS, and improve its effectiveness. Correct non-conformities to prevent recurrence. Promote a culture of quality and continual improvement. | |
| **Work Products (WPs)** | | |
| **Inputs** | | |
| **Number** | **Description** | **Supports** |
| Outside COBIT | Enterprisewide quality system | APO11-BP1<br>APO11-03 |
| BAI02-WP9 | Approved quality reviews | APO11-BP2<br>APO11-03 |
| Outside COBIT | • Industry good practices<br>• Available quality certifications | |
| Outside COBIT | Business and customer quality requirements | APO11-BP3<br>APO11-01/02 |
| BAI03-WP8 | Quality assurance plan | APO11-BP4<br>APO11-02/03 |
| BAI03-WP9 | Quality review results, exceptions and corrections | |
| DSS02-WP13 | Incident status and trends report | |
| DSS02-WP14 | Request fulfilment status and trends report | |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | APO11 *(cont.)* | | |
|---|---|---|---|
| **Process Name** | **Manage Quality** | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| APO11-WP1 | Quality management system (QMS) roles, responsibilities and decision rights | APO01.02<br>DSS06.03 | APO11-BP1<br>APO11-03 |
| APO11-WP2 | Quality management plans | BAI01.09 | |
| APO11-WP3 | Results of QMS effectiveness reviews | BAI03.06 | |
| APO11-WP4 | Quality management standards | All APO<br>All BAI<br>All DSS<br>All MEA | APO11-BP2<br>APO11-03 |
| APO11-WP5 | Customer requirements for quality management | APO08.05<br>APO09.03<br>BAI01.09 | APO11-BP3<br>APO11-01/02 |
| APO11-WP6 | Acceptance criteria | BAI02.01<br>BAI02.02 | |
| APO11-WP7 | Review results of quality of service, including customer feedback | APO08.05<br>APO09.05<br>BAI05.01<br>BAI07.07 | |
| APO11-WP8 | Results of quality reviews and audits | APO08.05<br>APO09.04<br>APO09.05<br>BAI07.08 | APO11-BP4<br>APO11-02/03 |
| APO11-WP9 | Process quality of service goals and metrics | All APO<br>All BAI<br>All DSS<br>All MEA | |
| APO11-WP10 | Results of solution and service delivery quality monitoring | APO08.05<br>APO09.04<br>BAI07.08 | APO11-BP5<br>APO11-01/03 |
| APO11-WP11 | Root causes of quality delivery failures | APO08.02<br>APO09.04<br>BAI07.08<br>MEA02.04<br>MEA02.07<br>MEA02.08 | |
| APO11-WP12 | Communications on continual improvement and best practices | All APO<br>All BAI<br>All DSS<br>All MEA | APO11-BP6<br>APO11-01/03 |
| APO11-WP13 | Examples of good practice to be shared | All APO<br>All BAI<br>All DSS<br>All MEA | |
| APO11-WP14 | Quality review benchmark results | All APO<br>All BAI<br>All DSS<br>All MEA | |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | AP012 | |
|---|---|---|
| **Process Name** | **Manage Risk** | |
| **Process Description** | Continually identify, assess and reduce IT-related risk within levels of tolerance set by enterprise executive management. | |
| **Process Purpose Statement** | Integrate the management of IT-related enterprise risk with overall ERM, and balance the costs and benefits of managing IT-related enterprise risk. | |
| **Outcomes (Os)** | | |
| **Number** | **Description** | |
| AP012-01 | IT-related risk is identified, analysed, managed and reported. | |
| AP012-02 | A current and complete risk profile exists. | |
| AP012-03 | All significant risk management actions are managed and under control. | |
| AP012-04 | Risk management actions are implemented effectively | |
| **Base Practices (BPs)** | | |
| **Number** | **Description** | **Supports** |
| AP012-BP1 | **Collect data.** Identify and collect relevant data to enable effective IT-related risk identification, analysis and reporting. | AP012-01 |
| AP012-BP2 | **Analyse risk.** Develop useful information to support risk decisions that take into account the business relevance of risk factors. | AP012-01/04 |
| AP012-BP3 | **Maintain a risk profile.** Maintain an inventory of known risk and risk attributes (including expected frequency, potential impact, and responses) and of related resources, capabilities, and current control activities. | AP012-02 |
| AP012-BP4 | **Articulate risk.** Provide information on the current state of IT-related exposures and opportunities in a timely manner to all required stakeholders for appropriate response. | AP012-03/04 |
| AP012-BP5 | **Define a risk management action portfolio.** Manage opportunities to reduce risk to an acceptable level as a portfolio. | |
| AP012-BP6 | **Respond to risk.** Respond in a timely manner with effective measures to limit the magnitude of loss from IT-related events. | AP012-03 |
| **Work Products (WPs)** | | |
| **Inputs** | | |
| **Number** | **Description** | **Supports** |
| EDM03-WP3 | Evaluation of risk management activities | AP012-BP1 AP012-01 |
| EDM03-WP4 | Risk management policies | |
| EDM03-WP5 | Key objectives to be monitored for risk management | |
| EDM03-WP6 | Approved process for measuring risk management | |
| AP002-WP3 | Gaps and risk related to current capabilities | |
| AP002-WP11 | Risk assessment initiatives | |
| AP010-WP10 | Identified supplier delivery risk | |
| DSS02-WP13 | Incident status and trends report | |
| DSS04-WP4 | Business impact analyses | AP012-BP2 AP012-01/04 |
| DSS05-WP2 | Evaluations of potential threats | |
| Outside COBIT | Threat advisories | |
| EDM03-WP1 | Risk appetite guidance | AP012-BP3 AP012-02 |
| EDM03-WP2 | Approved risk tolerance levels | |
| AP010-WP10 | Identified supplier delivery risk | |
| DSS05-WP2 | Evaluations of potential threats | |
| EDM03-WP7 | Remedial actions to address risk management deviations | AP012-BP6 AP012-03 |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | APO12 *(cont.)* | | |
|---|---|---|---|
| **Process Name** | **Manage Risk** | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| APO12-WP1 | Data on the operating environment relating to risk | Internal | APO12-BP1<br>APO12-01 |
| APO12-WP2 | Data on risk events and contributing factors | Internal | |
| APO12-WP3 | Emerging risk issues and factors | EDM03.01<br>APO01.03<br>APO02.02 | |
| APO12-WP4 | Scope of risk analysis efforts | Internal | APO12-BP2<br>APO12-01/04 |
| APO12-WP5 | IT risk scenarios | Internal | |
| APO12-WP6 | Risk analysis results | EDM03.03<br>APO01.03<br>APO02.02<br>BAI01.10 | |
| APO12-WP7 | Documented risk scenarios by line of business and function | Internal | APO12-BP3<br>APO12-02 |
| APO12-WP8 | Aggregated risk profile, including status of risk management actions | EDM03.02<br>APO02.02 | |
| APO12-WP9 | Risk analysis and risk profile reports for stakeholders | EDM03.03<br>EDM05.02<br>APO10.04<br>MEA02.08 | APO12-BP4<br>APO12-03/04 |
| APO12-WP10 | Results of third-party risk assessments | EDM03.03<br>APO10.04<br>MEA02.01 | |
| APO12-WP11 | Opportunities for acceptance of greater risk | EDM03.03 | |
| APO12-WP12 | Project proposals for reducing risk | APO02.02<br>APO13.02 | APO12-BP5<br>APO12-03/04 |
| APO12-WP13 | Risk-related incident response plans | DSS02.05 | APO12-BP6<br>APO12-03 |
| APO12-WP14 | Risk impact communication | APO01.04<br>APO08.04<br>DSS04.02 | |
| APO12-WP15 | Risk-related root causes | DSS02.03<br>DSS03.01<br>DSS03.02<br>DSS04.02<br>MEA02.04<br>MEA02.07<br>MEA02.08 | |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | AP013 | | |
|---|---|---|---|
| **Process Name** | **Manage Security** | | |
| **Process Description** | Define, operate and monitor a system for information security management. | | |
| **Process Purpose Statement** | Keep the impact and occurrence of information security incidents within the enterprise's risk appetite levels. | | |
| **Outcomes (Os)** | | | |
| **Number** | **Description** | | |
| AP013-01 | A system is in place that considers and effectively addresses enterprise information security requirements. | | |
| AP013-02 | A security plan has been established, accepted and communicated throughout the enterprise. | | |
| AP013-03 | Information security solutions are implemented and operated consistently throughout the enterprise. | | |
| **Base Practices (BPs)** | | | |
| **Number** | **Description** | | **Supports** |
| AP013-BP1 | **Establish and maintain an information security management system (ISMS).** Establish and maintain an ISMS that provides a standard, formal and continuous approach to security management for information, enabling secure technology and business processes that are aligned with business requirements and enterprise security management. | | AP013-01 |
| AP013-BP2 | **Define and manage an information security risk treatment plan.** Maintain an information security plan that describes how information security risk is to be managed and aligned with the enterprise strategy and enterprise architecture. Ensure that recommendations for implementing security improvements are based on approved business cases and implemented as an integral part of services and solutions development, then operated as an integral part of business operation | | AP013-02 |
| AP013-BP3 | **Monitor and review the ISMS.** Maintain and regularly communicate the need for, and benefits of, continuous information security improvement. Collect and analyse data about the ISMS, and improve the effectiveness of the ISMS. Correct non-conformities to prevent recurrence. Promote a culture of security and continual improvement. | | AP013-01/03 |
| **Work Products (WPs)** | | | |
| **Inputs** | | | |
| **Number** | **Description** | | **Supports** |
| Outside COBIT | Enterprise security approach | | AP013-BP1<br>AP013-01 |
| AP002-WP8 | Gaps and changes required to realise target capability | | AP013-BP2<br>AP013-02 |
| AP003-WP4 | Baseline domain descriptions and architecture definition | | |
| AP012-WP12 | Project proposals for reducing risk | | |
| DSS02-WP5 | Classified and prioritised incidents and service requests | | AP013-BP3<br>AP013-01/03 |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| AP013-WP1 | ISMS policy | Internal | AP013-BP1<br>AP013-01 |
| AP013-WP2 | ISMS scope statement | AP001.02<br>DSS06.03 | |
| AP013-WP3 | Information security risk treatment plan | All EDM<br>All APO<br>All BAI<br>All DSS<br>All MEA | AP013-BP2<br>AP013-02 |
| AP013-WP4 | Information security business cases | AP002.05 | |
| AP013-WP5 | ISMS audit reports | MEA02.01 | AP013-BP3<br>AP013-01/03 |
| AP013-WP6 | Recommendations for improving the ISMS | Internal | |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

**Page intentionally left blank**



Personal Copy of: Mr. Jorge Diab Maluf Filho

# 3.3 Build, Acquire and Implement (BAI)

**01** Manage programmes and projects.

**02** Manage requirements definition.

**03** Manage solutions identification and build.

**04** Manage availability and capacity.

**05** Manage organisational change enablement.

**06** Manage changes.

**07** Manage change acceptance and transitioning.

**08** Manage knowledge.

**09** Manage assets.

**10** Manage configuration.



Personal Copy of: Mr. Jorge Diab Maluf Filho

**Page intentionally left blank**



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | BAI01 | |
|---|---|---|
| **Process Name** | **Manage Programmes and Projects** | |
| **Process Description** | Manage all programmes and projects from the investment portfolio in alignment with enterprise strategy and in a co-ordinated way. Initiate, plan, control, and execute programmes and projects, and close with a post-implementation review. | |
| **Process Purpose Statement** | Realise business benefits and reduce the risk of unexpected delays, costs and value erosion by improving communication to and involvement of business and end users, ensuring the value and quality of project deliverables, and maximising their contribution to the investment and services portfolio. | |
| **Outcomes (Os)** | | |
| **Number** | **Description** | |
| BAI01-01 | Relevant stakeholders are engaged in the programmes and projects. | |
| BAI01-02 | The scope and outcomes of programmes and projects are viable and aligned with objectives. | |
| BAI01-03 | Programme and project plans are likely to achieve the expected outcomes. | |
| BAI01-04 | The programme and project activities are executed according to the plans. | |
| BAI01-05 | There are sufficient programme and project resources to perform activities according to the plans. | |
| BAI01-06 | The programme and project expected benefits are achieved and accepted. | |
| **Base Practices (BPs)** | | |
| **Number** | **Description** | **Supports** |
| BAI01-BP1 | **Maintain a standard approach for programme and project management.**<br>Maintain a standard approach for programme and project management that enables governance and management review and decision making and delivery management activities focussed on achieving value and goals (requirements, risk, costs, schedule, quality) for the business in a consistent manner. | BAI01-02 |
| BAI01-BP2 | **Initiate a programme.**<br>Initiate a programme to confirm the expected benefits and obtain authorisation to proceed. This includes agreeing on programme sponsorship, confirming the programme mandate through approval of the conceptual business case, appointing programme board or committee members, producing the programme brief, reviewing and updating the business case, developing a benefits realisation plan, and obtaining approval from sponsors to proceed. | BAI01-01 |
| BAI01-BP3 | **Manage stakeholder engagement.**<br>Manage stakeholder engagement to ensure an active exchange of accurate, consistent and timely information that reaches all relevant stakeholders. This includes planning, identifying and engaging stakeholders and managing their expectations. | |
| BAI01-BP4 | **Develop and maintain the programme plan.**<br>Formulate a programme to lay the initial groundwork and to position it for successful execution by formalising the scope of the work to be accomplished and identifying the deliverables that will satisfy its goals and deliver value. Maintain and update the programme plan and business case throughout the full economic life cycle of the programme, ensuring alignment with strategic objectives and reflecting the current status and updated insights gained to date. | BAI01-03 |
| BAI01-BP5 | **Launch and execute the programme.**<br>Launch and execute the programme to acquire and direct the resources needed to accomplish the goals and benefits of the programme as defined in the programme plan. In accordance with stage-gate or release review criteria, prepare for stage-gate, iteration or release reviews to report on the progress of the programme and to be able to make the case for funding up to the following stage-gate or release review. | BAI01-04 |
| BAI01-BP6 | **Monitor, control and report on the programme outcomes.**<br>Monitor and control programme (solution delivery) and enterprise (value/outcome) performance against plan throughout the full economic life cycle of the investment. Report this performance to the programme steering committee and the sponsors. | BAI01-06 |
| BAI01-BP7 | **Start up and initiate projects within a programme.**<br>Define and document the nature and scope of the project to confirm and develop amongst stakeholders a common understanding of project scope and how it relates to other projects within the overall IT-enabled investment programme. The definition should be formally approved by the programme and project sponsors. | BAI01-02 |
| BAI01-BP8 | **Plan projects.**<br>Establish and maintain a formal, approved integrated project plan (covering business and IT resources) to guide project execution and control throughout the life of the project. The scope of projects should be clearly defined and tied to building or enhancing business capability. | BAI01-03 |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | BAI01 *(cont.)* | |
|---|---|---|
| **Process Name** | **Manage Programmes and Projects** | |
| **Base Practices (BPs) *(cont.)*** | | |
| **Number** | **Description** | **Supports** |
| BAI01-BP9 | **Manage programme and project quality.**<br>Prepare and execute a quality management plan, processes and practices, aligned with the QMS that describes the programme and project quality approach and how it will be implemented. The plan should be formally reviewed and agreed on by all parties concerned and then incorporated into the integrated programme and project plans. | BAI01-04/05 |
| BAI01-BP10 | **Manage programme and project risk.**<br>Eliminate or minimise specific risk associated with programmes and projects through a systematic process of planning, identifying, analysing, responding to, and monitoring and controlling the areas or events that have the potential to cause unwanted change. Risk faced by programme and project management should be established and centrally recorded. | BAI01-05 |
| BAI01-BP11 | **Monitor and control projects.**<br>Measure project performance against key project performance criteria such as schedule, quality, cost and risk. Identify any deviations from the expected. Assess the impact of deviations on the project and overall programme, and report results to key stakeholders. | BAI01-04/06 |
| BAI01-BP12 | **Manage project resources and work packages.**<br>Manage project by work packages by placing formal requirements on authorising and accepting work packages, and assigning and co-ordinating appropriate business and IT resources. | BAI01-04 |
| BAI01-BP13 | **Close a project or iteration.**<br>At the end of each project, release or iteration, require the project stakeholders to ascertain whether the project, release or iteration delivered the planned results and value. Identify and communicate any outstanding activities required to achieve the planned results of the project and the benefits of the programme, and identify and document lessons learned for use on future projects, releases, iterations and programmes. | BAI01-04/06 |
| BAI01-BP14 | **Close a programme.**<br>Remove the programme from the active investment portfolio when there is agreement that the desired value has been achieved or when it is clear it will not be achieved within the value criteria set for the programme. | |
| **Work Products (WPs)** | | |
| **Inputs** | | |
| **Number** | **Description** | **Supports** |
| EDM02-WP4 | Requirements for stage-gate reviews | BAI01-BP1<br>BAI01-02 |
| EDM02-WP6 | Actions to improve value delivery | |
| AP003-WP10 | Implementation phase descriptions | |
| AP003-WP11 | Architecture governance requirements | |
| AP005-WP10 | Updated portfolios of programmes, services and assets | |
| AP010-WP10 | Identified supplier delivery risk | |
| AP003-WP9 | Resource requirements | BAI01-BP2<br>BAI01-01 |
| AP003-WP10 | Implementation phase descriptions | |
| AP005-WP6 | Programme business case | |
| AP007-WP5 | Skills and competencies matrix | |
| BAI05-WP4 | Common vision and goals | |
| AP005-WP8 | Selected programmes with return on investment (ROI) milestones | BAI01-BP4<br>BAI01-03 |
| AP007-WP5 | Skills and competencies matrix | |
| AP007-WP11 | Inventory of business and IT human resources | |
| BAI05-WP3 | Implementation team and roles | |
| BAI05-WP5 | Vision communication plan | |
| BAI05-WP8 | Identified quick wins | |
| BAI07-WP4 | Approved acceptance test plan | |
| BAI07-WP8 | Approved acceptance and release for production | |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | BAI01 *(cont.)* | | |
|---|---|---|---|
| **Process Name** | **Manage Programmes and Projects** | | |
| **Work Products (WPs)** *(cont.)* | | | |
| **Inputs** | | | |
| **Number** | **Description** | | **Supports** |
| BAI05-WP6 | Vision communications | | BAI01-BP5<br>BAI01-04 |
| EDM02-WP5 | Feedback on portfolio and programme performance | | BAI01-BP6<br>BAI01-06 |
| APO05-WP5 | Investment return expectations | | |
| APO05-WP7 | Business case assessments | | |
| APO05-WP9 | Investment portfolio performance reports | | |
| APO05-WP11 | Benefit results and related communications | | |
| APO05-WP12 | Corrective actions to improve benefit realisation | | |
| APO07-WP12 | Resourcing shortfall analyses | | |
| APO07-WP13 | Resource utilisation records | | |
| BAI05-WP9 | Communications of benefits | | |
| BAI06-WP5 | Change request status reports | | |
| BAI07-WP7 | Evaluation of acceptance results | | |
| BAI07-WP4 | Approved acceptance test plan | | BAI01-BP8<br>BAI01-03 |
| APO11-WP2 | Quality management plans | | BAI01-BP9<br>BAI01-04/05 |
| APO11-WP5 | Customer requirements for quality management | | |
| APO12-WP6 | Risk analysis results | | BAI01-BP10<br>BAI01-05 |
| BAI02-WP6 | Requirements risk register | | |
| BAI02-WP7 | Risk mitigation actions | | |
| Outside COBIT | ERM framework | | |
| BAI07-WP12 | Post-implementation review report | | BAI01-BP13<br>BAI01-04/06 |
| BAI07-WP13 | Remedial action plan | | |
| BAI07-WP12 | Post-implementation review report | | BAI01-BP14<br>BAI01-04/06 |
| BAI07-WP13 | Remedial action plan | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| BAI01-WP1 | Updated programme and project management approaches | Internal | BAI01-BP1<br>BAI01-02 |
| BAI01-WP2 | Programme concept business case | APO05.03 | BAI01-WP2<br>BAI01-01 |
| BAI01-WP3 | Programme mandate and brief | APO05.03 | |
| BAI01-WP4 | Programme benefit realisation plan | APO05.03<br>APO06.05 | |
| BAI01-WP5 | Stakeholder engagement plan | Internal | BAI01-BP3<br>BAI01-01 |
| BAI01-WP6 | Results of stakeholder engagement effectiveness assessments | Internal | |
| BAI01-WP7 | Programme plan | Internal | BAI01-BP4<br>BAI01-03 |
| BAI01-WP8 | Programme budget and benefits register | APO05.06<br>APO06.05 | |
| BAI01-WP9 | Resource requirements and roles | APO07.05<br>APO07.06 | |
| BAI01-WP10 | Results of benefit realisation monitoring | APO05.06<br>APO06.05 | BAI01-BP5<br>BAI01-04 |
| BAI01-WP11 | Results of programme goal achievement monitoring | APO02.04 | |
| BAI01-WP12 | Programme audit plans | MEA02.06 | |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | BAI01 *(cont.)* | | |
|---|---|---|---|
| **Process Name** | **Manage Programmes and Projects** | | |
| **Outputs *(cont.)*** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| BAI01-WP13 | Results of programme performance reviews | MEA01.03 | BAI01-BP6<br>BAI01-06 |
| BAI01-WP14 | Stage-gate review results | EDM02.01<br>APO02.04<br>APO05.04 | |
| BAI01-WP15 | Project scope statements | Internal | BAI01-BP7<br>BAI01-02 |
| BAI01-WP16 | Project definitions | Internal | |
| BAI01-WP17 | Project plans | Internal | BAI01-BP8<br>BAI01-03 |
| BAI01-WP18 | Project baseline | Internal | |
| BAI01-WP19 | Project reports and communications | Internal | |
| BAI01-WP20 | Quality management plan | BAI02.04<br>BAI03.06<br>BAI07.01 | BAI01-BP9<br>BAI01-04/05 |
| BAI01-WP21 | Requirements for independent verification of deliverables | BAI07.03 | |
| BAI01-WP22 | Project risk management plan | Internal | BAI01-BP10<br>BAI01-05 |
| BAI01-WP23 | Project risk assessment results | Internal | |
| BAI01-WP24 | Project risk register | Internal | |
| BAI01-WP25 | Project performance criteria | Internal | BAI01-BP11<br>BAI01-04/06 |
| BAI01-WP26 | Project progress reports | Internal | |
| BAI01-WP27 | Agreed-on changes to project | Internal | |
| BAI01-WP28 | Project resource requirements | APO07.05<br>APO07.06 | BAI01-BP12<br>BAI01-04 |
| BAI01-WP29 | Project roles and responsibilities | Internal | |
| BAI01-WP30 | Gaps in project planning | Internal | |
| BAI01-WP31 | Post-implementation review results | APO02.04 | BAI01-BP13<br>BAI01-04/06 |
| BAI01-WP32 | Project lessons learned | Internal | |
| BAI01-WP33 | Stakeholder project acceptance confirmations | Internal | |
| BAI01-WP34 | Communication of programme retirement and ongoing accountabilities | APO05.05<br>APO07.06 | BAI01-BP14<br>BAI01-04/06 |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | BAI02 | |
|---|---|---|
| **Process Name** | **Manage Requirements Definition** | |
| **Process Description** | Identify solutions and analyse requirements before acquisition or creation to ensure that they are in line with enterprise strategic requirements covering business processes, applications, information/data, infrastructure and services. Co-ordinate with affected stakeholders the review of feasible options including relative costs and benefits, risk analysis, and approval of requirements and proposed solutions. | |
| **Process Purpose Statement** | Create feasible optimal solutions that meet enterprise needs while minimising risk. | |
| **Outcomes (Os)** | | |
| **Number** | **Description** | |
| BAI02-01 | Business functional and technical requirements reflect enterprise needs and expectations. | |
| BAI02-02 | The proposed solution satisfies business functional, technical and compliance requirements. | |
| BAI02-03 | Risk associated with the requirements has been addressed in the proposed solution. | |
| BAI02-04 | Requirements and proposed solutions meet business case objectives (value expected and likely costs). | |
| **Base Practices (BPs)** | | |
| **Number** | **Description** | **Supports** |
| BAI02-BP1 | **Define and maintain business functional and technical requirements.**<br>Based on the business case, identify, prioritise, specify and agree on business information, functional, technical and control requirements covering the scope/understanding of all initiatives required to achieve the expected outcomes of the proposed IT-enabled business solution. | BAI02-01 |
| BAI02-BP2 | **Perform a feasibility study and formulate alternative solutions.**<br>Perform a feasibility study of potential alternative solutions, assess their viability and select the preferred option. If appropriate, implement the selected option as a pilot to determine possible improvements. | BAI02-02/04 |
| BAI02-BP3 | **Manage requirements risk.**<br>Identify, document, prioritise and mitigate functional, technical and information processing-related risks associated with the enterprise requirements and proposed solution. | BAI02-03 |
| BAI02-BP4 | **Obtain approval of requirements and solutions.**<br>Co-ordinate feedback from affected stakeholders and, at predetermined key stages, obtain business sponsor or product owner approval and sign-off on functional and technical requirements, feasibility studies, risk analyses and recommended solutions. | BAI02-01 |
| **Work Products (WPs)** | | |
| **Inputs** | | |
| **Number** | **Description** | **Supports** |
| AP001-WP10 | Data classification guidelines | BAI02-BP1<br>BAI02-01 |
| AP001-WP11 | Data security and control guidelines | |
| AP001-WP12 | Data integrity procedures | |
| AP003-WP2 | Architecture principles | |
| AP003-WP4 | Baseline domain descriptions and architecture definition | |
| AP003-WP6 | Information architecture model | |
| AP003-WP12 | Solution development guidance | |
| AP010-WP4 | Supplier requests for information (RFIs) and requests for proposals (RFPs) | |
| AP011-WP6 | Acceptance criteria | |
| AP003-WP12 | Solution development guidance | BAI02-BP2<br>BAI02-02/04 |
| AP010-WP2 | Supplier catalogue | |
| AP010-WP4 | Supplier requests for information (RFIs) and requests for proposals (RFPs) | |
| AP010-WP5 | RFI and RFP evaluations | |
| AP010-WP6 | Decision results of supplier evaluations | |
| AP011-WP6 | Acceptance criteria | |
| BAI01-WP20 | Quality management plan | BAI02-BP4<br>BAI02-01 |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | BAI02 *(cont.)* | | |
|---|---|---|---|
| **Process Name** | **Manage Requirements Definition** | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| BAI02-WP1 | Requirements definition repository | BAI03.01<br>BAI03.02<br>BAI04.01<br>BAI05.01 | BAI02-BP1<br>BAI02-01 |
| BAI02-WP2 | Confirmed acceptance criteria from stakeholders | BAI03.01<br>BAI03.02<br>BAI04.03<br>BAI05.01<br>BAI05.02 | |
| BAI02-WP3 | Record of requirement change requests | BAI03.09 | |
| BAI02-WP4 | Feasibility study report | BAI03.02<br>BAI03.03 | BAI02-BP2<br>BAI02-02/04 |
| BAI02-WP5 | High-level acquisition/development plan | APO10.02<br>BAI03.01 | |
| BAI02-WP6 | Requirements risk register | BAI01.10<br>BAI03.02<br>BAI04.01<br>BAI05.01 | BAI02-BP3<br>BAI02-03 |
| BAI02-WP7 | Risk mitigation actions | BAI01.10<br>BAI03.02<br>BAI05.01 | |
| BAI02-WP8 | Sponsor approvals of requirements and proposed solutions | BAI03.02<br>BAI03.03<br>BAI03.04 | BAI02-BP4<br>BAI02-01 |
| BAI02-WP9 | Approved quality reviews | APO11.02 | |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | BAI03 | |
|---|---|---|
| **Process Name** | **Manage Solutions Identification and Build** | |
| **Process Description** | Establish and maintain identified solutions in line with enterprise requirements covering design, development, procurement/sourcing and partnering with suppliers/vendors. Manage configuration, test preparation, testing, requirements management and maintenance of business processes, applications, information/data, infrastructure and services. | |
| **Process Purpose Statement** | Establish timely and cost-effective solutions capable of supporting enterprise strategic and operational objectives. | |
| **Outcomes (Os)** | | |
| **Number** | **Description** | |
| BAI03-01 | The solution design, including relevant components, meets enterprise needs, aligns with standards and addresses all identified risk. | |
| BAI03-02 | The solution conforms to the design, is in accordance with organisational standards, and has appropriate control, security and auditability. | |
| BAI03-03 | The solution is of acceptable quality and has been successfully tested. | |
| BAI03-04 | Approved changes to requirements are correctly incorporated into the solution. | |
| BAI03-05 | Maintenance activities successfully address business and technological needs. | |
| **Base Practices (BPs)** | | |
| **Number** | **Description** | **Supports** |
| BAI03-BP1 | **Design high-level solutions.** Develop and document high-level designs using agreed-on and appropriate phased or rapid agile development techniques. Ensure alignment with the IT strategy and enterprise architecture. Reassess and update the designs when significant issues occur during detailed design or building phases or as the solution evolves. Ensure that stakeholders actively participate in the design and approve each version. | BAI03-01/02 |
| BAI03-BP2 | **Design detailed solution components.** Develop, document and elaborate detailed designs progressively using agreed-on and appropriate phased or rapid agile development techniques, addressing all components (business processes and related automated and manual controls, supporting IT applications, infrastructure services and technology products, and partners/suppliers). Ensure that the detailed design includes internal and external SLAs and OLAs. | |
| BAI03-BP3 | **Develop solution components.** Develop solution components progressively in accordance with detailed designs following development methods and documentation standards, quality assurance (QA) requirements, and approval standards. Ensure that all control requirements in the business processes, supporting IT applications and infrastructure services, services and technology products, and partners/suppliers are addressed. | BAI03-02/03 |
| BAI03-BP4 | **Procure solution components.** Procure solution components based on the acquisition plan in accordance with requirements and detailed designs, architecture principles and standards, and the enterprise's overall procurement and contract procedures, QA requirements, and approval standards. Ensure that all legal and contractual requirements are identified and addressed by the supplier. | BAI03-01/02 |
| BAI03-BP5 | **Build solutions.** Install and configure solutions and integrate with business process activities. Implement control, security and audit ability measures during configuration, and during integration of hardware and infrastructural software, to protect resources and ensure availability and data integrity. Update the services catalogue to reflect the new solutions. | BAI03-01 |
| BAI03-BP6 | **Perform quality assurance (QA).** Develop, resource and execute a QA plan aligned with the QMS to obtain the quality specified in the requirements definition and the enterprise's quality policies and procedures. | BAI03-03 |
| BAI03-BP7 | **Prepare for solution testing.** Establish a test plan and required environments to test the individual and integrated solution components, including the business processes and supporting services, applications and infrastructure. | |
| BAI03-BP8 | **Execute solution testing.** Execute testing continually during development, including control testing, in accordance with the defined test plan and development practices in the appropriate environment. Engage business process owners and end users in the test team. Identify, log and prioritise errors and issues identified during testing. | |
| BAI03-BP9 | **Manage changes to requirements.** Track the status of individual requirements (including all rejected requirements) throughout the product life cycle and manage the approval of changes to requirements. | BAI03-04 |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | BAI03 *(cont.)* | |
|---|---|---|
| **Process Name** | **Manage Solutions Identification and Build** | |
| **Base Practices (BPs) *(cont.)*** | | |
| **Number** | **Description** | **Supports** |
| BAI03-BP10 | **Maintain solutions.**<br>Develop and execute a plan for the maintenance of solution and infrastructure components. Include periodic reviews against business needs and operational requirements | BAI03-05 |
| BAI03-BP11 | **Define IT services and maintain the service portfolio.**<br>Define and agree on new or changed IT services and service level options. Document new or changed service definitions and service level options to be updated in the services portfolio. | BAI03-01/02 |
| **Work Products (WPs)** | | |
| **Inputs** | | |
| **Number** | **Description** | **Supports** |
| APO03-WP2 | Architecture principles | BAI03-BP1<br>BAI03-01/02 |
| APO03-WP4 | Baseline domain descriptions and architecture definition | |
| APO04-WP4 | Research analyses of innovation possibilities | |
| APO04-WP5 | Evaluations of innovation ideas | |
| BAI02-WP1 | Requirements definition repository | |
| BAI02-WP2 | Confirmed acceptance criteria from stakeholders | |
| BAI02-WP5 | High-level acquisition/development plan | |
| APO03-WP2 | Architecture principles | BAI03-BP2<br>BAI03-01/02 |
| APO03-WP4 | Baseline domain descriptions and architecture definition | |
| APO03-WP6 | Information architecture model | |
| APO03-WP12 | Solution development guidance | |
| APO04-WP10 | Assessments of using innovative approaches | |
| BAI02-WP1 | Requirements definition repository | |
| BAI02-WP2 | Confirmed acceptance criteria from stakeholders | |
| BAI02-WP4 | Feasibility study report | |
| BAI02-WP6 | Requirements risk register | |
| BAI02-WP7 | Risk mitigation actions | |
| BAI02-WP8 | Sponsor approvals of requirements and proposed solutions | |
| BAI02-WP4 | Feasibility study report | BAI03-BP3<br>BAI03-02/03 |
| BAI02-WP8 | Sponsor approvals of requirements and proposed solutions | |
| BAI02-WP8 | Sponsor approvals of requirements and proposed solutions | BAI03-BP4<br>BAI03-01/02 |
| APO11-WP3 | Results of QMS effectiveness reviews | BAI03-BP6<br>BAI03-03 |
| BAI01-WP20 | Quality management plan | |
| APO04-WP9 | Analysis of rejected initiatives | BAI03-BP8<br>BAI03-03 |
| APO04-WP8 | Results and recommendations from proof-of-concept initiatives | BAI03-BP9<br>BAI03-04 |
| BAI02-WP3 | Record of requirement change requests | |
| EDM04-WP1 | Guiding principles for allocation of resources and capabilities | BAI03-BP11<br>BAI03-01/02 |
| APO02-WP8 | Gaps and changes required to realise target capability | |
| APO02-WP9 | Value benefit statement for target environment | |
| APO06-WP5 | Budget allocations | |
| APO06-WP6 | IT budget and plan | |
| APO06-WP7 | Budget communications | |
| APO08-WP9 | Definition of potential improvement projects | |
| BAI10-WP4 | Configuration baseline | |
| BAI10-WP6 | Approved changes to baseline | |
| BAI10-WP7 | Configuration status reports | |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | BAI03 *(cont.)* | | |
|---|---|---|---|
| **Process Name** | **Manage Solutions Identification and Build** | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| BAI03-WP1 | Approved high-level design specification | BAI04.03<br>BAI05.01 | BAI03-BP1<br>BAI03-01/02 |
| BAI03-WP2 | Approved detailed design specification | BAI04.03<br>BAI05.01 | BAI03-BP2<br>BAI03-01/02 |
| BAI03-WP3 | SLA and OLA revisions | BAI04.02 | |
| BAI03-WP4 | Documented solution components | BAI04.03<br>BAI05.05<br>BAI08.03<br>BAI08.04 | BAI03-BP3<br>BAI03-02/03 |
| BAI03-WP5 | Approved acquisition plan | APO10.03 | BAI03-BP4<br>BAI03-01/02 |
| BAI03-WP6 | Updates to asset inventory | BAI09.01 | |
| BAI03-WP7 | Integrated and configured solution components | BAI06.01 | BAI03-BP5<br>BAI03-01 |
| BAI03-WP8 | Quality assurance plan | APO11.04 | BAI03-BP6<br>BAI03-03 |
| BAI03-WP9 | Quality review results, exceptions and corrections | APO11.04 | |
| BAI03-WP10 | Test plan | BAI07.03 | BAI03-BP7<br>BAI03-03 |
| BAI03-WP11 | Test procedures | BAI07.03 | |
| BAI03-WP12 | Test result logs and audit trails | BAI07.03 | BAI03-BP8<br>BAI03-03 |
| BAI03-WP13 | Test result communications | BAI07.03 | |
| BAI03-WP14 | Record of all approved and applied change requests | BAI06.03 | BAI03-BP9<br>BAI03-04 |
| BAI03-WP15 | Maintenance plan | APO08.05 | BAI03-BP10<br>BAI03-05 |
| BAI03-WP16 | Updated solution components and related documentation | BAI05.05 | |
| BAI03-WP17 | Service definitions | APO05.01<br>DSS01.03 | BAI03-BP11<br>BAI03-01/02 |
| BAI03-WP18 | Updated service portfolio | APO05.05 | |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

**Page intentionally left blank**



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | BAI04 | |
|---|---|---|
| **Process Name** | **Manage Availability and Capacity** | |
| **Process Description** | Balance current and future needs for availability, performance and capacity with cost-effective service provision. Include assessment of current capabilities, forecasting of future needs based on business requirements, analysis of business impacts, and assessment of risk to plan and implement actions to meet the identified requirements. | |
| **Process Purpose Statement** | Maintain service availability, efficient management of resources, and optimisation of system performance through prediction of future performance and capacity requirements. | |
| **Outcomes (Os)** | | |
| **Number** | **Description** | |
| BAI04-01 | The availability plan anticipates the business expectation of critical capacity requirements. | |
| BAI04-02 | Capacity, performance and availability meet requirements. | |
| BAI04-03 | Availability, performance and capacity issues are identified and routinely resolved. | |
| **Base Practices (BPs)** | | |
| **Number** | **Description** | **Supports** |
| BAI04-BP1 | **Assess current availability, performance and capacity and create a baseline.** Assess availability, performance and capacity of services and resources to ensure that cost-justifiable capacity and performance are available to support business needs and deliver against SLAs. Create availability, performance and capacity baselines for future comparison. | BAI04-01/02/03 |
| BAI04-BP2 | **Assess business impact.** Identify important services to the enterprise, map services and resources to business processes, and identify business dependencies. Ensure that the impact of unavailable resources is fully agreed on and accepted by the customer. Ensure that, for vital business functions, the SLA availability requirements can be satisfied. | BAI04-01 |
| BAI04-BP3 | **Plan for new or changed service requirements.** Plan and prioritise availability, performance and capacity implications of changing business needs and service requirements. | |
| BAI04-BP4 | **Monitor and review availability and capacity.** Monitor, measure, analyse, report and review availability, performance and capacity. Identify deviations from established baselines. Review trend analysis reports identifying any significant issues and variances, initiating actions where necessary and ensuring that all outstanding issues are followed up. | BAI04-02/03 |
| BAI04-BP5 | **Investigate and address availability, performance and capacity issues.** Address deviations by investigating and resolving identified availability, performance and capacity issues. | |
| **Work Products (WPs)** | | |
| **Inputs** | | |
| **Number** | **Description** | **Supports** |
| BAI02-WP1 | Requirements definition repository | BAI04-BP1 BAI04-01/02/03 |
| BAI02-WP6 | Requirements risk register | |
| BAI03-WP3 | SLA and OLA revisions | BAI04-BP2 BAI04-01 |
| BAI02-WP2 | Confirmed acceptance criteria from stakeholders | BAI04-BP3 BAI04-01 |
| BAI03-WP1 | Approved high-level design specification | |
| BAI03-WP2 | Approved detailed design specification | |
| BAI03-WP4 | Documented solution components | |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | BAI04 *(cont.)* | | |
|---|---|---|---|
| **Process Name** | **Manage Availability and Capacity** | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| BAI04-WP1 | Availability, performance and capacity baselines | Internal | BAI04-BP1<br>BAI04-01/02/03 |
| BAI04-WP2 | Evaluations against SLAs | AP009.05 | |
| BAI04-WP3 | Availability, performance and capacity scenarios | Internal | BAI04-BP2<br>BAI04-01 |
| BAI04-WP4 | Availability, performance and capacity business impact assessments | Internal | |
| BAI04-WP5 | Prioritised improvements | AP002.02 | BAI04-BP3<br>BAI04-01 |
| BAI04-WP6 | Performance and capacity plans | AP002.02 | |
| BAI04-WP7 | Availability, performance and capacity reports | MEA01.03 | BAI04-BP4<br>BAI04-02/03 |
| BAI04-WP8 | Performance and capacity gaps | Internal | BAI04-BP5<br>BAI04-02/03 |
| BAI04-WP9 | Corrective actions | AP002.02 | |
| BAI04-WP10 | Emergency escalation procedure | DSS02.02 | |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | BAI05 | |
|---|---|---|
| **Process Name** | **Manage Organisational Change Enablement** | |
| **Process Description** | Maximise the likelihood of successfully implementing sustainable enterprisewide organisational change quickly and with reduced risk, covering the complete life cycle of the change and all affected stakeholders in the business and IT. | |
| **Process Purpose Statement** | Prepare and commit stakeholders for business change and reduce the risk of failure. | |
| **Outcomes (Os)** | | |
| **Number** | **Description** | |
| BAI05-01 | Stakeholder desire for the change has been understood. | |
| BAI05-02 | Implementation team is competent and able to drive the change. | |
| BAI05-03 | Desired change is understood and accepted by stakeholders. | |
| BAI05-04 | Role players are empowered to deliver the change. | |
| BAI05-05 | Role players are enabled to operate, use and maintain the change. | |
| BAI05-06 | The change is embedded and sustained. | |
| **Base Practices (BPs)** | | |
| **Number** | **Description** | **Supports** |
| BAI05-BP1 | **Establish the desire to change.**<br>Understand the scope and impact of the envisioned change and stakeholder readiness/willingness to change. Identify actions to motivate stakeholders to accept and want to make the change work successfully. | BAI05-01 |
| BAI05-BP2 | **Form an effective implementation team.**<br>Establish an effective implementation team by assembling appropriate members, creating trust, and establishing common goals and effectiveness measures. | BAI05-02 |
| BAI05-BP3 | **Communicate desired vision.**<br>Communicate the desired vision for the change in the language of those affected by it. The communication should be made by senior management and include the rationale for, and benefits of, the change, the impacts of not making the change; and, the vision, the road map and the involvement required of the various stakeholders. | BAI05-03 |
| BAI05-BP4 | **Empower role players and identify short-term wins.**<br>Empower those with implementation roles by ensuring that accountabilities are assigned, providing training, and aligning organisational structures and HR processes. Identify and communicate short-term wins that can be realised and are important from a change enablement perspective. | BAI05-04 |
| BAI05-BP5 | **Enable operation and use.**<br>Plan and implement all technical, operational and usage aspects such that all those who are involved in the future state environment can exercise their responsibility. | BAI05-05 |
| BAI05-BP6 | **Embed new approaches.**<br>Embed the new approaches by tracking implemented changes, assessing the effectiveness of the operation and use plan, and sustaining ongoing awareness through regular communication. Take corrective measures as appropriate, which may include enforcing compliance. | BAI05-06 |
| BAI05-BP7 | **Sustain changes.**<br>Sustain changes through effective training of new staff, ongoing communication campaigns, continued top management commitment, adoption monitoring and sharing of lessons learned across the enterprise. | |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | BAI05 *(cont.)* | | |
|---|---|---|---|
| **Process Name** | **Manage Organisational Change Enablement** | | |
| **Work Products (WPs)** | | | |
| **Inputs** | | | |
| **Number** | **Description** | | **Supports** |
| APO11-WP7 | Review results of quality of service, including customer feedback | | BAI05-BP1<br>BAI05-01 |
| BAI02-WP1 | Requirements definition repository | | |
| BAI02-WP2 | Confirmed acceptance criteria from stakeholders | | |
| BAI02-WP6 | Requirements risk register | | |
| BAI02-WP7 | Risk mitigation actions | | |
| BAI03-WP1 | Approved high-level design specification | | |
| BAI03-WP2 | Approved detailed design specification | | |
| BAI02-WP2 | Confirmed acceptance criteria from stakeholders | | BAI05-BP2<br>BAI05-02 |
| Outside COBIT | Enterprise organisational structure | | BAI05-BP4<br>BAI05-04 |
| BAI03-WP4 | Documented solution components | | BAI05-BP5<br>BAI05-05 |
| BAI03-WP16 | Updated solution components and related documentation | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| BAI05-WP1 | Communications of drivers for change | Internal | BAI05-BP1<br>BAI05-01 |
| BAI05-WP2 | Communications from executive management committing to change | Internal | |
| BAI05-WP3 | Implementation team and roles | BAI01.04 | BAI05-BP2<br>BAI05-02 |
| BAI05-WP4 | Common vision and goals | BAI01.02 | |
| BAI05-WP5 | Vision communication plan | BAI01.04 | BAI05-BP3<br>BAI05-03 |
| BAI05-WP6 | Vision communications | BAI01.05 | |
| BAI05-WP7 | Aligned HR performance objectives | APO07.04 | BAI05-BP4<br>BAI05-04 |
| BAI05-WP8 | Identified quick wins | BAI01.04 | |
| BAI05-WP9 | Communications of benefits | BAI01.06 | |
| BAI05-WP10 | Operation and use plan | APO08.04<br>BAI08.04<br>DSS01.01<br>DSS01.02<br>DSS06.02 | BAI05-BP5<br>BAI05-05 |
| BAI05-WP11 | Success measures and results | APO08.05<br>BAI07.07<br>BAI07.08<br>MEA01.03 | |
| BAI05-WP12 | Compliance audit results | MEA02.02<br>MEA03.03 | BAI05-BP6<br>BAI05-06 |
| BAI05-WP13 | Awareness communications | Internal | |
| BAI05-WP14 | HR performance review results | APO07.04 | |
| BAI05-WP15 | Knowledge transfer plans | BAI08.03<br>BAI08.04 | BAI05-BP7<br>BAI05-06 |
| BAI05-WP16 | Communications of management's commitment | Internal | |
| BAI05-WP17 | Reviews of operational use | MEA02.02 | |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | BAI06 | | |
|---|---|---|---|
| **Process Name** | **Manage Changes** | | |
| **Process Description** | Manage all changes in a controlled manner, including standard changes and emergency maintenance relating to business processes, applications and infrastructure. This includes change standards and procedures, impact assessment, prioritisation and authorisation, emergency changes, tracking, reporting, closure and documentation. | | |
| **Process Purpose Statement** | Enable fast and reliable delivery of change to the business and mitigation of the risks of negatively impacting the stability or integrity of the changed environment. | | |
| **Outcomes (Os)** | | | |
| **Number** | **Description** | | |
| BAI06-01 | Authorised changes are made in a timely manner and with minimal errors. | | |
| BAI06-02 | Impact assessments reveal the effect of the change on all affected components. | | |
| BAI06-03 | All emergency changes are reviewed and authorised after the change. | | |
| BAI06-04 | Key stakeholders are kept informed of all aspects of the change. | | |
| **Base Practices (BPs)** | | | |
| **Number** | **Description** | | **Supports** |
| BAI06-BP1 | **Evaluate, prioritise and authorise change requests.** Evaluate all requests for change to determine the impact on business processes and IT services, and to assess whether change will adversely affect the operational environment and introduce unacceptable risk. Ensure that changes are logged, prioritised, categorised, assessed, authorised, planned and scheduled. | | BAI06-02 |
| BAI06-BP2 | **Manage emergency changes.** Carefully manage emergency changes to minimise further incidents and make sure the change is controlled and takes place securely. Verify that emergency changes are appropriately assessed and authorised after the change. | | BAI06-03 |
| BAI06-BP3 | **Track and report change status.** Maintain a tracking and reporting system to document rejected changes, communicate the status of approved and in-process changes, and complete changes. Make certain that approved changes are implemented as planned. | | BAI06-01/04 |
| BAI06-BP4 | **Close and document the changes.** Whenever changes are implemented, update accordingly the solution and user documentation and the procedures affected by the change. | | BAI06-01/04 |
| **Work Products (WPs)** | | | |
| **Inputs** | | | |
| **Number** | **Description** | | **Supports** |
| BAI03-WP7 | Integrated and configured solution components | | BAI06-BP1<br>BAI06-02 |
| DSS02-WP6 | Approved service requests | | |
| DSS03-WP7 | Proposed solutions to known errors | | |
| DSS03-WP11 | Identified sustainable solutions | | |
| DSS04-WP18 | Approved changes to the plans | | |
| DSS06-WP2 | Root cause analyses and recommendations | | |
| BAI03-WP14 | Record of all approved and applied change requests | | BAI06-BP3<br>BAI06-01/04 |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| BAI06-WP1 | Impact assessments | Internal | BAI06-BP1<br>BAI06-02 |
| BAI06-WP2 | Approved requests for change | BAI07.01 | |
| BAI06-WP3 | Change plan and schedule | BAI07.01 | |
| BAI06-WP4 | Post-implementation review of emergency changes | Internal | BAI06-BP2<br>BAI06-03 |
| BAI06-WP5 | Change request status reports | BAI01.06<br>BAI10.03 | BAI06-BP3<br>BAI06-01/04 |
| BAI06-WP6 | Change documentation | Internal | BAI06-BP4<br>BAI06-01/04 |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

**Page intentionally left blank**



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | BAI07 | |
|---|---|---|
| **Process Name** | **Manage Change Acceptance and Transitioning** | |
| **Process Description** | Formally accept and make operational new solutions, including implementation planning, system and data conversion, acceptance testing, communication, release preparation, promotion to production of new or changed business processes and IT services, early production support, and a post-implementation review. | |
| **Process Purpose Statement** | Implement solutions safely and in line with the agreed-on expectations and outcomes. | |
| **Outcomes (Os)** | | |
| **Number** | **Description** | |
| BAI07-01 | Acceptance testing meets stakeholder approval and takes into account all aspects of the implementation and conversion plans. | |
| BAI07-02 | Releases are ready for promotion into production with stakeholder readiness and support. | |
| BAI07-03 | Releases are promoted successfully, are stable and meet expectations. | |
| BAI07-04 | Lessons learned contribute to future releases. | |
| **Base Practices (BPs)** | | |
| **Number** | **Description** | **Supports** |
| BAI07-BP1 | **Establish an implementation plan.**<br>Establish an implementation plan that covers system and data conversion, acceptance testing criteria, communication, training, release preparation, promotion to production, early production support, a fallback/backout plan, and a post-implementation review. Obtain approval from relevant parties. | BAI07-01 |
| BAI07-BP2 | **Plan business process, system and data conversion.**<br>Prepare for business process, IT service data and infrastructure migration as part of the enterprise's development methods, including audit trails and a recovery plan should the migration fail. | |
| BAI07-BP3 | **Plan acceptance tests.**<br>Establish a test plan based on enterprisewide standards that define roles, responsibilities, and entry and exit criteria. Ensure that the plan is approved by relevant parties. | |
| BAI07-BP4 | **Establish a test environment.**<br>Define and establish a secure test environment representative of the planned business process and IT operations environment, performance and capacity, security, internal controls, operational practices, data quality and privacy requirements, and workloads. | |
| BAI07-BP5 | **Perform acceptance tests.**<br>Test changes independently in accordance with the defined test plan prior to migration to the live operational environment. | |
| BAI07-BP6 | **Promote to production and manage releases.**<br>Promote the accepted solution to the business and operations. Where appropriate, run the solution as a pilot implementation or in parallel with the old solution for a defined period and compare behaviour and results. If significant problems occur, revert back to the original environment based on the fallback/backout plan. Manage releases of solution components. | BAI07-02/03 |
| BAI07-BP7 | **Provide early production support.**<br>Provide early support to the users and IT operations for an agreed period of time to deal with issues and help stabilise the new solution. | BAI07-02/03 |
| BAI07-BP8 | **Perform a post-implementation review.**<br>Conduct a post-implementation review to confirm outcome and results, identify lessons learned, and develop an action plan. Evaluate and check the actual performance and outcomes of the new or changed service against the predicted performance and outcomes (i.e., the service expected by the user or customer). | BAI07-04 |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | BAI07 *(cont.)* | | |
|---|---|---|---|
| **Process Name** | **Manage Change Acceptance and Transitioning** | | |
| **Work Products (WPs)** | | | |
| **Inputs** | | | |
| **Number** | **Description** | | **Supports** |
| BAI01-WP20 | Quality management plan | | BAI07-BP1<br>BAI07-01 |
| BAI06-WP2 | Approved requests for change | | |
| BAI06-WP3 | Change plan and schedule | | |
| BAI01-WP21 | Requirements for independent verification of deliverables | | BAI07-BP3<br>BAI07-01 |
| BAI03-WP10 | Test plan | | |
| BAI03-WP11 | Test procedures | | |
| BAI03-WP12 | Test result logs and audit trails | | |
| BAI03-WP13 | Test result communications | | |
| APO11-WP7 | Review results of quality of service, including customer feedback | | BAI07-BP7<br>BAI07-02/03 |
| BAI05-WP11 | Success measures and results | | |
| APO11-WP8 | Results of quality reviews and audits | | BAI07-BP8<br>BAI07-04 |
| APO11-WP10 | Results of solution and service delivery quality monitoring | | |
| APO11-WP11 | Root causes of quality delivery failures | | |
| BAI05-WP11 | Success measures and results | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| BAI07-WP1 | Approved implementation plan | Internal | BAI07-BP1<br>BAI07-01 |
| BAI07-WP2 | Implementation fallback and recovery process | Internal | |
| BAI07-WP3 | Migration plan | DSS06.02 | BAI07-BP2<br>BAI07-01 |
| BAI07-WP4 | Approved acceptance test plan | BAI01.04<br>BAI01.08 | BAI07-BP3<br>BAI07-01 |
| BAI07-WP5 | Test data | Internal | BAI07-BP4<br>BAI07-01 |
| BAI07-WP6 | Test results log | Internal | BAI07-BP5<br>BAI07-01 |
| BAI07-WP7 | Evaluation of acceptance results | BAI01.06 | |
| BAI07-WP8 | Approved acceptance and release for production | BAI01.04 | |
| BAI07-WP9 | Release plan | BAI10.01 | BAI07-BP6<br>BAI07-02/03 |
| BAI07-WP10 | Release log | Internal | |
| BAI07-WP11 | Supplemental support plan | APO08.04<br>APO08.05<br>DSS02.04 | BAI07-BP7<br>BAZI07-02/03 |
| BAI07-WP12 | Post-implementation review report | BAI01.13<br>BAI01.14 | BAI07-BP8<br>BAI07-04 |
| BAI07-WP13 | Remedial action plan | BAI01.13<br>BAI01.14 | |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | BAI08 | | |
|---|---|---|---|
| **Process Name** | **Manage Knowledge** | | |
| **Process Description** | Maintain the availability of relevant, current, validated and reliable knowledge to support all process activities and to facilitate decision making. Plan for the identification, gathering, organising, maintaining, use and retirement of knowledge. | | |
| **Process Purpose Statement** | Provide the knowledge required to support all staff in their work activities and for informed decision making and enhanced productivity. | | |
| **Outcomes (Os)** | | | |
| **Number** | **Description** | | |
| BAI08-01 | Sources of information are identified and classified. | | |
| BAI08-02 | Knowledge is used and shared. | | |
| BAI08-03 | Knowledge sharing is embedded in the culture of the enterprise. | | |
| BAI08-04 | Knowledge is updated and improved to support requirements. | | |
| **Base Practices (BPs)** | | | |
| **Number** | **Description** | | **Supports** |
| BAI08-BP1 | **Nurture and facilitate a knowledge-sharing culture.**<br>Devise and implement a scheme to nurture and facilitate a knowledge-sharing culture. | | BAI08-03 |
| BAI08-BP2 | **Identify and classify sources of information.**<br>Identify, validate and classify diverse sources of internal and external information required to enable effective use and operation of business processes and IT services. | | BAI08-01 |
| BAI08-BP3 | **Organise and contextualise information into knowledge.**<br>Organise information based on classification criteria. Identify and create meaningful relationships between information elements and enable use of information. Identify owners and define and implement levels of access to knowledge resources. | | BAI08-03 |
| BAI08-BP4 | **Use and share knowledge.**<br>Propagate available knowledge resources to relevant stakeholders and communicate how these resources can be used to address different needs (e.g., problem solving, learning, strategic planning and decision making). | | BAI08-02 |
| BAI08-BP5 | **Evaluate and retire information.**<br>Measure the use and evaluate the currency and relevance of information. Retire obsolete information. | | BAI08-04 |
| **Work Products (WPs)** | | | |
| **Inputs** | | | |
| **Number** | **Description** | | **Supports** |
| Outside COBIT | Knowledge requirements and sources | | BAI08-BP2<br>BAI08-01 |
| BAI03-WP4 | Documented solution components | | BAI08-BP3<br>BAI08-03 |
| BAI05-WP15 | Knowledge transfer plans | | |
| BAI03-WP4 | Documented solution components | | BAI08-BP4<br>BAI08-02 |
| BAI05-WP10 | Operation and use plan | | |
| BAI05-WP15 | Knowledge transfer plans | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| BAI08-WP1 | Communications on value of knowledge | APO01.04 | BAI08-BP1<br>BAI08-03 |
| BAI08-WP2 | Classification of information sources | Internal | BAI08-BP2<br>BAI08-01 |
| BAI08-WP3 | Published knowledge repositories | APO07.03 | BAI08-BP3<br>BAI08-03 |
| BAI08-WP4 | Knowledge user database | Internal | BAI08-BP4<br>BAI08-02 |
| BAI08-WP5 | Knowledge awareness and training schemes | APO07.03 | |
| BAI08-WP6 | Knowledge use evaluation results | Internal | BAI08-BP5<br>BAI08-04 |
| BAI08-WP7 | Rules for knowledge retirement | Internal | |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

**Page intentionally left blank**



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | BAI09 | | |
|---|---|---|---|
| **Process Name** | **Manage Assets** | | |
| **Process Description** | Manage IT assets through their life cycle to make sure that their use delivers value at optimal cost, they remain operational (fit for purpose), they are accounted for and physically protected, and those assets that are critical to support service capability are reliable and available. Manage software licences to ensure that the optimal number are acquired, retained and deployed in relation to required business usage, and the software installed is in compliance with licence agreements. | | |
| **Process Purpose Statement** | Account for all IT assets and optimise the value provided by these assets. | | |
| **Outcomes (Os)** | | | |
| **Number** | **Description** | | |
| BAI09-01 | Licences are compliant and aligned with business need. | | |
| BAI09-02 | Assets are maintained at optimal levels. | | |
| **Base Practices (BPs)** | | | |
| **Number** | **Description** | | **Supports** |
| BAI09-BP1 | **Identify and record current assets.**<br>Maintain an up-to-date and accurate record of all IT assets required to deliver services and ensure alignment with configuration management and financial management. | | BAI09-02 |
| BAI09-BP2 | **Manage critical assets.**<br>Identify assets that are critical in providing service capability and take steps to maximise their reliability and availability to support business needs. | | BAI09-02 |
| BAI09-BP3 | **Manage the asset life cycle.**<br>Manage assets from procurement to disposal to ensure that assets are utilised as effectively and efficiently as possible and are accounted for and physically protected. | | BAI09-02 |
| BAI09-BP4 | **Optimise asset costs.**<br>Regularly review the overall asset base to identify ways to optimise costs and maintain alignment with business needs. | | BAI09-02 |
| BAI09-BP5 | **Manage licences.**<br>Manage software licences so that the optimal number of licences is maintained to support business requirements and the number of licences owned is sufficient to cover the installed software in use. | | BAI09-01 |
| **Work Products (WPs)** | | | |
| **Inputs** | | | |
| **Number** | **Description** | | **Supports** |
| BAI03-WP6 | Updates to asset inventory | | BAI09-BP1<br>BAI09-02 |
| BAI10-WP3 | Configuration repository | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| BAI09-WP1 | Asset register | APO06.01<br>BAI10.03 | BAI09-BP1<br>BAI09-02 |
| BAI09-WP2 | Results of physical inventory checks | BAI10.03<br>BAI10.04<br>DSS05.03 | |
| BAI09-WP3 | Results of fit-for-purpose reviews | APO02.02 | |
| BAI09-WP4 | Communication of planned maintenance downtime | APO08.04 | BAI09-BP2<br>BAI09-02 |
| BAI09-WP5 | Maintenance agreements | Internal | |
| BAI09-WP6 | Approved asset procurement requests | Internal | BAI09-BP3<br>BAI-02 |
| BAI09-WP7 | Asset register revisions | BAI10.03 | |
| BAI09-WP8 | Authorised asset retirements | BAI10.03 | |
| BAI09-WP9 | Results of cost optimisation reviews | APO02.02 | BAI09-BP4<br>BAI09-02 |
| BAI09-WP10 | Opportunities to reduce asset costs or increase value | APO02.02 | |
| BAI09-WP11 | Register of software licences | BAI10.02 | BAI09-BP5<br>BAI09-01 |
| BAI09-WP12 | Results of installed licence audits | MEA03.03 | |
| BAI09-WP13 | Action plan to adjust licence numbers and allocations | APO02.05 | |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

**Page intentionally left blank**



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | BAI10 | | |
|---|---|---|---|
| **Process Name** | **Manage Configuration** | | |
| **Process Description** | Define and maintain descriptions and relationships between key resources and capabilities required to deliver IT-enabled services, including collecting configuration information, establishing baselines, verifying and auditing configuration information, and updating the configuration repository. | | |
| **Process Purpose Statement** | Provide sufficient information about service assets to enable the service to be effectively managed, assess the impact of changes and deal with service incidents. | | |
| **Outcomes (Os)** | | | |
| **Number** | **Description** | | |
| BAI10-O1 | Configuration repository is accurate, complete and up to date. | | |
| **Base Practices (BPs)** | | | |
| **Number** | **Description** | | **Supports** |
| BAI10-BP1 | **Establish and maintain a configuration model.**<br>Establish and maintain a logical model of the services, assets and infrastructure and how to record configuration items (CIs) and the relationships amongst them. Include the CIs considered necessary to manage services effectively and to provide a single reliable description of the assets in a service. | | BAI10-O1 |
| BAI10-BP2 | **Establish and maintain a configuration repository and baseline.**<br>Establish and maintain a configuration management repository and create controlled configuration baselines. | | BAI10-O1 |
| BAI10-BP3 | **Maintain and control configuration items.**<br>Maintain an up-to-date repository of configuration items by populating with changes. | | BAI10-O1 |
| BAI10-BP4 | **Produce status and configuration reports.**<br>Define and produce configuration reports on status changes of configuration items. | | BAI10-O1 |
| BAI10-BP5 | **Verify and review integrity of the configuration repository.**<br>Periodically review the configuration repository and verify completeness and correctness against the desired target. | | BAI10-O1 |
| **Work Products (WPs)** | | | |
| **Inputs** | | | |
| **Number** | **Description** | | **Supports** |
| BAI07-WP9 | Release plan | | BAI10-BP1<br>BAI10-O1 |
| BAI09-WP11 | Register of software licences | | BAI10-BP2<br>BAI10-O1 |
| BAI06-WP5 | Change request status reports | | BAI10-BP3<br>BAI10-O1 |
| BAI09-WP1 | Asset register | | |
| BAI09-WP2 | Results of physical inventory checks | | |
| BAI09-WP7 | Asset register revisions | | |
| BAI09-WP8 | Authorised asset retirements | | |
| BAI09-WP2 | Results of physical inventory checks | | BAI10-BP4<br>BAI10-O1 |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| BAI10-WP1 | Scope of configuration management model | Internal | BAI10-BP1<br>BAI10-O1 |
| BAI10-WP2 | Logical configuration model | Internal | |
| BAI10-WP3 | Configuration repository | BAI09.01<br>DSS02.01 | BAI10-BP2<br>BAI10-O1 |
| BAI10-WP4 | Configuration baseline | BAI03.11 | |
| BAI10-WP5 | Updated repository with configuration items | DSS02.01 | BAI10-BP3<br>BAI10-O1 |
| BAI10-WP6 | Approved changes to baseline | BAI03.11 | |
| BAI10-WP7 | Configuration status reports | BAI03.11<br>DSS02.01 | BAI10-BP4<br>BAI10-O1 |
| BAI10-WP8 | Results of physical verification of configuration items | Internal | BAI10-BP5<br>BAI10-O1 |
| BAI10-WP9 | Licence deviations | MEA03.03 | |
| BAI10-WP10 | Results of repository completeness reviews | Internal | |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

**Page intentionally left blank**



Personal Copy of: Mr. Jorge Diab Maluf Filho

# 3.4 Deliver, Service and Support (DSS)

**01** Manage operations.

**02** Manage service requests and incidents.

**03** Manage problems.

**04** Manage continuity.

**05** Manage security services.

**06** Manage business process controls.



Personal Copy of: Mr. Jorge Diab Maluf Filho

**Page intentionally left blank**



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | DSS01 | | |
|---|---|---|---|
| **Process Name** | **Manage Operations** | | |
| **Process Description** | Co-ordinate and execute the activities and operational procedures required to deliver internal and outsourced IT services, including the execution of pre-defined standard operating procedures and the required monitoring activities. | | |
| **Process Purpose Statement** | Deliver IT operational service outcomes as planned. | | |
| **Outcomes (Os)** | | | |
| **Number** | **Description** | | |
| DSS01-O1 | Operational activities are performed as required and scheduled. | | |
| DSS01-O2 | Operations are monitored, measured, reported and remediated. | | |
| **Base Practices (BPs)** | | | |
| **Number** | **Description** | | **Supports** |
| DSS01-BP1 | **Perform operational procedures.** Maintain and perform operational procedures and operational tasks reliably and consistently. | | DSS01-01 |
| DSS01-BP2 | **Manage outsourced IT services.** Manage the operation of outsourced IT services to maintain the protection of enterprise information and reliability of service delivery. | | |
| DSS01-BP3 | **Monitor IT infrastructure.** Monitor the IT infrastructure and related events. Store sufficient chronological information in operations logs to enable the reconstruction, review and examination of the time sequences of operations and the other activities surrounding or supporting operations. | | DSS01-02 |
| DSS01-BP4 | **Manage the environment.** Maintain measures for protection against environmental factors. Install specialised equipment and devices to monitor and control the environment. | | DSS01-02 |
| DSS01-BP5 | **Manage facilities.** Manage facilities, including power and communications equipment, in line with laws and regulations, technical and business requirements, vendor specifications, and health and safety guidelines. | | DSS01-02 |
| **Work Products (WPs)** | | | |
| **Inputs** | | | |
| **Number** | **Description** | | **Supports** |
| BAI05-WP10 | Operation and use plan | | DSS01-BP1<br>DSS01-01 |
| APO09-WP4 | SLAs | | DSS01-BP2<br>DSS01-01 |
| APO09-WP5 | OLAs | | |
| BAI05-WP10 | Operation and use plan | | |
| BAI03-WP17 | Service definitions | | DSS01-BP3<br>DSS01-02 |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| DSS01-WP1 | Operational schedule | Internal | DSS01-BP1<br>DSS01-01 |
| DSS01-WP2 | Backup log | Internal | |
| DSS01-WP3 | Independent assurance plans | MEA02.06 | DSS01-BP2<br>DSS01-01 |
| DSS01-WP4 | Asset monitoring rules and event conditions | DSS02.01<br>DSS02.02 | DSS01-BP3<br>DSS01-02 |
| DSS01-WP5 | Event logs | Internal | |
| DSS01-WP6 | Incident tickets | DSS02.02 | |
| DSS01-WP7 | Environmental policies | APO01.08 | DSS01-BP4<br>DSS01-02 |
| DSS01-WP8 | Insurance policy reports | MEA03.03 | |
| DSS01-WP9 | Facilities assessment reports | MEA01.03 | DSS01-BP5<br>DSS01-02 |
| DSS01-WP10 | Health and safety awareness | Internal | |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

**Page intentionally left blank**



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | DSS02 | |
|---|---|---|
| **Process Name** | **Manage Service Requests and Incidents** | |
| **Process Description** | Provide timely and effective response to user requests and resolution of all types of incidents. Restore normal service; record and fulfil user requests; and record, investigate, diagnose, escalate and resolve incidents. | |
| **Process Purpose Statement** | Achieve increased productivity and minimise disruptions through quick resolution of user queries and incidents. | |
| **Outcomes (Os)** | | |
| **Number** | **Description** | |
| DSS02-01 | IT-related services are available for use. | |
| DSS02-02 | Incidents are resolved according to agreed-on service levels. | |
| DSS02-03 | Service requests are dealt with according to agreed-on service levels and to the satisfaction of users. | |
| **Base Practices (BPs)** | | |
| **Number** | **Description** | **Supports** |
| DSS02-BP1 | **Define incident and service request classification schemes.**<br>Define incident and service request classification schemes and models. | DSS02-01 |
| DSS02-BP2 | **Record, classify and prioritise requests and incidents.**<br>Identify, record and classify service requests and incidents, and assign a priority according to business criticality and service agreements. | DSS02-01/02 |
| DSS02-BP3 | **Verify, approve and fulfil service requests.**<br>Select the appropriate request procedures and verify that the service requests fulfil defined request criteria. Obtain approval, if required, and fulfil the requests. | DSS02-03 |
| DSS02-BP4 | **Investigate, diagnose and allocate incidents.**<br>Identify and record incident symptoms, determine possible causes, and allocate for resolution. | |
| DSS02-BP5 | **Resolve and recover from incidents.**<br>Document, apply and test the identified solutions or workarounds and perform recovery actions to restore the IT-related service. | DSS02-02 |
| DSS02-BP6 | **Close service requests and incidents.**<br>Verify satisfactory incident resolution and/or request fulfilment, and close. | DSS02-03 |
| DSS02-BP7 | **Track status and produce reports.**<br>Regularly track, analyse and report incident and request fulfilment trends to provide information for continual improvement. | |
| **Work Products (WPs)** | | |
| **Inputs** | | |
| **Number** | **Description** | **Supports** |
| APO09-WP4 | SLAs | DSS02-BP1<br>DSS02-01 |
| BAI10-WP3 | Configuration repository | |
| BAI10-WP5 | Updated repository with configuration items | |
| BAI10-WP7 | Configuration status reports | |
| DSS01-WP4 | Asset monitoring rules and event conditions | |
| DSS03-WP1 | Problem classification scheme | |
| DSS04-WP7 | Incident response actions and communications | |
| APO09-WP4 | SLAs | DSS02-BP2<br>DSS02-01/02 |
| BAI04-WP10 | Emergency escalation procedure | |
| DSS01-WP4 | Asset monitoring rules and event conditions | |
| DSS01-WP6 | Incident tickets | |
| DSS05-WP14 | Security incident tickets | |
| APO12-WP15 | Risk-related root causes | DSS02-BP3<br>DSS02-03 |
| BAI07-WP11 | Supplemental support plan | DSS02-BP4<br>DSS02-03 |
| APO12-WP13 | Risk-related incident response plans | DSS02-BP5<br>DSS02-02 |
| DSS03-WP6 | Known-error records | |
| DSS03-WP9 | Communication of knowledge learned | |
| DSS03-WP8 | Closed problem records | DSS02-BP6<br>DSS02-03 |
| APO09-WP5 | OLAs | DSS02-BP7<br>DSS02-03 |
| DSS03-WP2 | Problem status reports | |
| DSS03-WP5 | Problem resolution reports | |
| DSS03-WP10 | Problem resolution monitoring reports | |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | DSS02 *(cont.)* | | |
|---|---|---|---|
| **Process Name** | **Manage Service Requests and Incidents** | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| DSS02-WP1 | Incident and service request classification schemes and models | Internal | DSS02-BP1<br>DSS02-01 |
| DSS02-WP2 | Rules for incident escalation | Internal | |
| DSS02-WP3 | Criteria for problem registration | DSS03.01 | |
| DSS02-WP4 | Incident and service request log | Internal | DSS02-BP2<br>DSS02-01/02 |
| DSS02-WP5 | Classified and prioritised incidents and service requests | APO08.03<br>APO09.04<br>APO13.03 | |
| DSS02-WP6 | Approved service requests | BAI06.01 | DSS02-BP3<br>DSS02-03 |
| DSS02-WP7 | Fulfilled service requests | Internal | |
| DSS02-WP8 | Incident symptoms | Internal | DSS02-BP4<br>DSS02-03 |
| DSS02-WP9 | Problem log | DSS03.01 | |
| DSS02-WP10 | Incident resolutions | DSS03.04 | DSS02-BP5<br>DSS02-02 |
| DSS02-WP11 | Closed service requests and incidents | APO08.03<br>APO09.04<br>DSS03.04 | DSS02-BP6<br>DSS02-03 |
| DSS02-WP12 | User confirmation of satisfactory fulfilment or resolution | APO08.03 | |
| DSS02-WP13 | Incident status and trends report | APO08.03<br>APO09.04<br>APO11.04<br>APO12.01<br>MEA01.03 | DSS02-BP7<br>DSS02-03 |
| DSS02-WP14 | Request fulfilment status and trends report | APO08.03<br>APO09.04<br>APO11.04<br>MEA01.03 | |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | DSS03 | | |
|---|---|---|---|
| **Process Name** | **Manage Problems** | | |
| **Process Description** | Identify and classify problems and their root causes and provide timely resolution to prevent recurring incidents. Provide recommendations for improvements | | |
| **Process Purpose Statement** | Increase availability, improve service levels, reduce costs, and improve customer convenience and satisfaction by reducing the number of operational problems. | | |
| **Outcomes (Os)** | | | |
| **Number** | **Description** | | |
| DSS03-01 | IT-related problems are resolved so that they do not reoccur. | | |
| **Base Practices (BPs)** | | | |
| **Number** | **Description** | | **Supports** |
| DSS03-BP1 | **Identify and classify problems.**<br>Define and implement criteria and procedures to report problems identified, including problem classification, categorisation and prioritisation. | | DSS03-01 |
| DSS03-BP2 | **Investigate and diagnose problems.**<br>Investigate and diagnose problems using relevant subject management experts to assess and analyse root causes. | | DSS03-01 |
| DSS03-BP3 | **Raise known errors.**<br>As soon as the root causes of problems are identified, create known-error records and an appropriate workaround, and identify potential solutions. | | |
| DSS03-BP4 | **Resolve and close problems.**<br>Identify and initiate sustainable solutions addressing the root cause, raising change requests via the established change management process if required to resolve errors. Ensure that the personnel affected are aware of the actions taken and the plans developed to prevent future incidents from occurring. | | DSS03-01 |
| DSS03-BP5 | **Perform proactive problem management.**<br>Collect and analyse operation data (especially incident and change records) to identify emerging trends that may indicate problems. Log problem records to enable assessment. | | |
| **Work Products (WPs)** | | | |
| **Inputs** | | | |
| **Number** | **Description** | | **Supports** |
| AP012-WP15 | Risk-related root causes | | DSS03-BP1<br>DSS03-01 |
| DSS02-WP3 | Criteria for problem registration | | |
| DSS02-WP9 | Problem log | | |
| AP012-WP15 | Risk-related root causes | | DSS03-BP2<br>DSS03-01 |
| DSS02-WP10 | Incident resolutions | | DSS03-BP4<br>DSS03-01 |
| DSS02-WP11 | Closed service requests and incidents | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| DSS03-WP1 | Problem classification scheme | DSS02.01 | DSS03-BP1<br>DSS03-01 |
| DSS03-WP2 | Problem status reports | DSS02.07 | |
| DSS03-WP3 | Problem register | Internal | |
| DSS03-WP4 | Root causes of problems | Internal | DSS03-BP2<br>DSS03-01 |
| DSS03-WP5 | Problem resolution reports | DSS02.07 | |
| DSS03-WP6 | Known-error records | DSS02.05 | DSS03-BP3<br>DSS03-01 |
| DSS03-WP7 | Proposed solutions to known errors | BAI06.01 | |
| DSS03-WP8 | Closed problem records | DSS02.06 | DSS03-BP4<br>DSS03-01 |
| DSS03-WP9 | Communication of knowledge learned | AP008.04<br>DSS02.05 | |
| DSS03-WP10 | Problem resolution monitoring reports | DSS02.07 | DSS03-BP5<br>DSS03-01 |
| DSS03-WP11 | Identified sustainable solutions | BAI06.01 | |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

**Page intentionally left blank**



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | DSS04 | |
|---|---|---|
| **Process Name** | **Manage Continuity** | |
| **Process Description** | Establish and maintain a plan to enable the business and IT to respond to incidents and disruptions in order to continue operation of critical business processes and required IT services and maintain availability of information at a level acceptable to the enterprise. | |
| **Process Purpose Statement** | Continue critical business operations and maintain availability of information at a level acceptable to the enterprise in the event of a significant disruption. | |
| **Outcomes (Os)** | | |
| **Number** | **Description** | |
| DSS04-01 | Business-critical information is available to the business in line with minimum required service levels. | |
| DSS04-02 | Sufficient resilience is in place for critical services. | |
| DSS04-03 | Service continuity tests have verified the effectiveness of the plan. | |
| DSS04-04 | An up-to-date continuity plan reflects current business requirements. | |
| DSS04-05 | Internal and external parties have been trained in the continuity plan. | |
| **Base Practices (BPs)** | | |
| **Number** | **Description** | **Supports** |
| DSS04-BP1 | **Define the business continuity policy, objectives and scope.**<br>Define business continuity policy and scope aligned with enterprise and stakeholder objectives. | DSS04-01/04 |
| DSS04-BP2 | **Maintain a continuity strategy.**<br>Evaluate business continuity management options and choose a cost-effective and viable continuity strategy that will ensure enterprise recovery and continuity in the face of a disaster or other major incident or disruption. | DSS04-04 |
| DSS04-BP3 | **Develop and implement a business continuity response.**<br>Develop a business continuity plan (BCP) based on the strategy that documents the procedures and information in readiness for use in an incident to enable the enterprise to continue its critical activities. | DSS04-02/03 |
| DSS04-BP4 | **Exercise, test and review the BCP.**<br>Test the continuity arrangements on a regular basis to exercise the recovery plans against predetermined outcomes and to allow innovative solutions to be developed and help to verify over time that the plan will work as anticipated. | DSS04-03/04 |
| DSS04-BP5 | **Review, maintain and improve the continuity plan.**<br>Conduct a management review of the continuity capability at regular intervals to ensure its continued suitability, adequacy and effectiveness. Manage changes to the plan in accordance with the change control process to ensure the continuity plan is kept up to date and continually reflects actual business requirements. | DSS04-04 |
| DSS04-BP6 | **Conduct continuity plan training.**<br>Provide all concerned internal and external parties with regular training sessions regarding the procedures and their roles and responsibilities in case of disruption. | DSS04-05 |
| DSS04-BP7 | **Manage backup arrangements.**<br>Maintain availability of business-critical information. | DSS04-01 |
| DSS04-BP8 | **Conduct post-resumption review.**<br>Assess the adequacy of the BCP following the successful resumption of business processes and services after a disruption. | DSS04-04 |
| **Work Products (WPs)** | | |
| **Inputs** | | |
| **Number** | **Description** | **Supports** |
| APO09-WP4 | SLAs | DSS04-BP1<br>DSS04-01/04 |
| APO12-WP14 | Risk impact communication | DSS04-BP2<br>DSS04-04 |
| APO12-WP15 | Risk-related root causes | |
| APO09-WP5 | OLAs | DSS04-BP3<br>DSS04-02/03 |
| HR | List of personnel requiring training | DSS04-BP6<br>DSS04-05 |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | DSS04 *(cont.)* | | |
|---|---|---|---|
| **Process Name** | **Manage Continuity** | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| DSS04-WP1 | Policy and objectives for business continuity | APO01.04 | DSS04-BP1<br>DSS04-01/04 |
| DSS04-WP2 | Disruptive incident scenarios | Internal | |
| DSS04-WP3 | Assessments of current continuity capabilities and gaps | Internal | |
| DSS04-WP4 | Business impact analyses | APO12.02 | DSS04-BP2<br>DSS04-04 |
| DSS04-WP5 | Continuity requirements | Internal | |
| DSS04-WP6 | Approved strategic options | APO02.05 | |
| DSS04-WP7 | Incident response actions and communications | DSS02.01 | DSS04-BP3<br>DSS04-02/03 |
| DSS04-WP8 | BCP | Internal | |
| DSS04-WP9 | Test objectives | Internal | DSS04-BP4<br>DSS04-03/04 |
| DSS04-WP10 | Test exercises | Internal | |
| DSS04-WP11 | Test results and recommendations | Internal | |
| DSS04-WP12 | Results of reviews of plans | Internal | DSS04-BP5<br>DSS04-04 |
| DSS04-WP13 | Recommended changes to plans | Internal | |
| DSS04-WP14 | Training requirements | APO07.03 | DSS04-BP6<br>DSS04-05 |
| DSS04-WP15 | Monitoring results of skills and competencies | APO07.03 | |
| DSS04-WP16 | Test results of backup data | Internal | DSS04-BP7<br>DSS04-01 |
| DSS04-WP17 | Post-resumption review report | Internal | DSS04-BP8<br>DSS04-04 |
| DSS04-WP18 | Approved changes to the plans | BAI06.01 | |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | DSS05 | |
|---|---|---|
| **Process Name** | **Manage Security Services** | |
| **Process Description** | Protect enterprise information to maintain the level of information security risk acceptable to the enterprise in accordance with the security policy. Establish and maintain information security roles and access privileges and perform security monitoring. | |
| **Process Purpose Statement** | Minimise the business impact of operational information security vulnerabilities and incidents. | |
| **Outcomes (Os)** | | |
| **Number** | **Description** | |
| DSS05-01 | Network and communications security meet business needs. | |
| DSS05-02 | Information processed on, stored on and transmitted by endpoint devices is protected. | |
| DSS05-03 | All users are uniquely identifiable and have access rights in accordance with their business role. | |
| DSS05-04 | Physical measures have been implemented to protect information from unauthorised access, damage and interference when being processed, stored or transmitted. | |
| DSS05-05 | Electronic information is properly secured when stored, transmitted or destroyed. | |
| **Base Practices (BPs)** | | |
| **Number** | **Description** | **Supports** |
| DSS05-BP1 | **Protect against malware.**<br>Implement and maintain preventive, detective and corrective measures in place (especially up-to-date security patches and virus control) across the enterprise to protect information systems and technology from malware (e.g., viruses, worms, spyware, spam). | DSS05-01/02 |
| DSS05-BP2 | **Manage network and connectivity security.**<br>Use security measures and related management procedures to protect information over all methods of connectivity. | DSS05-01 |
| DSS05-BP3 | **Manage endpoint security.**<br>Ensure that endpoints (e.g., laptop, desktop, server and other mobile and network devices or software) are secured at a level that is equal to or greater than the defined security requirements of the information processed, stored or transmitted. | DSS05-02 |
| DSS05-BP4 | **Manage user identity and logical access.**<br>Ensure that all users have information access rights in accordance with their business requirements and co-ordinate with business units that manage their own access rights within business processes. | DSS05-03 |
| DSS05-BP5 | **Manage physical access to IT assets.**<br>Define and implement procedures to grant, limit and revoke access to premises, buildings and areas according to business needs, including emergencies. Access to premises, buildings and areas should be justified, authorised, logged and monitored. This should apply to all persons entering the premises, including staff, temporary staff, clients, vendors, visitors or any other third party. | DSS05-04 |
| DSS05-BP6 | **Manage sensitive documents and output devices.**<br>Establish appropriate physical safeguards, accounting practices and inventory management over sensitive IT assets, such as special forms, negotiable instruments, special-purpose printers or security tokens. | DSS05-05 |
| DSS05-BP7 | **Monitor the infrastructure for security-related events**<br>Using intrusion detection tools, monitor the infrastructure for unauthorised access and ensure that any events are integrated with general event monitoring and incident management. | DSS05-01 |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | DSS05 *(cont.)* | | |
|---|---|---|---|
| **Process Name** | **Manage Security Services** | | |
| **Work Products (WPs)** | | | |
| **Inputs** | | | |
| **Number** | **Description** | | **Supports** |
| APO01-WP10 | Data classification guidelines | | DSS05-BP2<br>DSS05-01 |
| APO09-WP4 | SLAs | | |
| APO03-WP6 | Information architecture model | | DSS05-BP3<br>DSS05-02 |
| APO09-WP4 | SLAs | | |
| APO09-WP5 | OLAs | | |
| BAI09-WP2 | Results of physical inventory checks | | |
| DSS06-WP11 | Reports of violations | | |
| APO01-WP4 | Definition of IT-related roles and responsibilities | | DSS05-BP4<br>DSS05-03 |
| APO03-WP6 | Information architecture model | | |
| APO03-WP6 | Information architecture model | | DSS05-BP6<br>DSS05-05 |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| DSS05-WP1 | Malicious software prevention policy | APO01.04 | DSS05-BP1<br>DSS05-01/02 |
| DSS05-WP2 | Evaluations of potential threats | APO12.02<br>APO12.03 | |
| DSS05-WP3 | Connectivity security policy | APO01.04 | DSS05-BP2<br>DSS05-01 |
| DSS05-WP4 | Results of penetration tests | MEA02.08 | |
| DSS05-WP5 | Security policies for endpoint devices | APO01.04 | DSS05-BP3<br>DSS05-02 |
| DSS05-WP6 | Approved user access rights | Internal | DSS05-BP4<br>DSS05-03 |
| DSS05-WP7 | Results of reviews of user accounts and privileges | Internal | |
| DSS05-WP8 | Approved access requests | Internal | DSS05-BP5<br>DSS05-04 |
| DSS05-WP9 | Access logs | DSS06.03 | |
| DSS05-WP10 | Inventory of sensitive documents and devices | Internal | DSS05-BP6<br>DSS05-05 |
| DSS05-WP11 | Access privileges | Internal | |
| DSS05-WP12 | Security event logs | Internal | DSS05-BP7<br>DSS05-01 |
| DSS05-WP13 | Security incident characteristics | Internal | |
| DSS05-WP14 | Security incident tickets | DSS02.02 | |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | DSS06 | |
|---|---|---|
| **Process Name** | **Manage Business Process Controls** | |
| **Process Description** | Define and maintain appropriate business process controls to ensure that information related to and processed by in-house or outsourced business processes satisfies all relevant information control requirements. Identify the relevant information control requirements and manage and operate adequate controls to ensure that information and information processing satisfy these requirements. | |
| **Process Purpose Statement** | Maintain information integrity and the security of information assets handled within business processes in the enterprise or outsourced. | |
| **Outcomes (Os)** | | |
| **Number** | **Description** | |
| DSS06-01 | Coverage and effectiveness of key controls to meet business requirements for processing information are complete. | |
| DSS06-02 | The inventory of roles, responsibilities and access rights is aligned with authorised business needs. | |
| DSS06-03 | Business transactions are retained completely and as required in logs. | |
| **Base Practices (BPs)** | | |
| **Number** | **Description** | **Supports** |
| DSS06-BP1 | **Align control activities embedded in business processes with enterprise objectives.** Continually assess and monitor the execution of the business process activities and related controls, based on enterprise risk, to ensure that the processing controls are aligned with business needs. | DSS06-01 |
| DSS06-BP2 | **Control the processing of information.** Operate the execution of the business process activities and related controls, based on enterprise risk, to ensure that information processing is valid, complete, accurate, timely, and secure (i.e., reflects legitimate and authorised business use). | |
| DSS06-BP3 | **Manage roles, responsibilities, access privileges and levels of authority.** Manage the business roles, responsibilities, levels of authority and segregation of duties needed to support the business process objectives. Authorise access to any information assets related to business information processes, including those under the custody of the business, IT and third parties. This ensures that the business knows where the data are and who is handling data on its behalf. | DSS06-02 |
| DSS06-BP4 | **Manage errors and exceptions.** Manage business process exceptions and errors and facilitate their correction. Include escalation of business process errors and exceptions and the execution of defined corrective actions. This provides assurance of the accuracy and integrity of the business information process. | DSS06-01/03 |
| DSS06-BP5 | **Ensure traceability of Information events and accountabilities.** Ensure that business information can be traced to the originating business event and accountable parties. This enables traceability of the information through its life cycle and related processes. This provides assurance that information that drives the business is reliable and has been processed in accordance with defined objectives. | DSS06-03 |
| DSS06-BP6 | **Secure information assets.** Secure information assets accessible by the business through approved methods, including information in electronic form (such as methods that create new assets in any form, portable media devices, user applications and storage devices), information in physical form (such as source documents or output reports) and information during transit. This benefits the business by providing end-to-end safeguarding of information. | DSS06-02 |
| **Work Products (WPs)** | | |
| **Inputs** | | |
| **Number** | **Description** | **Supports** |
| APO01-WP10 | Data classification guidelines | DSS06-BP1<br>DSS06-01 |
| APO01-WP12 | Data integrity procedures | |
| BAI05-WP10 | Operation and use plan | DSS06-BP2<br>DSS06-01 |
| BAI07-WP3 | Migration plan | |
| EDM04-WP5 | Assigned responsibilities for resource management | DSS06-BP3<br>DSS06-02 |
| APO11-WP1 | Quality management system (QMS) roles, responsibilities and decision rights | |
| APO13-WP2 | ISMS scope statement | |
| DSS05-WP9 | Access logs | |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | DSS06 *(cont.)* | | |
|---|---|---|---|
| **Process Name** | **Manage Business Process Controls** | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| DSS06-WP1 | Results of processing effectiveness reviews | MEA02.04 | DSS06-BP1<br>DSS06-01 |
| DSS06-WP2 | Root cause analyses and recommendations | BAI06.01<br>MEA02.04<br>MEA02.07<br>MEA02.08 | |
| DSS06-WP3 | Processing control reports | Internal | DSS06-BP2<br>DSS06-01 |
| DSS06-WP4 | Allocated roles and responsibilities | APO01.02 | DSS06-BP3<br>DSS06-02 |
| DSS06-WP5 | Allocated levels of authority | APO01.02 | |
| DSS06-WP6 | Allocated access rights | APO07.04 | |
| DSS06-WP7 | Evidence of error correction and remediation | MEA02.04 | DSS06-BP4<br>DSS06-01/03 |
| DSS06-WP8 | Error reports and root cause analysis | Internal | |
| DSS06-WP9 | Retention requirements | Internal | DSS06-BP5<br>DSS06-03 |
| DSS06-WP10 | Record of transactions | Internal | |
| DSS06-WP11 | Reports of violations | DSS05.03 | DSS06-BP6<br>DSS06-02 |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

# 3.5 Monitor, Evaluate and Assess (MEA)

**01** Monitor, evaluate and assess performance and conformance.

**02** Monitor, evaluate and assess the system of internal control.

**03** Monitor, evaluate and assess compliance with external requirements.



Personal Copy of: Mr. Jorge Diab Maluf Filho

**Page intentionally left blank**



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | MEA01 | |
|---|---|---|
| **Process Name** | **Monitor, Evaluate and Assess Performance and Conformance** | |
| **Process Description** | Collect, validate and evaluate business, IT and process goals and metrics. Monitor that processes are performing against agreed-on performance and conformance goals and metrics and provide reporting that is systematic and timely. | |
| **Process Purpose Statement** | Provide transparency of performance and conformance and drive achievement of goals. | |
| **Outcomes (Os)** | | |
| **Number** | **Description** | |
| MEA01-O1 | Goals and metrics are approved by the stakeholders. | |
| MEA01-O2 | Processes are measured against agreed-on goals and metrics. | |
| MEA01-O3 | The enterprise monitoring, assessing and informing approach is effective and operational. | |
| MEA01-O4 | Goals and metrics are integrated within enterprise monitoring systems. | |
| MEA01-O5 | Process reporting on performance and conformance is useful and timely. | |
| **Base Practices (BPs)** | | |
| **Number** | **Description** | **Supports** |
| MEA01-BP1 | **Establish a monitoring approach.**<br>Engage with stakeholders to establish and maintain a monitoring approach to define the objectives, scope and method for measuring business solution and service delivery and contribution to enterprise objectives. Integrate this approach with the corporate performance management system. | MEA01-O1/O4 |
| MEA01-BP2 | **Set performance and conformance targets.**<br>Work with the stakeholders to define, periodically review, update and approve performance and conformance targets within the performance measurement system. | MEA01-O1/O2 |
| MEA01-BP3 | **Collect and process performance and conformance data.**<br>Collect and process timely and accurate data aligned with enterprise approaches. | MEA01-O3 |
| MEA01-BP4 | **Analyse and report performance.**<br>Periodically review and report performance against targets, using a method that provides a succinct all-around view of IT performance and fits within the enterprise monitoring system. | MEA01-O5 |
| MEA01-BP5 | **Ensure the implementation of corrective actions.**<br>Assist stakeholders in identifying, initiating and tracking corrective actions to address anomalies | MEA01-O4 |
| **Work Products (WPs)** | | |
| **Inputs** | | |
| **Number** | **Description** | **Supports** |
| EDM05-WP1 | Evaluation of enterprise reporting requirements | MEA01-BP1<br>MEA01-O1/O4 |
| EDM05-WP2 | Reporting and communications principles | |
| EDM05-WP3 | Rules for validating and approving mandatory reports | |
| EDM05-WP5 | Assessment of reporting effectiveness | |
| APO01-WP15 | Performance goals and metrics for process improvement tracking | MEA01-BP2<br>MEA01-O1/O2 |
| APO01-WP13 | Process capability assessments | MEA01-BP3<br>MEA01-O3 |
| APO05-WP9 | Investment portfolio performance reports | |
| APO09-WP6 | Service level performance reports | |
| APO10-WP13 | Supplier compliance monitoring review results | |
| BAI01-WP13 | Results of programme performance reviews | |
| BAI04-WP7 | Availability, performance and capacity reports | |
| BAI05-WP11 | Success measures and results | |
| DSS01-WP9 | Facilities assessment reports | |
| DSS02-WP14 | Request fulfilment status and trends report | |
| DSS02-WP13 | Incident status and trends report | |
| EDM05-WP4 | Escalation guidelines | MEA01-BP5<br>MEA01-O4 |
| APO01-WP16 | Non-compliance remedial actions | |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | MEA01 *(cont.)* | | |
|---|---|---|---|
| **Process Name** | **Monitor, Evaluate and Assess Performance and Conformance** | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| MEA01-WP1 | Monitoring requirements | Internal | MEA01-BP1<br>MEA01-01/04 |
| MEA01-WP2 | Approved monitoring goals and metrics | Internal | |
| MEA01-WP3 | Monitoring targets | All APO<br>All BAI<br>All DSS<br>All MEA | MEA01-BP2<br>MEA01-01/02 |
| MEA01-WP4 | Processed monitoring data | Internal | MEA01-BP3<br>MEA01-03 |
| MEA01-WP5 | Performance reports | EDM01.03<br>All APO<br>All BAI<br>All DSS<br>All MEA | MEA01-BP4<br>MEA01-05 |
| MEA01-WP6 | Remedial actions and assignments | All APO<br>All BAI<br>All DSS<br>All MEA | MEA01-BP5<br>MEA01-04 |
| MEA01-WP7 | Status and results of actions | EDM01.03 | |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | MEA02 | |
|---|---|---|
| **Process Name** | **Monitor, Evaluate and Assess the System of Internal Control** | |
| **Process Description** | Continuously monitor and evaluate the control environment, including self-assessments and independent assurance reviews. Enable management to identify control deficiencies and inefficiencies and to initiate improvement actions. Plan, organise and maintain standards for internal control assessment and assurance activities. | |
| **Process Purpose Statement** | Obtain transparency for key stakeholders on the adequacy of the system of internal controls and thus provide trust in operations, confidence in the achievement of enterprise objectives and an adequate understanding of residual risk. | |
| **Outcomes (Os)** | | |
| **Number** | **Description** | |
| MEA02-O1 | Processes, resources and information meet enterprise internal control system requirements. | |
| MEA02-O2 | All assurance initiatives are planned and executed effectively. | |
| MEA02-O3 | Independent assurance that the system of internal control is operational and effective is provided. | |
| MEA02-O4 | Internal control is established and deficiencies are identified and reported. | |
| **Base Practices (BPs)** | | |
| **Number** | **Description** | **Supports** |
| MEA02-BP1 | **Monitor internal controls.**<br>Continuously monitor, benchmark and improve the IT control environment and control framework to meet organisational objectives. | MEA02-01 |
| MEA02-BP2 | **Review business process controls effectiveness.**<br>Review the operation of controls, including a review of monitoring and test evidence, to ensure that controls within business processes operate effectively. Include activities to maintain evidence of the effective operation of controls through mechanisms such as periodic testing of controls, continuous controls monitoring, independent assessments, command and control centres, and network operations centres. This provides the business with the assurance of control effectiveness to meet requirements related to business, regulatory and social responsibilities. | MEA02-03 |
| MEA02-BP3 | **Perform control self-assessments.**<br>Encourage management and process owners to take positive ownership of control improvement through a continuing programme of self-assessment to evaluate the completeness and effectiveness of management's control over processes, policies and contracts. | MEA02-02/03 |
| MEA02-BP4 | **Identify and report control deficiencies.**<br>Identify control deficiencies and analyse and identify their underlying root causes. Escalate control deficiencies and report to stakeholders. | MEA02-04 |
| MEA02-BP5 | **Ensure that assurance providers are independent and qualified.**<br>Ensure that the entities performing assurance are independent from the function, groups or organisations in scope. The entities performing assurance should demonstrate an appropriate attitude and appearance, competence in the skills and knowledge necessary to perform assurance, and adherence to codes of ethics and professional standards. | MEA02-03 |
| MEA02-BP6 | **Plan assurance initiatives.**<br>Plan assurance initiatives based on enterprise objectives and strategic priorities, inherent risk, resource constraints, and sufficient knowledge of the enterprise. | MEA02-02 |
| MEA02-BP7 | **Scope assurance initiatives.**<br>Define and agree with management on the scope of the assurance initiative, based on the assurance objectives. | |
| MEA02-BP8 | **Execute assurance initiatives.**<br>Execute the planned assurance initiative. Report on identified findings. Provide positive assurance opinions, where appropriate, and recommendations for improvement relating to identified operational performance, external compliance and internal control system residual risk. | MEA02-02/04 |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | MEA02 *(cont.)* | | |
|---|---|---|---|
| **Process Name** | **Monitor, Evaluate and Assess the System of Internal Control** | | |
| **Work Products (WPs)** | | | |
| **Inputs** | | | |
| **Number** | **Description** | | **Supports** |
| APO12-WP10 | Results of third-party risk assessments | | MEA02-BP1<br>MEA02-01 |
| APO13-WP5 | ISMS audit reports | | |
| Outside COBIT | Industry standards and good practices | | |
| BAI05-WP12 | Compliance audit results | | MEA02-BP2<br>MEA02-03 |
| BAI05-WP17 | Reviews of operational use | | |
| APO11-WP11 | Root causes of quality delivery failures | | MEA02-BP4<br>MEA02-04 |
| APO12-WP15 | Risk-related root causes | | |
| DSS06-WP1 | Results of processing effectiveness reviews | | |
| DSS06-WP2 | Root cause analyses and recommendations | | |
| DSS06-WP7 | Evidence of error correction and remediation | | |
| BAI01-WP12 | Programme audit plans | | MEA02-BP6<br>MEA02-02 |
| DSS01-WP3 | Independent assurance plans | | |
| APO11-WP11 | Root causes of quality delivery failures | | MEA02-BP7<br>MEA02-02 |
| APO12-WP15 | Risk-related root causes | | |
| DSS06-WP2 | Root cause analyses and recommendations | | |
| MEA03-WP8 | Reports of non-compliance issues and root causes | | |
| APO11-WP11 | Root causes of quality delivery failures | | MEA02-BP8<br>MES02-02/04 |
| APO12-WP9 | Risk analysis and risk profile reports for stakeholders | | |
| APO12-WP15 | Risk-related root causes | | |
| DSS05-WP4 | Results of penetration tests | | |
| DSS06-WP2 | Root cause analyses and recommendations | | |
| MEA03-WP5 | Identified compliance gaps | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| MEA02-WP1 | Results of internal control monitoring and reviews | EDM01.03<br>All APO<br>All BAI<br>All DSS<br>All MEA | MEA02-BP1<br>MEA02-01 |
| MEA02-WP2 | Results of benchmarking and other evaluations | EDM01.03<br>All APO<br>All BAI<br>All DSS<br>All MEA | |
| MEA02-WP3 | Evidence of control effectiveness | Internal | MEA02-BP2<br>MEA02-03 |
| MEA02-WP4 | Self-assessment plans and criteria | All APO<br>All BAI<br>All DSS<br>All MEA | MEA02-BP3<br>MEA02-02/03 |
| MEA02-WP5 | Results of self-assessments | Internal | |
| MEA02-WP6 | Results of reviews of self-assessments | EDM01.03<br>All APO<br>All BAI<br>All DSS<br>All MEA | |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | MEA02 *(cont.)* | | |
|---|---|---|---|
| **Process Name** | **Monitor, Evaluate and Assess the System of Internal Control** | | |
| **Outputs *(cont.)*** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| MEA02-WP7 | Control deficiencies | All APO<br>All BAI<br>All DSS<br>All MEA | MEA02-BP4<br>MEA02-04 |
| MEA02-WP8 | Remedial actions | All APO<br>All BAI<br>All DSS<br>All MEA | |
| MEA02-WP9 | Results of assurance provider evaluations | Internal | MEA02-BP5<br>MEA02-03 |
| MEA02-WP10 | High-level assessments | Internal | MEA02-BP6<br>MEA02-02 |
| MEA02-WP11 | Assurance plans | EDM01.03<br>All APO<br>All BAI<br>All DSS<br>All MEA | |
| MEA02-WP12 | Assessment criteria | Internal | |
| MEA02-WP13 | Assurance review scope | Internal | MEA02-BP7<br>MEA02-02 |
| MEA02-WP14 | Engagement plan | Internal | |
| MEA02-WP15 | Assurance review practices | Internal | |
| MEA02-WP16 | Refined scope | All APO<br>All BAI<br>All DSS<br>All MEA | MEA02-BP8<br>MEA02-02/04 |
| MEA02-WP17 | Assurance review results | EDM05.01<br>EDM05.03<br>All APO<br>All BAI<br>All DSS<br>All MEA | |
| MEA02-WP18 | Assurance review report | EDM05.03<br>All APO<br>All BAI<br>All DSS<br>All MEA | |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

**Page intentionally left blank**



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | MEA03 | |
|---|---|---|
| **Process Name** | **Monitor, Evaluate and Assess Compliance With External Requirements** | |
| **Process Description** | Evaluate that IT processes and IT-supported business processes are compliant with laws, regulations and contractual requirements. Obtain assurance that the requirements have been identified and complied with, and integrate IT compliance with overall enterprise compliance. | |
| **Process Purpose Statement** | Ensure that the enterprise is compliant with all applicable external requirements. | |
| **Outcomes (Os)** | | |
| **Number** | **Description** | |
| MEA03-O1 | All external compliance requirements are identified. | |
| MEA03-O2 | External compliance requirements are adequately addressed. | |
| **Base Practices (BPs)** | | |
| **Number** | **Description** | **Supports** |
| MEA03-BP1 | **Identify external compliance requirements.**<br>On a continuous basis, identify and monitor for changes in local and international laws, regulations and other external requirements that must be complied with from an IT perspective. | MEA03-O1 |
| MEA03-BP2 | **Optimise response to external requirements.**<br>Review and adjust policies, principles, standards, procedures and methodologies to ensure that legal, regulatory and contractual requirements are addressed and communicated. Consider industry standards, codes of good practice, and best practice guidance for adoption and adaptation. | MEA03-O2 |
| MEA03-BP3 | **Confirm external compliance.**<br>Confirm compliance of policies, principles, standards, procedures and methodologies with legal, regulatory and contractual requirements. | MEA03-O1/O2 |
| MEA03-BP4 | **Obtain assurance of external compliance.**<br>Obtain and report assurance of compliance and adherence with policies, principles, standards, procedures and methodologies. Confirm that corrective actions to address compliance gaps are closed in a timely manner. | MEA03-O1/O2 |
| **Work Products (WPs)** | | |
| **Inputs** | | |
| **Number** | **Description** | **Supports** |
| Outside COBIT | Legal and regulatory compliance requirements | MEA03-BP1<br>MEA03-O1 |
| BAI05-WP12 | Compliance audit results | MEA03-BP3<br>MEA03-O1/O2 |
| BAI09-WP12 | Results of installed licence audits | |
| BAI10-WP9 | Licence deviations | |
| DSS01-WP8 | Insurance policy reports | |
| EDM05-WP3 | Rules for validating and approving mandatory reports | MEA03-BP4<br>MEA03-O1/O2 |
| EDM05-WP5 | Assessment of reporting effectiveness | |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Process ID | MEA03 *(cont.)* | | |
|---|---|---|---|
| **Process Name** | **Monitor, Evaluate and Assess Compliance With External Requirements** | | |
| **Outputs** | | | |
| **Number** | **Description** | **Input to** | **Supports** |
| MEA03-WP1 | Compliance requirements register | Internal | MEA03-BP1<br>MEA03-01 |
| MEA03-WP2 | Log of required compliance actions | Internal | |
| MEA03-WP3 | Updated policies, principles, procedures and standards | APO01.07<br>APO01.08 | MEA03-BP2<br>MEA03-02 |
| MEA03-WP4 | Communications of changed compliance requirements | EDM01.01<br>All APO<br>All BAI<br>All DSS<br>All MEA | |
| MEA03-WP5 | Identified compliance gaps | MEA02.08 | MEA03-BP3<br>MEA03-01/02 |
| MEA03-WP6 | Compliance confirmations | EDM01.03 | |
| MEA03-WP7 | Compliance assurance reports | EDM01.03 | MEA03-BP4<br>MEA03-01/02 |
| MEA03-WP8 | Reports of non-compliance issues and root causes | EDM01.03<br>MEA02.07 | |

Note: Refer to **figure 7** for a complete listing of outputs common to all processes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

# 4.0 Process Capability Indicators

This section presents the process capability indicators related to the process attributes (PAs) associated with capability levels 1 to 5 defined in the capability dimension of the process assessment model.

Process capability indicators are the means of achieving the capabilities addressed by the process attributes. Evidence of process capability indicators supports the judgement of the degree of achievement of the process attribute.

The capability dimension of the process assessment model consists of six capability levels matching the capability levels defined in section 2.3 of this process assessment model. This section describes the process capability indicators for the nine process attributes included in the capability dimension for levels 1 to 5.

Level 0 does not include any type of indicators. Level 0 reflects a non-implemented process or a process that fails, even partially, to achieve its outcomes.

## 4.1 Level 1—Performed Process

**PA 1.1 Process Performance**—A measure of the extent to which the process purpose is achieved. Full achievement of this attribute results in the process achieving its defined outcomes, as shown in **figure 8**.

| Figure 8—PA 1.1 Process Performance | | |
|---|---|---|
| **Result of Full Achievement of the Attribute** | **Base Practices (BPs)** | **Work Products (WPs)** |
| The process achieves its defined outcomes. | **BP 1.1.1 Achieve the process outcomes.** There is evidence that the intent of the base practice is being performed. | Work products are produced that provide evidence of process outcomes, as outlined in section 3.0. |

## 4.2 Level 2—Managed Process

Process Performance is now implemented in a managed fashion (planned, monitored and adjusted) and its work products are appropriately established, controlled and maintained.

**PA 2.1 Performance Management**—A measure of the extent to which the performance of the process is managed. As a result of full achievement of this attribute:
a. Objectives for the performance of the process are identified.
b. Performance of the process is planned and monitored.
c. Performance of the process is adjusted to meet plans.
d. Responsibilities and authorities for performing the process are defined, assigned and communicated.
e. Resources and information necessary for performing the process are identified, made available, allocated and used.
f. Interfaces between the involved parties are managed to ensure effective communication and clear assignment of responsibility.



Personal Copy of: Mr. Jorge Diab Maluf Filho

The GPs and GWPs that provide evidence of achievement of the attribute are shown in **figure 9**.

**Figure 9—PA 2.1 Performance Management**

| Result of Full Achievement of the Attribute | Generic Practices (GPs) | Generic Work Products (GWPs) |
|---|---|---|
| a. Objectives for the performance of the process are identified. | **GP 2.1.1 Identify the objectives** for the performance of the process. The performance objectives, scoped together with assumptions and constraints, are defined and communicated. | **GWP 1.0 Process documentation** should outline the process scope.<br><br>**GWP 2.0 Process plan** should provide details of the process performance objectives. |
| b. Performance of the process is planned and monitored. | **GP 2.1.2 Plan and monitor the performance** of the process to fulfil the identified objectives. Basic measures of process performance linked to business objectives are established and monitored. They include key milestones, required activities, estimates and schedules. | **GWP 2.0 Process plan** should provide details of the process performance objectives.<br><br>**GWP 9.0 Process performance records** should provide details of the outcomes.<br><br>**Note:** At this level, the record of process performance may be in the form of reports, issues registers and informal records. |
| c. Performance of the process is adjusted to meet plans. | **GP 2.1.3 Adjust the performance** of the process. Action is taken when planned performance is not achieved. Actions include identification of process performance issues and adjustment of plans and schedules as appropriate. | **GWP 4.0 Quality record** should provide details of action taken when performance is not achieved. |
| d. Responsibilities and authorities for performing the process are defined, assigned and communicated. | **GP 2.1.4 Define responsibilities and authorities** for performing the process. The key responsibilities and authorities for performing the key activities of the process are defined, assigned and communicated. The need for process performance experience, knowledge and skills is defined. | **GWP 1.0 Process documentation** should provide details of the process owner and who is responsible, accountable, consulted and/or informed (RACI).<br><br>**GWP 2.0 Process plan** should include details of the process communication plan as well as process performance experience, skills requirement. |
| e. Resources and information necessary for performing the process are identified, made available, allocated and used. | **GP 2.1.5 Identify and make available** resources to perform the process according to plan. Resources and information necessary for performing the key activities of the process are identified, made available, allocated and used. | **GWP 2.0 Process plan** should provide details of the process training plan and process resourcing plan. |
| f. Interfaces between the involved parties are managed to ensure effective communication and clear assignment of responsibility. | **GP 2.1.6 Manage the interfaces** between involved parties. The individuals and groups involved with the process are identified, responsibilities are defined and effective communication mechanisms are in place. | **GWP 1.0 Process documentation** should provide details of the individuals and groups involved (suppliers, customers and RACI).<br><br>**GWP 2.0 Process plan** should provide details of the process communication plan. |

**PA 2.2 Work Product Management**—A measure of the extent to which the work products produced by the process are appropriately managed. The work products referred to in this clause are those that result from the achievement of the process outcomes. As a result of full achievement of this attribute:
a. Requirements for the work products of the process are defined.
b. Requirements for documentation and control of the work products are defined.
c. Work products are appropriately identified, documented and controlled.
d. Work products are reviewed in accordance with planned arrangements and adjusted as necessary to meet requirements.

**Note:** Requirements for documentation and control of work products may include requirements for the identification of changes and revision status, approval and re-approval of work products, and the creation of relevant versions of applicable work products available at points of use.



Personal Copy of: Mr. Jorge Diab Maluf Filho

The GPs and GWPs that provide evidence of achievement of the attribute are shown in **figure 10**.

| Figure 10—PA 2.2 Work Product Management | | |
|---|---|---|
| **Result of Full Achievement of the Attribute** | **Generic Practices (GPs)** | **Generic Work Products (GWPs)** |
| a. Requirements for the work products of the process are defined. | **GP 2.2.1 Define the requirements for the work products,** including content structure and quality criteria. | **GWP 3.0 Quality plan** should provide details of quality criteria and work product content and structure. |
| b. Requirements for documentation and control of the work products are defined. | **GP 2.2.2 Define the requirements for documentation and control** of the work products. This should include identification of dependencies, approvals and traceability of requirements. | **GWP 1.0 Process documentation** should provide details of controls (control matrix).<br><br>**GWP 3.0 Quality plan** should provide details of work product, quality criteria, documentation requirements and change control. |
| c. Work products are appropriately identified, documented and controlled. | **GP 2.2.3 Identify, document and control** the work products. Work products are subject to change control, versioning and configuration management as appropriate. | **GWP 3.0 Quality plan** should provide details of work product, quality criteria, documentation requirements and change control. |
| d. Work products are reviewed in accordance with planned arrangements and adjusted as necessary to meet requirements. | **GP 2.2.4 Review and adjust work products** to meet the defined requirements. Work products are subject to review against requirements in accordance with planned arrangements and any issues arising are resolved. | **GWP 4.0 Quality records** should provide an audit trail of reviews undertaken. |

## 4.3 Level 3—Established Process

Managed Process is now implemented using a defined process that is capable of achieving its process outcomes.

**PA 3.1 Process Definition**—A measure of the extent to which a standard process is maintained to support the deployment of the defined process. As a result of full achievement of this attribute:

a. A standard process, including appropriate tailoring guidelines, is defined that describes the fundamental elements that must be incorporated into a defined process.
b. The sequence and interaction of the standard process with other processes are determined.
c. Required competencies and roles for performing a process are identified as part of the standard process.
d. Required infrastructure and work environment for performing a process are identified as part of the standard process.
e. Suitable methods for monitoring the effectiveness and suitability of the process are determined.

**Note:** A standard process may be used as is when deploying a defined process, in which case tailoring guidelines would not be necessary.



Personal Copy of: Mr. Jorge Diab Maluf Filho

The GPs and GWPs that provide evidence of achievement of the attribute are shown in **figure 11**.

**Figure 11—PA 3.1 Process Definition**

| Result of Full Achievement of the Attribute | Generic Practices (GPs) | Generic Work Products (GWPs) |
|---|---|---|
| a. A standard process, including appropriate tailoring guidelines, is defined that describes the fundamental elements that must be incorporated into a defined process. | **GP 3.1.1 Define the standard** process that will support the deployment of the defined process. A standard process is defined that identifies the fundamental process elements and provides guidance and procedures to support implementation and guidance on how it can be tailored when needed. | **GWP 5.0 Policies and standards** should provide details of the organisational objectives for the process, minimum standards of performance, standard procedures, and reporting and monitoring requirements. The evidential requirement at this level is not just that policies and standards exist, but that they are applied across the organisation. |
| b. The sequence and interaction of the standard process with other processes are determined. | **GP 3.1.2 Determine the sequence and interaction between processes** so that they work as an integrated system of processes. The standard process sequence and interaction with other processes are determined and maintained when a process is implemented in different parts of the organisation. | **GWP 5.0 Policies and standards** should provide a process mapping with details of standard processes and expected sequences and interaction. The evidential requirement at this level is not just that policies and standards exist, but that they are applied across the organisation. |
| c. Required competencies and roles for performing a process are identified as part of the standard process. | **GP 3.1.3 Identify the roles and competencies** for performing the standard process. | **GWP 5.0 Policies and standards** should provide details of roles and competencies for performing. The evidential requirement at this level is not just that policies and standards exist, but that they are applied across the organisation. |
| d. Required infrastructure and work environment for performing a process are identified as part of the standard process. | **GP 3.1.4 Identify the required infrastructure and work environment** for performing the standard process. The infrastructure (facilities, tools, methods, etc.) and work environment for performing the standard process are identified. | **GWP 5.0 Policies and standards** should identify minimum required infrastructure and work environment for performing the process. The evidential requirement at this level is not just that policies and standards exist, but that they are applied across the organisation. |
| e. Suitable methods for monitoring the effectiveness and suitability of the process are determined. | **GP 3.1.5 Determine suitable methods** to monitor the effectiveness and suitability of the standard process, including ensuring that appropriate criteria and data needed to monitor the effectiveness and suitability of the process are defined, and establishing the need to conduct internal audit and management review. | **GWP 5.0 Policies and standards** should provide details of the organisational objectives for process, minimum standards of performance, standard procedures, and reporting and monitoring requirements. The evidential requirement at this level is not just that policies and standards exist, but that they are applied across the organisation.<br><br>**GWP 4.0 Quality records** and **GWP 9.0 Process performance records** should provide evidence of reviews undertaken. |

**PA 3.2 Process Deployment**—A measure of the extent to which the standard process is effectively deployed as a defined process to achieve its process outcomes. As a result of full achievement of this attribute:

a. A defined process is deployed based on an appropriately selected and/or tailored standard process.
b. Required roles, responsibilities and authorities for performing the defined process are assigned and communicated.
c. Personnel performing the defined process are competent on the basis of appropriate education, training and experience.
d. Required resources and information necessary for performing the defined process are made available, allocated and used.
e. Required infrastructure and work environment for performing the defined process are made available, managed and maintained.
f. Appropriate data are collected and analysed as a basis for understanding the behaviour of the process, to demonstrate its suitability and effectiveness, and to evaluate where continuous improvement of the process can be made.

**Note:** Competency results from a combination of knowledge, skills and personal attributes that are gained through education, training and experience.



Personal Copy of: Mr. Jorge Diab Maluf Filho

The GPs and GWPs that provide evidence of achievement of the attribute are shown in **figure 12**.

| Figure 12—PA 3.2 Process Deployment | | |
|---|---|---|
| **Result of Full Achievement of the Attribute** | **Generic Practices (GPs)** | **Generic Work Products (GWPs)** |
| a. A defined process is deployed based on an appropriately selected and/or tailored standard process. | **GP 3.2.1 Deploy a defined process** that satisfies the context. When the same process is used within different areas of the organisation, it is based on a standard process, tailored as appropriate, with conformance to the requirements of the defined process verified. | **GWP 5.0 Policies and standards** should define the standards to be followed across all implementations of the process. The evidential requirement at this level is not just that policies and standards exist, but that they are applied across the organisation. |
| b. Required roles, responsibilities and authorities for performing the defined process are assigned and communicated. | **GP 3.2.2 Assign and communicate roles, responsibilities and authorities** for performing the defined process. When the same process is used within different areas of the organisation, the authorities and roles for performing the activities of process are assigned and communicated. | **GWP 5.0 Policies and standards** should provide details, responsibilities and authorities for performing the activities of process. The evidential requirement at this level is not just that policies and standards exist, but that they are applied across the organisation. |
| c. Personnel performing the defined process are competent on the basis of appropriate education, training and experience. | **GP 3.2.3 Ensure necessary competencies** for performing the defined process. When the same process is used within different areas of the organisation, the appropriate competencies for assigned personnel are identified and suitable training is available for those deploying the defined process. | **GWP 1.0 Process documentation** should provide details of competencies and training requirements.<br><br>**GWP 2.0 Process plan** should include details of the process communication plan, training plan and resourcing plan for each instance of the process. |
| d. Required resources and information necessary for performing the defined process are made available, allocated and used. | **GP 3.2.4 Provide resources and information** to support the performance of the defined process. When the same process is used within different areas of the organisation, the required human resources and information to perform the process are made available, allocated and used. | **GWP 2.0 Process plan** should include details of the resourcing plan for each instance of the process. |
| e. Required infrastructure and work environment for performing the defined process are made available, managed and maintained. | **GP 3.2.5 Provide adequate process infrastructure** to support the performance of the defined process. When the same process is used within different areas of the organisation, the required organisational support, infrastructure and work environment are made available, allocated and used. | **GWP 2.0 Process plan** should include details of the process infrastructure and work environment for each instance of the process. |
| f. Appropriate data are collected and analysed as a basis for understanding the behaviour of the process to demonstrate its suitability and effectiveness, and to evaluate where continuous improvement of the process can be made. | **GP 3.2.6 Collect and analyse data** about performance of the process to demonstrate its suitability and effectiveness. Data required to monitor the effectiveness and suitability of the process across the organisation are defined, collected and analysed as a basis for continual improvement. | **GWP 4.0 Quality records** and **GWP 9.0 Process performance records** should provide evidence of reviews undertaken tools for each instance of the process. |



Personal Copy of: Mr. Jorge Diab Maluf Filho

## 4.4 Level 4—Predictable Process

Established Process now operates within defined limits to achieve its process outcomes.

**PA 4.1 Process Measurement**—A measure of the extent to which measurement results are used to ensure that performance of the process supports the achievement of relevant process performance objectives in support of defined business goals. Measures may be either process measures or product measures or both. As a result of full achievement of this attribute:

a. Process information needs in support of relevant defined business goals are established.
b. Process measurement objectives are derived from process information needs.
c. Quantitative objectives for process performance in support of relevant business goals are established.
d. Measures and frequency of measurement are identified and defined in line with process measurement objectives and quantitative objectives for process performance.
e. Results of measurement are collected, analysed and reported in order to monitor the extent to which the quantitative objectives for process performance are met.
f. Measurement results are used to characterise process performance.

**Note:** Information needs may typically reflect management, technical, project, process or product needs.

The GPs and GWPs that provide evidence of achievement of the attribute are shown in **figure 13**.

**Figure 13—PA 4.1 Process Measurement**

| Result of Full Achievement of the Attribute | Generic Practices (GPs) | Generic Work Products (GWPs) |
|---|---|---|
| a. Process information needs in support of relevant defined business goals are established. | **GP 4.1.1 Identify process information needs,** in relation with business goals. The business goals and process stakeholder information needs have been established as a basis for determining the process performance measurement objectives. | **GWP 6.0 Process improvement plan** should provide process improvement objectives and proposed Improvement actions. |
| b. Process measurement objectives are derived from process information needs. | **GP 4.1.2 Derive process measurement objectives** from process information needs. Measurement objectives are based on the defined process measurement objectives. | **GWP 7.0 Process measurement plan** should provide details of proposed measurement objectives. |
| c. Quantitative objectives for process performance in support of relevant business goals are established. | **GP 4.1.3 Establish quantitative objectives** for the performance of the defined process, according to the alignment of the process with the business goals Quantitative measurement objectives are established that explicitly reflect business goals and have been verified as realistic and useful with organisational management and process owner(s). | **GWP 7.0 Process measurement plan** should provide details of proposed measurement measures and indicators. |
| d. Measures and frequency of measurement are identified and defined in line with process measurement objectives and quantitative objectives for process performance. | **GP 4.1.4 Identify product and process measures** that support the achievement of the quantitative objectives for process performance. Detailed measures for products and process are identified, together with the frequency of data collection and measurement as well as verification mechanisms. | **GWP 7.0 Process measurement plan** should provide details of proposed measures and indicators together with data collection procedures and analytical procedures. |
| e. Results of measurement are collected, analysed and reported in order to monitor the extent to which the quantitative objectives for process performance are met. | **GP 4.1.5 Collect product and process measurement results** through performing the defined process. Product and process measurement results are collected, analysed and reported according to a defined plan. | **GWP 7.0 Process measurement plan** should provide details of proposed analytical procedures.<br><br>**GWP 9.0 Process performance records** should provide details of measurements collected and analysed. |
| f. Measurement results are used to characterise process performance. | **GP 4.1.6 Use the results of the defined measurement** to monitor and verify the achievement of the process performance objectives. The results of the defined measurement are analysed to verify achievement against the process performance objectives. Appropriate techniques are used to understand process performance and capability within defined control limits. | **GWP 9.0 Process performance records** should provide details of measurements collected and analysed. |



Personal Copy of: Mr. Jorge Diab Maluf Filho

**PA 4.2 Process Control**—A measure of the extent to which the process is quantitatively managed to produce a process that is stable, capable and predictable within defined limits. As a result of full achievement of this attribute:
a. Analysis and control techniques are determined and applied where applicable.
b. Control limits of variation are established for normal process performance.
c. Measurement data are analysed for special causes of variation.
d. Corrective actions are taken to address special causes of variation.
e. Control limits are re-established (as necessary) following corrective action.

The GPs and GWPs that provide evidence of achievement of the attribute are shown in **figure 14**.

**Figure 14—PA 4.2 Process Control**

| Result of Full Achievement of the Attribute | Generic Practices (GPs) | Generic Work Products (GWPs) |
|---|---|---|
| a. Analysis and control techniques are determined and applied where applicable. | **GP 4.2.1 Determine analysis** and control techniques appropriate to control the process performance. Methods of measuring the effectiveness of process control are defined and validated. | **GWP 1.0 Process documentation** should provide details of controls (control matrix).<br><br>**GWP 8.0 Process control plan** should exist that specifies for each process the measurement approach. |
| b. Control limits of variation are established for normal process performance. | **GP 4.2.2 Define parameters** suitable to control the process performance. The standard process definition is modified to include methods for process control and control limits are established. | **GWP 8.0 Process control plan** should exist that specifies for each control limits for normal performance. |
| c. Measurement data are analysed for special causes of variation. | **GP 4.2.3 Analyse process and product measurement results** to identify variations in process performance. The results of process control measurements are analysed to determine issues of concern and forwarded for action. | **GWP 9.0 Process performance record** should provide details of measurements collected and analysed. |
| d. Corrective actions are taken to address special causes of variation. | **GP 4.2.4 Identify and implement corrective actions** to address assignable causes. Corrective action is taken to address process control concerns and results are monitored and evaluated. | **GWP 9.0 Process performance record** should provide details of measurements collected and analysed and corrective action taken. |
| e. Control limits are re-established (as necessary) following corrective action. | **GP 4.2.5 Re-establish control** limits following corrective action. Process control limits are appropriately modified after corrective action is taken. | **GWP 8.0 Process control plan** should exist that specifies control limits for normal performance. |

## 4.5 Level 5—Optimising Process

Predictable Process is continuously improved to meet relevant current and projected business goals.

**PA 5.1 Process Innovation**—A measure of the extent to which changes to the process are identified from analysis of common causes of variation in performance, and from investigations of innovative approaches to the definition and deployment of the process. As a result of full achievement of this attribute:
a. Process improvement objectives for the process are defined that support the relevant business goals.
b. Appropriate data are analysed to identify common causes of variations in process performance.
c. Appropriate data are analysed to identify opportunities for best practice and innovation.
d. Improvement opportunities derived from new technologies and process concepts are identified.
e. An implementation strategy is established to achieve the process improvement objectives.


Personal Copy of: Mr. Jorge Diab Maluf Filho

The GPs and GWPs that provide evidence of achievement of the attribute are shown in **figure 15**.

**Figure 15—PA 5.1 Process Innovation**

| Result of Full Achievement of the Attribute | Generic Practices (GPs) | Generic Work Products (GWPs) |
|---|---|---|
| a. Process improvement objectives for the process are defined that support the relevant business goals. | **GP 5.1.1 Define the process improvement objectives for the process** that supports the relevant business goals. Directions to process innovations are set. Quantitative and qualitative process improvement objectives—based on the potential for process innovation as well as business vision and goals— have been defined and documented. | **GWP 7.0 Process improvement plan** should provide process improvement objectives and proposed improvement actions. |
| b. Appropriate data are analysed to identify common causes of variations in process performance. | **GP 5.1.2 Analyse measurement data of the process** to identify real and potential variations in process performance. Process performance data are analysed to identify variations in process performance together with the root cause of common process performance issues. | **GWP 9.0 Process performance records** should provide details of measurements collected and analysed. |
| c. Appropriate data are analysed to identify opportunities for best practice and innovation. | **GP 5.1.3 Identify improvement opportunities of the process** based on innovation and best practices. Process improvement opportunities are identified based on comparison with industry best practices. | **GWP 6.0 Process improvement plan** should provide details of analysis against best practice. |
| d. Improvement opportunities derived from new technologies and process concepts are identified. | **GP 5.1.4 Derive improvement opportunities of the process from new technologies and process concepts.** Process improvement opportunities are identified based on review and analysis of emerging technological and process concept innovations, taking into account business environment changes including emerging business risks. | **GWP 6.0 Process improvement plan** should provide details of analysis of technology improvement opportunities. |
| e. An implementation strategy is established to achieve the process improvement objectives. | **GP 5.1.5 Define an implementation strategy** based on long-term improvement vision and objectives. A process improvement strategy is defined and validated based on long-term improvement goals and objectives. Commitment to improvement is demonstrated by organisational management and process owner(s). | **GWP 6.0 Process improvement plan** should provide details of the implementation strategy for process improvement. |

**PA 5.2 Process Optimisation**—A measure of the extent to which changes to the definition, management and performance of the process result in effective impact that achieves the relevant process improvement objectives. As a result of full achievement of this attribute:

a. Impact of all proposed changes is assessed against the objectives of the defined process and standard process.
b. Implementation of all agreed changes is managed to ensure that any disruption to the process performance is understood and acted on.
c. Based on actual performance, effectiveness of process change is evaluated against the defined product requirements and process objectives to determine whether results are due to common or special causes.



Personal Copy of: Mr. Jorge Diab Maluf Filho

The GPs and GWPs that provide evidence of achievement of the attribute are shown in **figure 16**.

| Figure 16—PA 5.2 Process Optimisation | | |
|---|---|---|
| **Result of Full Achievement of the Attribute** | **Generic Practices (GPs)** | **Generic Work Products (GWPs)** |
| a. Impact of all proposed changes is assessed against the objectives of the defined process and standard process. | **GP 5.2.1 Assess the impact of each proposed change** against the objectives of the defined and standard process. The impact of proposed changes is assessed against the objectives of the process and to determine the impact on product quality and process performance as well as other related processes. | **GWP 6.0 Process** improvement plan should provide details of the required process improvement project quality approach. |
| b. Implementation of all agreed changes is managed to ensure that any disruption to the process performance is understood and acted on. | **GP 5.2.2. Manage the implementation of agreed changes** to selected areas of the defined and standard process according to the implementation strategy. The implementation of agreed changes is managed in accordance with defined change management and change enablement processes. | **GWP 6.0 Process improvement plan** should provide details of the implementation strategy for process improvement and evidence of changes in:<br>• **GWP 1.0 Process documentation**<br>• **GWP 3.0 Quality plan**<br>• **GWP 5.0 Policies and standards** |
| c. Based on actual performance, effectiveness of process change is evaluated against the defined product requirements and process objectives to determine whether results are due to common or special causes. | **GP 5.2.3 Based on actual performance, evaluate the effectiveness of process change** against process performance, capability objectives and business goals. The effectiveness of the changes made to the process is measured, evaluated and reported after implementation. | **GWP 6.0 Process improvement plan** should provide details of the required process improvement project quality approach. |



Personal Copy of: Mr. Jorge Diab Maluf Filho

**Page intentionally left blank**



Personal Copy of: Mr. Jorge Diab Maluf Filho

# Appendix A. Conformity of the COBIT 5 Process Assessment Model

## A.1 Introduction

This part of the COBIT 5 process assessment is the statement of conformance to the requirements defined in ISO/IEC 15504-2. For ease of reference, the requirements from Clause 6.3 of ISO/IEC 15504-2 are embedded verbatim in the text of this action.

## A.2 Requirements for Process Assessment Models (From ISO/IEC 15504-2)

### *A.2.1 Introduction*

> *In order to assure that assessment results are translatable into an ISO/IEC 15504 process profile in a repeatable and reliable manner, Process Assessment Models shall adhere to certain requirements. A Process Assessment Model shall contain a definition of its purpose, scope and elements; its mapping to the Measurement Framework and specified Process Reference Model(s); and a mechanism for consistent expression of results.*
>
> *A Process Assessment Model is considered suitable for the purpose of assessing process capability by conforming to 6.3.2, 6.3.3, and 6.3.4.*
>
> *ISO/IEC 15504:2, 6.3.1*

The purpose of the COBIT 5 process assessment model is to support assessment of process capability in accordance with the requirements of ISO/IEC 15504:2 (refer to Clause 1).

### *A.2.2 Process Assessment Model Scope*

> ***6.3.2.1*** *A Process Assessment Model shall relate to at least one process from the specified Process Reference Model(s).*
>
> ***6.3.2.2*** *A Process Assessment Model shall address, for a given process, all, or a continuous subset, of the levels (starting at level 1) of the Measurement Framework for process capability for each of the processes within its scope.*
>
> ***Note:*** *It would be permissible for a model, for example, to address solely level 1, or to address levels 1, 2 and 3, but it would not be permissible to address levels 2 and 3 without level 1.*
>
> ***6.3.2.3*** *A Process Assessment Model shall declare its scope of coverage in the terms of:*
> *a) the selected Process Reference Model(s);*
> *b) the selected processes taken from the Process Reference Model(s);*
> *c) the capability levels selected from the Measurement Framework.*
>
> *ISO/IEC 15504:2, 6.3.2*

This process assessment model is based on COBIT 5, which serves as its 'process reference model'.

In the process dimension of this process assessment model, the model provides coverage of all processes in the process reference model.

In the capability dimension of this process assessment model, the model addresses all of the capability levels defined in the Measurement Framework in ISO/IEC 15504-2, Clause 5.



Personal Copy of: Mr. Jorge Diab Maluf Filho

### A.2.3 Process Assessment Model Elements and Indicators

*A Process Assessment Model shall be based on a set of indicators that explicitly addresses the purposes and outcomes, as defined in the selected Process Reference Model, of all the processes within the scope of the Process Assessment Model; and that demonstrates the achievement of the process attributes within the capability level scope of the Process Assessment Model. The indicators focus attention on the implementation of the processes in the scope of the model.*
*ISO/IEC 15504:2, 6.3.3*

The COBIT 5 process assessment model provides a two-dimensional view of process capability for the processes in the process reference model, through the inclusion of assessment indicators as shown in **figure 5**. The assessment indicators used are:
• Base practices (BPs) and work products (WPs)
• Generic practices (GPs) and generic work products (GWPs)

They support the judgement of the performance and capability of an implemented process.

**Note:** The assessment indicators for COBIT 5 process assessment model do not include resources.

### A.2.4 Mapping Process Assessment Models to Process Reference Models

*A Process Assessment Model shall provide an explicit mapping from the relevant elements of the model to the processes of the selected Process Reference Model and to the relevant process attributes of the Measurement Framework.*

*The mapping shall be complete, clear and unambiguous. The mapping of the indicators within the Process Assessment Model shall be to:*
*a) the purposes and outcomes of the processes in the specified Process Reference Model*
*b) the process attributes (including all of the results of achievements listed for each process attribute) in the Measurement Framework.*

*This enables Process Assessment Models that are structurally different to be related to the same Process Reference Model.*
*ISO/IEC 15504:2, 6.3.4*

Each of the processes in this COBIT 5 process assessment model is identical in scope to the process defined in the process reference model. Each base practice and work product is cross-referenced to the process outcomes it addresses. All work products relate as inputs or outputs to the process as a whole—see the mappings in ISO/IEC 15504-2, Clause 5.

Each of the process attributes in this process assessment model is identical to the process attribute defined in the measurement framework. The GPs address the characteristics from each process attribute. The generic resources and GWPs relate to the process attribute as a whole.

The mappings of the GPs to the achievements associated with each process attribute are shown in section 4.0.

### A.2.5 Expression of Assessment Results

*A Process Assessment Model shall provide a formal and verifiable mechanism for representing the results of an assessment as a set of process attribute ratings for each process selected from the specified Process Reference Model(s).*

*Note: The expression of results may involve a direct translation of Process Assessment Model ratings into a process profile as defined in this international standard, or the conversion of the data collected during the assessment (with the possible inclusion of additional information) through further judgment on the part of the assessor.*
*ISO/IEC 15504:2, 6.3.5*

The processes in this process assessment model are identical to those defined in the process reference model. The process attributes and the process attributes rating in this process assessment model are identical to those defined in the ISO/IEC 15504-2 Measurement Framework. As a consequence, results of assessments based on this process assessment model are expressed directly as a set of process attribute ratings for each process within the scope of the assessment. No form of translation or conversion is required.


Personal Copy of: Mr. Jorge Diab Maluf Filho

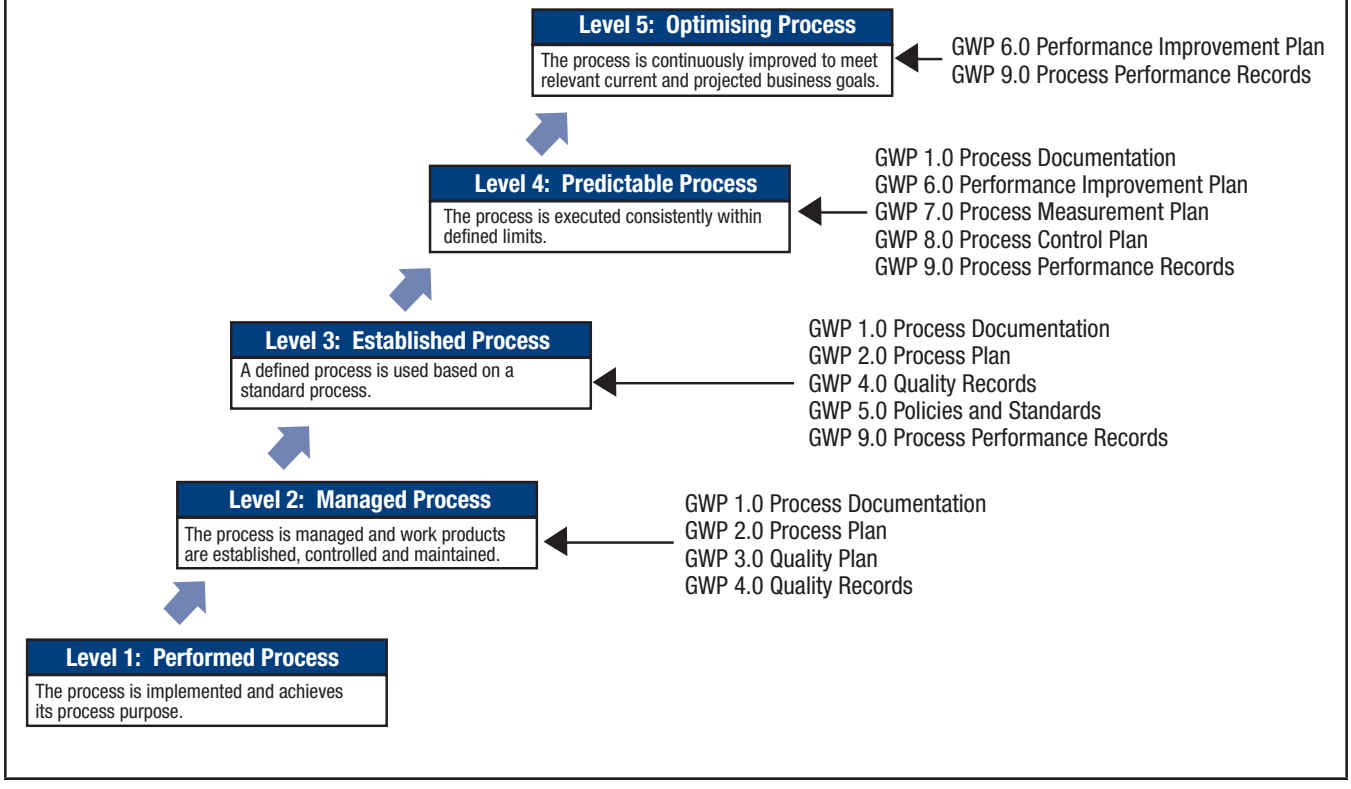
# Appendix B. Generic and Level 1 Output Work Products

## B.1 Generic Work Products (GWPs)

The GWPs are those work products required to support the management of a process. As outlined in section 4, their existence, together with GPs, provides evidence for the achievement of specific process capability attributes. The evidence includes such things as process objectives, responsibilities, performance requirements, improvement plans and outcomes required at various levels of process capability.

They are called 'generic' because similar work products would be expected for each process. They are indicative of the types of work products and content that will be introduced to support increased process capability. **Figure 17** lists the GWPs and the capability levels at which they would be required for evidential purposes.

**Figure 17—Generic Work Products and Relation to Capability Level**






Personal Copy of: Mr. Jorge Diab Maluf Filho

It is not expected that every organisation will use GWPs with the exact description and content as shown in **figure 18**.

**Figure 18—Generic Work Products (GWPs)**

| GWP ID | GWP | Typical Contents | Related GP | Additional Explanation |
|---|---|---|---|---|
| 1.0 | **Process Documentation** | Process name | N/A | The name of the process. |
| | | Process owner | GP 2.1.4 | The person responsible for the design of the process. This includes being responsible for the creation, update and approval of documents (procedures, work instructions/protocols) to support the process. |
| | | Process scope | GP 2.1.1 | A clear statement of where the process begins and ends |
| | | Process roles | GP 2.1.6 | Details of key roles in the process:<br>• Supplier(s) and inputs<br>• Output and customers |
| | | Process map | GP 3.1.2 | Generally, in the form of a schematic picture of a process to show the sequential flow of work. In most cases, there will be a map showing flows across a number of processes. |
| | | RACI chart | GP 2.1.4<br>GP 2.1.6 | Identifies who is responsible, accountable, consulted and informed with respect to each of the key activities in the process |
| | | Internal control matrix | GP 2.2.2 | Matrix showing identified risk within the business process together with identified controls |
| | | Process procedures | GP 3.1.1 | A document outlining the activities required to achieve the required process outcomes |
| 2.0 | **Process Plan** | Process performance objectives | GP 2.1.1<br>GP 2.1.2 | Will vary, depending on the process. However, there should be evidence of targets such as milestones, required activities, estimated output volumes or schedules. |
| | | Process resourcing | GP 2.1.5<br>GP 3.2.4 | A plan indicating resources and information required to meet the performance required for the process, and information on what resources are to be supplied |
| | | Process communication | GP 2.1.4<br>GP 2.1.6<br>GP 3.2.3 | A plan for the communication required for the process. It should include such things as the:<br>• Responsibility for communication<br>• Target audience<br>• Content that should be communicated<br>• Timing for communications<br>• Communication approach |
| | | Process infrastructure and work environment | GP 3.1.4<br>GP 3.2.5 | The facilities, tools, methods and work environment for performing the processes |
| | | Process performance experience, skills requirement | GP 2.1.4 | Job descriptions and skills required to undertake the process |
| | | Process training requirement | GP 2.1.5 | User skills and competencies, including individual training requirements |
| 3.0 | **Quality Plan** | Statement of quality policy and objectives | GP 2.1.2 | A statement of the customer's quality expectations for the process, e.g., deliverables or timeliness |
| | | Work products content | GP 2.2.1 | Identification of all work products, their structure and expected content |
| | | Quality criteria for the work products produced during the processes as basis for reviews and approvals | GP 2.2.1 | The criteria against which each work product will be reviewed and approved |
| | | Work products documentation | GP 2.2.2 | The requirements for documentation and control requirement, including identification, traceability and approvals |
| | | Work products change control, versioning and configuration management requirements | GP 2.2.3 | Outline of procedures for versioning and change control to be applied to work products |
| 4.0 | **Quality Records** | Records of reviews against requirements and action taken providing evidence during the required controls and quality checks | GP 2.2.4 | Record of reviews undertaken of work products together with any issues arising and resolution |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Figure 18—Generic Work Products (GWPs) *(cont.)* | | | | |
|---|---|---|---|---|
| **GWP ID** | **GWP** | **Typical Contents** | **Related GP** | **Additional Explanation** |
| 5.0 | **Policies and Standards** | Organisational objectives and responsibility for the process | GP 3.1.1 | A statement of the organisation's objectives for the process as it is applied across organisational units. It should identify overall responsibilities of the process.<br><br>**Note:** The implementation of policies and standards across the organisation will have to be confirmed. |
| | | Minimum standard of performance required for a process | GP 3.1.1 | The expected level of performance expected for the process across the organisation. This could include milestones, required activities, estimated output volumes or schedules.<br><br>**Note:** It is possible that this will be established for individual implementations of the process rather than as a generic performance. |
| | | Standard process mapping, including expected sequence and interaction between processes | GP 3.1.2<br>GP 3.2.1 | A schematic picture of the sequential flow of work expected for the process. This should also identify expected interactions between different implementations of the process. |
| | | Standardised procedures | GP 3.2.1 | A document outlining the procedures that should be followed in all implementations of the processes |
| | | Roles and competency for performing the process to minimum standards of performance | GP 3.1.3<br>GP 3.2.2<br>GP 3.2.3 | Standardised job descriptions, experience, qualifications and skill requirements for the process |
| | | The minimum infrastructure (facilities, tools, methods, etc.) and work environment for performing the standard process | GP 3.1.4 | The facilities, tools, methods and work environment for performing the processes |
| | | Reporting and monitoring requirements, including audit and review | GP 3.1.5 | Expected reports and monitoring required for the process, including standardised reporting requirements |
| 6.0 | **Performance Improvement Plan** | Process improvement objectives | GP 5.1.1 | The level of performance expected from the process, based on business objectives |
| | | Analysis against best practice | GP 5.1.3 | Identified opportunities for process improvements based on analysis of comparison with industry best practices |
| | | Technology improvement opportunities | GP 5.1.4 | Identified opportunities for process improvements based on analysis of technology and process innovations |
| | | Improvement actions | GP 5.1.5 | Identified actions for improving the process across the organisation |
| | | Improvement implementation plan | GP 5.1.6 | The proposed improvements, planned actions to implement those improvements, responsibilities and time table |
| | | Project quality approach | GP 5.1.5 | Proposed process for confirming the achievement of the improvements—measures, reviews, etc. |
| 7.0 | **Process Measurement Plan** | Measurement objectives | GP 4.1.1 | Quantitative objectives for the process relative to quality and process performance, based on customer needs and business objectives |
| | | Proposed measure/indicators | GP 4.1.2 | Identification of what is to be measured and the measurement indicators |
| | | Data collection procedures | GP 4.1.3 | Identification of how data are to be collected to support measurement |
| | | Analytical procedures | GP 4.1.3<br>GP 4.1.4 | Identification of analytical procedures to be used, from simple charts and graphs, to more sophisticated quantitative analyses such as statistical process control (SPC), structural modelling, or other multivariate statistical methods |
| 8.0 | **Process Control Plan** | Control techniques | GP 4.2.1 | A description of the methods used to minimise process and product variation. It will differ for each process and may include such things as standards, testing, reviews, walk-through and testing. |
| | | Measurement approach | GP 4.2.1 | How the variation in each process will be measured |
| | | Control limits for normal performance | GP 4.2.2 | The acceptable level of process variations |
| 9.0 | **Process Performance Records** | Records of reviews against requirements and action taken | GP 4.1.5 | Record of actual process performance, with any variations from expected results and action taken to rectify variations |



Personal Copy of: Mr. Jorge Diab Maluf Filho

## B.2 Level 1 Output Work Products

**Figure 19** provides level 1 output WPs. It was compiled from ISO/IEC 15504:1, 15504:7, COBIT 5 and this publication. For a general introduction to the concepts of process assessment, refer to section 4 of ISO/IEC 15504:1.

**Figure 19 - Level 1 Output Work Products**

| WP ID | WP | Description |
|---|---|---|
| EDM01-WP1 | Enterprise governance guiding principles | A document or record that outlines basic principles similar to ISO 38500 upon which the COBIT 5 framework is based |
| EDM01-WP2 | Decision-making model | A definition of information required and authority levels necessary to make informed decisions |
| EDM01-WP3 | Authority levels | A document similar to a RACI chart that shows clearly roles, responsibilities and accountabilities and levels of authority |
| EDM01-WP4 | Enterprise governance communications | A system or process that communicates the appropriate oversight of IT in the enterprise |
| EDM01-WP5 | Reward system approach | Documentation that confirms and clarifies the approach to rewards or incentives for employee performance; usually part of a performance process |
| EDM01-WP6 | Feedback on governance effectiveness and performance | Reported information generated by monitoring the effectiveness of the performance of the governance system |
| EDM02-WP1 | Evaluation of strategic alignment | The output of a governance activity enabled by a description of the enterprise goals with the associated contribution to enterprise goals |
| EDM02-WP2 | Evaluation of investment and services portfolios | Reported information or results of evaluating the portfolio of IT-enabled investments, services and assets to determine the likelihood of achieving enterprise objectives and delivering value at a reasonable cost |
| EDM02-WP3 | Investment types and criteria | Part of portfolio structure, it shows the types of investment and associated criteria |
| EDM02-WP4 | Requirements for stage-gate reviews | Criteria for reviews that are important to control IT-enabled investments and would form part of the programme or portfolio monitoring and review process |
| EDM02-WP5 | Feedback on portfolio and programme performance | Information such as key goals and metrics that are generated by a portfolio and programme monitoring process |
| EDM02-WP6 | Actions to improve value delivery | Results of an assessment approach or process to identify value delivery improvement opportunities or corrective actions |
| EDM03-WP1 | Risk appetite guidance | Forms part of an enterprise risk management plan that shows an understanding and guidance of the enterprise's risk tolerance |
| EDM03-WP2 | Approved risk tolerance levels | An approval process for risk tolerance levels should be in place. |
| EDM03-WP3 | Evaluation of risk management activities | Exists as part of a risk assessment system or process |
| EDM03-WP4 | Risk management policies | Policies, standards or operating practices that outline the enterprise risk management requirements, roles, responsibilities and controls |
| EDM03-WP5 | Key objectives to be monitored for risk management | Key goals associated with key metrics to be monitored as part of the risk assessment process |
| EDM03-WP6 | Approved process for measuring risk management | Information usually part of a risk register or remediation log kept as part of the risk assessment process during which risk management deviations in practice are identified |
| EDM03-WP7 | Remedial actions to address risk management deviations | Evidenced from a risk register or remediation log as part of the risk assessment process |
| EDM03-WP8 | Risk management issues for the board | Risk management issues with sufficient ranking or severity to require attention from the board of directors |
| EDM04-WP1 | Guiding principles for allocation of resources and capabilities | Statements that describe the allocation of resources and capabilities as part of the resource planning process or strategy |
| EDM04-WP2 | Guiding principles for enterprise architecture | Statements that describe the enterprise architecture planning and strategy |
| EDM04-WP3 | Approved resources plan | A resource assignment plan approved by both IT and the business |
| EDM04-WP4 | Communication of resourcing strategies | Part of the monitoring and reporting process to assist in informed decision making |
| EDM04-WP5 | Assigned responsibilities for resource management | A RACI chart will outline these roles and responsibilities. |
| EDM04-WP6 | Principles for safeguarding resources | A rule that must be followed that helps safeguard data and is usually part of the resourcing planning process or strategy |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Figure 19 - Level 1 Output Work Products *(cont.)* | | |
|---|---|---|
| **WP ID** | **WP** | **Description** |
| EDM04-WP7 | Feedback on allocation and effectiveness of resources and capabilities | Information resulting from the monitoring and reporting process for ensuring resource optimisation |
| EDM04-WP8 | Remedial actions to address resource management deviations | Part of the monitoring and reporting process for ensuring resource optimisation |
| EDM05-WP1 | Evaluation of enterprise reporting requirements | An evaluation of both internal and external reporting requirements including legal and regulatory and will be part of the governance framework |
| EDM05-WP2 | Reporting and communications principles | Principles will be part of the reporting in the governance framework. |
| EDM05-WP3 | Rules for validating and approving mandatory reports | Rules will be part of the reporting in the governance framework and could be in the form of policies, operating practices, and standards and/or procedures. |
| EDM05-WP4 | Escalation guidelines | A part of reporting in the governance framework and could be in the form of policies, operating practices and standards and/or procedures |
| EDM05-WP5 | Assessment of reporting effectiveness | Usually found from an annual internal audit or assessment report on the effectiveness of governance |
| APO01-WP1 | Definition of organisational structure and functions | Part of the IT management framework related to IT organisation |
| APO01-WP2 | Enterprise operational guidelines | Part of the IT-related policies, procedures and practices for the IT management framework |
| APO01-WP3 | Communication ground rules | Part of a monitoring and reporting process in the IT management framework |
| APO01-WP4 | Definition of IT-related roles and responsibilities | A RACI chart will outline these roles and responsibilities. |
| APO01-WP5 | Definition of supervisory practices | Part of the IT-related policies, procedures and practices for the IT management framework |
| APO01-WP6 | IT-related policies | Policies and/or operating practices/standards that reflect IT operations and accountabilities |
| APO01-WP7 | Communication on IT objectives | Part of a monitoring and reporting process for defining an IT framework |
| APO01-WP8 | Evaluation of options for IT organisation | Part of the IT management framework related to IT organisation |
| APO01-WP9 | Defined operational placement of IT function | Part of the IT management framework related to IT organisation |
| APO01-WP10 | Data classification guidelines | Part of an enterprise architecture plus data retention and risk management policy |
| APO01-WP11 | Data security and control guidelines | Part of the IT-related policies, procedures and guidelines, but specific to data security |
| APO01-WP12 | Data integrity procedures | Part of the IT-related policies, procedures and guidelines, but specific to data security; these are the more detailed procedures. |
| APO01-WP13 | Process capability assessments | Part of a monitoring and reporting process for defining an IT framework such as COBIT PAM |
| APO01-WP14 | Process improvement opportunities | Opportunities to improve arising from the use of a monitoring and reporting process for defining an IT framework |
| APO01-WP15 | Performance goals and metrics for process improvement tracking | Part of a monitoring and reporting process for defining an IT framework |
| APO01-WP16 | Non-compliance remedial actions | Part of the IT-related policies, procedures and practices for the IT management framework |
| APO02-WP1 | Sources and priorities for changes | Part of understanding the enterprise direction and looking at internal and external sources for change. This is part of the strategic planning process. |
| APO02-WP2 | Baseline of current capabilities | An assessment of current business capabilities as part of the strategic planning process |
| APO02-WP3 | Gaps and risk related to current capabilities | Part of the capability assessment; gaps will be present in either a risk/gap register or remediation log. |
| APO02-WP4 | Capability SWOT analysis | Part of the assessment of business capability in the strategic planning process |
| APO02-WP5 | High-level IT-related goals | Part of the strategic plan road map |
| APO02-WP6 | Required business and IT capabilities | Part of the strategic plan road map |
| APO02-WP7 | Proposed enterprise architecture changes | Part of both an enterprise architecture plan and the IT strategic plan |
| APO02-WP8 | Gaps and changes required to realise target capability | Part of the capability assessment; gaps will be present in either a risk/gap register or remediation log. |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Figure 19 - Level 1 Output Work Products *(cont.)* | | |
|---|---|---|
| **WP ID** | **WP** | **Description** |
| AP002-WP9 | Value benefit statement for target environment | Part of the IT strategic plan and results from the benefits analysis process of the IT Investment portfolio |
| AP002-WP10 | Definition of strategic initiatives | Part of the strategic plan road map |
| AP002-WP11 | Risk assessment initiatives | Part of the risk assessment process and will be included in the strategic plan road map |
| AP002-WP12 | Strategic road map | A plan that outlines the key steps/phases in getting or achieving a strategic plan |
| AP002-WP13 | Communication plan | Part of a reporting and monitoring process for strategic planning |
| AP002-WP14 | Communication package | The process outline for all communication dealing with strategic planning, includes the plan, methods and delivery of communication and frequency |
| AP003-WP1 | Defined scope of architecture | Part of the definition of a reference enterprise architecture model |
| AP003-WP2 | Architecture principles | Part of the definition of a reference enterprise architecture model |
| AP003-WP3 | Architecture concept business case and value proposition | Business case proposal for an architecture concept |
| AP003-WP4 | Baseline domain descriptions and architecture definition | Part of an enterprise architecture model |
| AP003-WP5 | Process architecture model | A typical process architecture model organises the logic for business process and IT infrastructure, which reflects the integration and standardisation requirements of the enterprise operating model. |
| AP003-WP6 | Information architecture model | Part of an enterprise architecture model, but will specifically relate to how information is organised |
| AP003-WP7 | High-level implementation and migration strategy | Implementation and migration strategy for architecture |
| AP003-WP8 | Transition architectures | Part of the implementation and migration strategy for architecture |
| AP003-WP9 | Resource requirements | Part of the implementation plan for enterprise architecture |
| AP003-WP10 | Implementation phase descriptions | Part of the implementation plan for enterprise architecture |
| AP003-WP11 | Architecture governance requirements | Part of the enterprise architecture model or framework governance requirements |
| AP003-WP12 | Solution development guidance | Part of the implementation plan for enterprise architecture |
| AP004-WP1 | Innovation plan | Innovation plan with the summary of approved and evaluated opportunities, business benefits and risk articulated |
| AP004-WP2 | Recognition and reward programme | Part of the strategic IT plan |
| AP004-WP3 | Innovation opportunities linked to business drivers | Part of an innovation plan for applications and IT infrastructure articulated in a strategic IT plan |
| AP004-WP4 | Research analyses of innovation possibilities | Found in an innovation planning process and will form part of a strategic IT plan |
| AP004-WP5 | Evaluations of innovation ideas | Found in an innovation planning process and will form part of a strategic IT plan |
| AP004-WP6 | Proof-of-concept scope and outline business case | Validation of assumptions for a proof of concept and will be part of the business case |
| AP004-WP7 | Test results from proof-of-concept initiatives | Part of a pilot or test found in an evaluation report |
| AP004-WP8 | Results and recommendations from proof-of-concept initiatives | Part of a pilot or test found in an evaluation report |
| AP004-WP9 | Analysis of rejected initiatives | Part of a pilot or test found in an evaluation report |
| AP004-WP10 | Assessments of using innovative approaches | Part of an innovation plan |
| AP004-WP11 | Evaluation of innovation benefits | Part of the business case preparation and planning |
| AP004-WP12 | Adjusted innovation plans | Final adjusted innovation plan |
| AP005-WP1 | Defined investment mix | Part of the investment portfolio |
| AP005-WP2 | Identified resources and capabilities required to support strategy | Reviewing the strategy to identify the enterprise capabilities in support of the strategy |
| AP005-WP3 | Feedback on strategy and goals | Part of a monitoring and communications plan to report on portfolio management |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Figure 19 - Level 1 Output Work Products *(cont.)* | | |
|---|---|---|
| **WP ID** | **WP** | **Description** |
| APO05-WP4 | Funding options | Reviewing source of funds statements as they relate to the investment portfolios |
| APO05-WP5 | Investment return expectations | Part of the management of benefits of the portfolios |
| APO05-WP6 | Programme business case | Part of the business case process. There may be several programme business cases, depending on the number and types of portfolios. |
| APO05-WP7 | Business case assessments | For both project and programmes |
| APO05-WP8 | Selected programmes with return on investment (ROI) milestones | Part of the programme business case |
| APO05-WP9 | Investment portfolio performance reports | Part of a monitoring and communications plan to report on portfolio management |
| APO05-WP10 | Updated portfolios of programmes, services and assets | Part of the portfolio maintenance process. Assessors should verify that such a process exists and provides sufficient audit reporting to verify that portfolios are effectively maintained. |
| APO05-WP11 | Benefit results and related communications | Part of a monitoring and communications plan to report on portfolio management. These will be articulated as part of programme business cases. |
| APO05-WP12 | Corrective actions to improve benefit realisation | Part of a benefits realisation plan |
| APO06-WP1 | Accounting processes | For managing IT-related expenditures. Most IT departments will have their own system for managing costs and budgets and business allocations, or be part of or integrated into the main enterprise accounting systems. |
| APO06-WP2 | IT costs classification scheme | Part of the IT accounting system |
| APO06-WP3 | Financial planning practices | Part of the enterprise financial planning system integrated into the IT cost and budget systems. Look for the enterprise policy and procedures. |
| APO06-WP4 | Prioritisation and ranking of IT initiatives | Part of the IT budgetary control system, which will be part of the accounting process |
| APO06-WP5 | Budget allocations | Part of the IT accounting system and agreed on with the business |
| APO06-WP6 | IT budget and plan | Also will report outputs from the IT accounting system or process |
| APO06-WP7 | Budget communications | Part of the IT financial reporting process. Budgets, plans and variance analysis will be reported as part of this process. |
| APO06-WP8 | Categorised IT costs | Part of the IT accounting system and agreed on with the business |
| APO06-WP9 | Cost allocation model | Part of the IT accounting system and agreed on with the business |
| APO06-WP10 | Cost allocation communications | Part of the IT financial reporting process. Budgets, plans and variance analysis will be reported as part of this process. |
| APO06-WP11 | Operational procedures | Based on the regular review performed, revise existing procedures, or create new ones, to meet new or changed requirements |
| APO06-WP12 | Cost data collection method | Part of the IT financial reporting process. Budgets, plans and variance analysis will be reported as part of this process. |
| APO06-WP13 | Cost consolidation method | Part of the IT financial reporting process. Budgets, plans and variance analysis will be reported as part of this process. |
| APO06-WP14 | Cost optimisation opportunities | Part of the IT financial reporting process. Budgets, plans and variance analysis will be reported as part of this process. |
| APO07-WP1 | Staffing requirement evaluations | Part of business and IT planning cycles, usually annually, and forms part of the operating plans and budgets. HR departments will contain planning reports that are input into the main plans. |
| APO07-WP2 | Competency and career development plans | Forms part of the business and IT operating plans and be part of the HR systems |
| APO07-WP3 | Personnel sourcing plans | An evaluation of internal and external sources, depending on the competencies required for both IT and business |
| APO07-WP4 | List of key personnel | Listing of personnel whose job roles are considered critical to the success of the enterprise |
| APO07-WP5 | Skills and competencies matrix | A matrix that maps skills and competencies to the specific job or role |
| APO07-WP6 | Skills development plans | A skills plan that identifies competency gaps and plans for development |
| APO07-WP7 | Review reports | Part of the HR reporting system. Assessors should confirm with management what reports exist. |
| APO07-WP8 | Personnel goals | Forms part of a staff annual appraisal or performance evaluation process |
| APO07-WP9 | Performance evaluations | Usually annually and part of the appraisal process |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Figure 19 - Level 1 Output Work Products *(cont.)* | | |
|---|---|---|
| **WP ID** | **WP** | **Description** |
| AP007-WP10 | Improvement plans | Part of the performance evaluation specific to the person being evaluated |
| AP007-WP11 | Inventory of business and IT human resources | Part of the HR reporting system. Assessors should confirm with management what reports exist. |
| AP007-WP12 | Resourcing shortfall analyses | Part of the skills development plans |
| AP007-WP13 | Resource utilisation records | Part of the HR system |
| AP007-WP14 | Contract staff policies | Some HR systems contain separate processes and master files for all contracts. |
| AP007-WP15 | Contract agreements | Some HR systems contain separate processes and master files for all contracts. |
| AP007-WP16 | Contract agreement reviews | Should be done with HR and IT and the business |
| AP008-WP1 | Clarified and agreed-on business expectations | Forms part of the business and IT operating plans. Sometimes these are reflected in specific SLAs or OLAs |
| AP008-WP2 | Agreed-on next steps and action plans | Forms part of the business and IT operating plans and/or business and IT service delivery plans |
| AP008-WP3 | Agreed-on key decisions | Forms part of the business and IT operating plans and/or business and IT service delivery plans |
| AP008-WP4 | Complaint and escalation status | Forms part of the contract process |
| AP008-WP5 | Communication plan | Part of a reporting and monitoring process for strategic planning |
| AP008-WP6 | Communication packages | The process outline for all communication dealing with relationship planning. It will include the plan, methods and delivery of communication, and frequency. |
| AP008-WP7 | Customer responses | Part of the communication package especially for periodic customer (internal and external) surveys and assessments |
| AP008-WP8 | Satisfaction analyses | Part of the communication package especially for periodic customer (internal and external) surveys and assessments |
| AP008-WP9 | Definition of potential improvement projects | Identify potential opportunities for IT to be an enabler of enhanced enterprise performance as part of the communication package and strategic IT plan. |
| AP009-WP1 | Identified gaps in IT services to the business | Part of a service catalogue process, which contains SLAs and OLAs to allow effective monitoring and reporting of gaps |
| AP009-WP2 | Definitions of standard services | Usually found in a service catalogue |
| AP009-WP3 | Service catalogues | All IT services and relevant target groups are documented in a catalogue. |
| AP009-WP4 | SLAs | SLAs are defined in the service catalogue. An SLA is a part of a service contract where the level of service is formally defined. |
| AP009-WP5 | OLAs | OLAs are defined in the service catalogue. An OLA defines the interdependent relationships amongst the internal support groups of an organisation working to support a SLA. |
| AP009-WP6 | Service level performance reports | Forms part of the monitoring and reporting process and is periodic, usually monthly and/or quarterly |
| AP009-WP7 | Improvement action plans and remediations | Comes out of the monitoring and reporting process and will usually be found in an issues log |
| AP009-WP8 | SLA revisions | Based on improvement action plans, assessor should verify if and when SLAs are updated. |
| AP010-WP1 | Supplier significance and evaluation criteria | Forms part of a procurement system, which will have reports analysing the supplier or vendor master file |
| AP010-WP2 | Supplier catalogue | Usually a supplementary system that typically identifies suppliers and associated contracts and categorises them into type, significance and criticality. Supplier and contract evaluation criteria should be established. |
| AP010-WP3 | Potential revisions to supplier contracts | New or changed contracts should conform to enterprise standards and legal and regulatory requirements. Any contractual disputes are dealt with and contract revisions made. |
| AP010-WP4 | Supplier requests for information (RFIs) and requests for proposals (RFPs) | RFIs and RFPs are part of a formal supplier selection process. |
| AP010-WP5 | RFI and RFP evaluations | Part of the supplier selection process |
| AP010-WP6 | Decision results of supplier evaluations | Part of the supplier selection process |
| AP010-WP7 | Supplier roles and responsibilities | Outlined is a supplier catalogue |
| AP010-WP8 | Communication and review process | Part of a supplier monitoring and reporting process. Assessors should check for periodic reviews of supplier performance. |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Figure 19 - Level 1 Output Work Products *(cont.)* | | |
|---|---|---|
| **WP ID** | **WP** | **Description** |
| APO10-WP9 | Results and suggested improvements | Part of a supplier monitoring and reporting process. Assessors should check for periodic reviews of supplier performance. |
| APO10-WP10 | Identified supplier delivery risk | Part of a supplier risk assessment and should be present in the contract process |
| APO10-WP11 | Identified contract requirements to minimise risk | Part of a supplier risk assessment and should be present in the contract process |
| APO10-WP12 | Supplier compliance monitoring criteria | Part of a supplier monitoring and reporting process. Assessors should check for periodic reviews of supplier performance. |
| APO10-WP13 | Supplier compliance monitoring review results | Part of a supplier monitoring and reporting process. Assessors should check for periodic reviews of supplier performance and compliance, especially with legal and statutory requirements. |
| APO11-WP1 | Quality management system (QMS) roles, responsibilities and decision rights | A QMS is established to outline clear roles, responsibilities and decision rights (who is accountable and authorised to make the decision). |
| APO11-WP2 | Quality management plans | An overall quality plan should be maintained that promotes continuous improvement. This should include the need for, and benefits of, continuous improvement. Assessors should collect and analyse data about the QMS, and check for the effectiveness of the QMS. |
| APO11-WP3 | Results of QMS effectiveness reviews | Part of a continuous monitoring and reporting process |
| APO11-WP4 | Quality management standards | Part of the QMS and should be in line with the IT control framework requirements |
| APO11-WP5 | Customer requirements for quality management | Customer requirements should be aligned in the QMS. |
| APO11-WP6 | Acceptance criteria | Part of the QMS and should be in line with the IT control framework requirements |
| APO11-WP7 | Review results of quality of service, including customer feedback | Part of a continuous monitoring and reporting process |
| APO11-WP8 | Results of quality reviews and audits | Part of a continuous monitoring and reporting process |
| APO11-WP9 | Process quality of service goals and metrics | Part of the QMS and should be in line with the IT control framework requirements |
| APO11-WP10 | Results of solution and service delivery quality monitoring | Part of a continuous monitoring and reporting process and will typically be a periodic report |
| APO11-WP11 | Root causes of quality delivery failures | Part of a continuous monitoring and reporting process and can be found in a root cause log or register |
| APO11-WP12 | Communications on continual improvement and best practices | Part of a continuous monitoring and reporting process and can be found in periodic reporting to management |
| APO11-WP13 | Examples of good practice to be shared | Part of a continuous monitoring and reporting process and can be found from analysis of review meetings and management reporting |
| APO11-WP14 | Quality review benchmark results | Part of a continuous monitoring and reporting process and can be found from a process capability or maturity modelling assessment |
| APO12-WP1 | Data on the operating environment relating to risk | An assessor would review the enterprise risk assessment process that contains a risk profile, scenarios, events, a risk register and reporting tools. The risk profile will show all relevant data on the operating environment. |
| APO12-WP2 | Data on risk events and contributing factors | Part of the enterprise risk profile |
| APO12-WP3 | Emerging risk issues and factors | Part of the enterprise risk profile |
| APO12-WP4 | Scope of risk analysis efforts | Part of the enterprise risk profile |
| APO12-WP5 | IT risk scenarios | Part of the enterprise risk profile. Scenario analysis is a process of analysing possible future events by considering alternative possible outcomes and or events, e.g., loss of data due to disaster. |
| APO12-WP6 | Risk analysis results | Outcomes of a risk assessment show impacts, probabilities and how they are managed. |
| APO12-WP7 | Documented risk scenarios by line of business and function | See risk profile and IT risk scenarios. This is part of the enterprise risk management plan. |
| APO12-WP8 | Aggregated risk profile, including status of risk management actions | The IT risk register contains this information. |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Figure 19 - Level 1 Output Work Products *(cont.)* | | |
|---|---|---|
| **WP ID** | **WP** | **Description** |
| APO12-WP9 | Risk analysis and risk profile reports for stakeholders | Part of the risk assessment process and ongoing monitoring and reporting, usually quarterly for ongoing and at project or programme start-up and also for new IT application and software developments |
| APO12-WP10 | Results of third-party risk assessments | Part of third-party and contract reviews |
| APO12-WP11 | Opportunities for acceptance of greater risk | Depends on the organisation's risk appetite, which should be defined in the risk profile |
| APO12-WP12 | Project proposals for reducing risk | Part of the risk management process, it usually is based on an analysis of the risk register and periodic reporting process |
| APO12-WP13 | Risk-related incident response plans | Linked to the IT and information security incidence response and reporting process |
| APO12-WP14 | Risk impact communication | Part of the risk assessment and risk reporting process |
| APO12-WP15 | Risk-related root causes | Part of the risk assessment and risk reporting process |
| APO13-WP1 | ISMS policy | There will be either a policy, standard or operating practice that will be part of the ISMS. |
| APO13-WP2 | ISMS scope statement | Part of the ISMS strategy and planning documentation or the ISMS programme outline |
| APO13-WP3 | Information security risk treatment plan | Part of the ISMS risk assessment process based on the risk profile |
| APO13-WP4 | Information security business cases | Only if required for an information security project or programme |
| APO13-WP5 | ISMS audit reports | Part of internal audit reporting or monthly information security reporting, which will also be integrated into a security incident response and reporting system |
| APO13-WP6 | Recommendations for improving the ISMS | Part of normal ISMS monitoring and reporting. Assessors should look for or ask for this. |
| BAI01-WP1 | Updated programme and project management approaches | Part of the organisation's project/programme management information (PMI) system or framework |
| BAI01-WP2 | Programme concept business case | Usually the first, high-level business case produced at a programme level. Once noted and approved to go to the next stage, and after more analysis and feasibility studies, a more detailed business case is done and broken down to project level. |
| BAI01-WP3 | Programme mandate and brief | Part of the project/programme manager's office (PMO) setup and process, and creates the charter to set up a project or programme |
| BAI01-WP4 | Programme benefit realisation plan | A precursor to the business case and would normally be part of that analysis |
| BAI01-WP5 | Stakeholder engagement plan | Part of the portfolio management process |
| BAI01-WP6 | Results of stakeholder engagement effectiveness assessments | Part of the portfolio management process and periodic project and programme management reporting |
| BAI01-WP7 | Programme plan | Produced by the programme manager and is detailed enough to show costs, benefits, resourcing, time lines, dependencies and risk analysis |
| BAI01-WP8 | Programme budget and benefits register | A key part of the PMO setup and process and a source of input for business cases, benefits realisation planning, and programme and project management |
| BAI01-WP9 | Resource requirements and roles | Part of the PMO setup and process and creates the charter to set up a project or programme |
| BAI01-WP10 | Results of benefit realisation monitoring | Part of the PMO setup and process and should be incorporated into the monthly project and programme monitoring and reporting |
| BAI01-WP11 | Results of programme goal achievement monitoring | Part of the PMO setup and process and should be incorporated into the monthly project and programme monitoring and reporting |
| BAI01-WP12 | Programme audit plans | Part of the PMO setup and process and should be incorporated into the monthly project and programme monitoring and reporting |
| BAI01-WP13 | Results of programme performance reviews | Part of the PMO setup and process and should be incorporated into the monthly project and programme monitoring and reporting |
| BAI01-WP14 | Stage-gate review results | A stage-gate process is a conceptual and operational road map for moving a new-product project from idea to launch. Stage-gate divides the effort into distinct stages separated by management decision gates. For example, some are organised around a project life cycle (appraise, select, define, execute and operate), some by project phases. A decision must be made at each gate before the project or programme can progress. Assessors should look for the reviews of these decisions. |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Figure 19 - Level 1 Output Work Products *(cont.)* | | |
|---|---|---|
| **WP ID** | **WP** | **Description** |
| BAI01-WP15 | Project scope statements | Self-explanatory and part of the normal PMO setup and process |
| BAI01-WP16 | Project definitions | Self explanatory and part of the normal PMO setup and process |
| BAI01-WP17 | Project plans | Part of the normal PMO setup and process |
| BAI01-WP18 | Project baseline | Part of project planning and is done at the project start-up and at periodic intervals decided on by the PMO |
| BAI01-WP19 | Project reports and communications | Part of the normal PMO setup and process |
| BAI01-WP20 | Quality management plan | Part of the normal PMO setup and process |
| BAI01-WP21 | Requirements for independent verification of deliverables | Usually part of the stage-gate reviews. A gate decision maker may ask for this if necessary, but it is dependent on the project or programme. |
| BAI01-WP22 | Project risk management plan | Self-explanatory and part of the normal PMO setup and process |
| BAI01-WP23 | Project risk assessment results | Self-explanatory and part of the normal PMO setup and process |
| BAI01-WP24 | Project risk register | Self-explanatory and part of the normal PMO setup and process |
| BAI01-WP25 | Project performance criteria | Self-explanatory and part of the normal PMO setup and process |
| BAI01-WP26 | Project progress reports | Self-explanatory and part of the normal PMO setup and process |
| BAI01-WP27 | Agreed-on changes to project | Self-explanatory and part of the normal PMO setup and process |
| BAI01-WP28 | Project resource requirements | Self-explanatory and part of the normal PMO setup and process |
| BAI01-WP29 | Project roles and responsibilities | Self-explanatory and part of the normal PMO setup and process |
| BAI01-WP30 | Gaps in project planning | Self-explanatory and part of the normal PMO setup and process |
| BAI01-WP31 | Post-implementation review results | Timing is an issue here, usually undertaken after several months of operation |
| BAI01-WP32 | Project lessons learned | Part of the post-implementation review |
| BAI01-WP33 | Stakeholder project acceptance confirmations | Part of the project sign-off and closure |
| BAI01-WP34 | Communication of programme retirement and ongoing accountabilities | Part of the project sign-off and closure |
| BAI02-WP1 | Requirements definition repository | Part of the systems development analysis for new developments and is a log or register holding all business user requirements |
| BAI02-WP2 | Confirmed acceptance criteria from stakeholders | Usually done as part of a feasibility study report |
| BAI02-WP3 | Record of requirement change requests | Part of a change log for operational change management |
| BAI02-WP4 | Feasibility study report | A comprehensive report that contains user requirements, outline of the solutions for development, risk assessment, capacity and performance planning, etc. |
| BAI02-WP5 | High-level acquisition/ development plan | Contains the initial design and development proposal for applications and infrastructure |
| BAI02-WP6 | Requirements risk register | Similar to the IT or enterprise risk management risk register and integrated into the main risk assessment process |
| BAI02-WP7 | Risk mitigation actions | Derived from the requirements risk register |
| BAI02-WP8 | Sponsor approvals of requirements and proposed solutions | There must be evidence of requirements sign-off of both the statement of requirements (SOR) and definitions and the feasibility study report. |
| BAI02-WP9 | Approved quality reviews | Part of the ongoing project development cycle |
| BAI03-WP1 | Approved high-level design specification | Self-explanatory and part of the system development life cycle (SDLC) process |
| BAI03-WP2 | Approved detailed design specification | Self-explanatory and part of the SDLC process |
| BAI03-WP3 | SLA and OLA revisions | Changes made to existing SLAs and OLAs based on periodic or one-off reviews |
| BAI03-WP4 | Documented solution components | Self-explanatory and part of the SDLC process |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Figure 19 - Level 1 Output Work Products *(cont.)* | | |
|---|---|---|
| **WP ID** | **WP** | **Description** |
| BAI03-WP5 | Approved acquisition plan | May be found in the mergers and acquisitions department with copies in the IT department, if predominantly an IT development |
| BAI03-WP6 | Updates to asset inventory | Self-explanatory and should be part of asset inventory procedures |
| BAI03-WP7 | Integrated and configured solution components | Usually undertaken by the accounts department, but instigated by the bringing the new asset into production |
| BAI03-WP8 | Quality assurance plan | Self-explanatory and part of the SDLC process |
| BAI03-WP9 | Quality review results, exceptions and corrections | Self-explanatory and part of the SDLC process |
| BAI03-WP10 | Test plan | Part of the new system changeover planning documents |
| BAI03-WP11 | Test procedures | Part of the new system changeover planning documents |
| BAI03-WP12 | Test result logs and audit trails | Part of the new system changeover planning documents |
| BAI03-WP13 | Test result communications | Part of the new system changeover planning documents |
| BAI03-WP14 | Record of all approved and applied change requests | Found in a change management log |
| BAI03-WP15 | Maintenance plan | Part of the new system changeover planning documents |
| BAI03-WP16 | Updated solution components and related documentation | Usually found in a plan for the maintenance of solution and infrastructure components. Periodic reviews against business needs and operational requirements should be included. |
| BAI03-WP17 | Service definitions | Usually found in a service catalogue |
| BAI03-WP18 | Updated service portfolio | Usually managed by the business with agreement of IT services and is the main driver or enabler of the service catalogue |
| BAI04-WP1 | Availability, performance and capacity baselines | An assessment of system infrastructure and application performance and capacity, is assessed during the development stages and baselined after testing and start-up of the system or process |
| BAI04-WP2 | Evaluations against SLAs | Periodic evaluations, usually monthly, as part of monthly IT reporting and monitoring and uses the service catalogue or portfolio as a reference point |
| BAI04-WP3 | Availability, performance and capacity scenarios | Part of capacity planning and originates during the system development phases through baselining, testing and change over. Will need updating as part of capacity planning and reporting on a periodic basis. |
| BAI04-WP4 | Availability, performance and capacity business impact assessments | Part of the IT risk management assessment process. It will not normally be separate, so assessor should check to see that the risk register includes these impacts. |
| BAI04-WP5 | Prioritised improvements | Based on monthly evaluations of system performance |
| BAI04-WP6 | Performance and capacity plans | Produced with baselining during the monthly reporting and monitoring process |
| BAI04-WP7 | Availability, performance and capacity reports | Part of the monthly IT monitoring and reporting process |
| BAI04-WP8 | Performance and capacity gaps | Normally logged in a register or log and forms part of the monthly IT monitoring and reporting process |
| BAI04-WP9 | Corrective actions | Shown in the register or log. Assessor should verify that there are follow-up actions as part of the periodic reporting process. |
| BAI04-WP10 | Emergency escalation procedure | Part of the change management process defined in the change management operating practices and or standards |
| BAI05-WP1 | Communications of drivers for change | Part of the organisation change management process and will include strong business input |
| BAI05-WP2 | Communications from executive management committing to change | Part of the change management process. Business should be accountable for all IT changes; documentation should exist confirming this, usually in the programme or project change management process. |
| BAI05-WP3 | Implementation team and roles | Part of the PMO procedures and programme initiation document |
| BAI05-WP4 | Common vision and goals | Part of the PMO procedures and programme initiation document |
| BAI05-WP5 | Vision communication plan | Part of the programme or project plans, may not be a separate document |
| BAI05-WP6 | Vision communications | Part of the project reporting process |
| BAI05-WP7 | Aligned HR performance objectives | Part of the benefits realisation planning and business case |
| BAI05-WP8 | Identified quick wins | Part of the benefits realisation planning and business case |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Figure 19 - Level 1 Output Work Products *(cont.)* | | |
|---|---|---|
| **WP ID** | **WP** | **Description** |
| BAI05-WP9 | Communications of benefits | Part of the benefits realisation planning and business case |
| BAI05-WP10 | Operation and use plan | More tactical and typically a plan that outlines the details of how the changes will be used and the operation process around them |
| BAI05-WP11 | Success measures and results | Part of the operation and use plan |
| BAI05-WP12 | Compliance audit results | Assumes an internal audit or formal assessment/evaluation of the change management programme or project |
| BAI05-WP13 | Awareness communications | Part of the change management communication plan |
| BAI05-WP14 | HR performance review results | Part of sustaining the changes. It relates to the effective training of new staff and is typically linked to the annual appraisal process. |
| BAI05-WP15 | Knowledge transfer plans | Part of sustaining the changes. There should be some form of ongoing communication campaigns, continued top management commitment, adoption monitoring and sharing of lessons learned across the enterprise. |
| BAI05-WP16 | Communications of management's commitment | Part of the organisational change management process. Assessors should confirm that there these communications are documented. |
| BAI05-WP17 | Reviews of operational use | Part of the monthly monitoring and reporting process |
| BAI06-WP1 | Impact assessments | Part of the IT risk management process. Assessor should verify that normal operational change impacts are being captured in the risk register. |
| BAI06-WP2 | Approved requests for change | Documented in a change management log and must have user/requestor authorisation |
| BAI06-WP3 | Change plan and schedule | Part of the change management process. Day-to-day changes will be documented in an annual plan and monthly schedule and will typically include all patch management, normal upgrades, etc. |
| BAI06-WP4 | Post-implementation review of emergency changes | Usually done quarterly as part of the ongoing monitoring and reporting process |
| BAI06-WP5 | Change request status reports | Typically shows where the change is in the cycle, development, test, etc. |
| BAI06-WP6 | Change documentation | Starts with a comprehensive change log or register and will include requests for change, review and approval, feedback to management and initiator. Segregation of duties is an important part of this documentation. |
| BAI07-WP1 | Approved implementation plan | Part of the changeover/cutover planning and includes roles and responsibilities, a detailed schedule of testing and handover procedures |
| BAI07-WP2 | Implementation fallback and recovery process | Part of the implementation plan and a crucial element in the plan |
| BAI07-WP3 | Migration plan | Part of the implementation and documents how both master data and operational data are to be transferred; typically includes both manual and automated processes |
| BAI07-WP4 | Approved acceptance test plan | Usually part of the implementation plan or a subset, but is usually comprehensive enough because it is one of the key phases of system changeover. |
| BAI07-WP5 | Test data | Part of test planning; usually requires preparation and decisions on source, live examples or dummy data. |
| BAI07-WP6 | Test results log | Part of the testing process |
| BAI07-WP7 | Evaluation of acceptance results | Refers to the test results |
| BAI07-WP8 | Approved acceptance and release for production | Final sign-off is crucial to the successful launch of a new system and comes after the evaluation of test results. |
| BAI07-WP9 | Release plan | Part of the acceptance and approval process |
| BAI07-WP10 | Release log | Optional. Many enterprises will have a release plan without a separate release log, but will have a change implementation log, which includes all phases of the implementation. |
| BAI07-WP11 | Supplemental support plan | Part of the implementation plans showing users who will be supported through the initial start-up phase and ongoing and how they will be supported. The length of the ongoing support will depend on the size and complexity of the changed system or process. |
| BAI07-WP12 | Post-implementation review report | Usually lags behind launch and support period. Assessors should confirm that it is planned. |
| BAI07-WP13 | Remedial action plan | Part of the cutover planning; is important to ensure the support period of the implementation |
| BAI08-WP1 | Communications on value of knowledge | Part of the knowledge strategy and planning process |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Figure 19 - Level 1 Output Work Products *(cont.)* | | |
|---|---|---|
| **WP ID** | **WP** | **Description** |
| BAI08-WP2 | Classification of information sources | Similar to a data classification scheme, but enhanced for not only statutory requirements of data and record retention, but internal uses of information, taking into consideration knowledge database organisation |
| BAI08-WP3 | Published knowledge repositories | Usually part of the web system combined with a repository (e.g., SharePoint), but specifically targeting public classified information |
| BAI08-WP4 | Knowledge user database | A system like SharePoint or iMIS that the organisation will use or its user database |
| BAI08-WP5 | Knowledge awareness and training schemes | Self-explanatory |
| BAI08-WP6 | Knowledge use evaluation results | Enterprises should track the use of the knowledge database and capture or record the results. |
| BAI08-WP7 | Rules for knowledge retirement | Part of the knowledge strategy and plan that, as part of a data classification and retention policy, clarifies specific rules of retirement, which take into consideration legal and regulatory requirements |
| BAI09-WP1 | Asset register | Asset registers are usually part of, or integrated into, the enterprise's accounting software application and not normally found in separate IT registers. However, these systems will allow asset classifications to meet individual functional requirements such as the organisation of IT and information assets. |
| BAI09-WP2 | Results of physical inventory checks | Physical inventories are usually conducted annually. It is important for IT to include this type of monitoring into its reporting process. |
| BAI09-WP3 | Results of fit-for-purpose reviews | Review of IT assets in terms of meeting business requirements. It is a check for obsolescence and is important to ensure ongoing support for business or enterprise goals. |
| BAI09-WP4 | Communication of planned maintenance downtime | An essential part of operational planning especially around databases, networks and critical applications |
| BAI09-WP5 | Maintenance agreements | With vendors, but also with internal business users. Software licensing will be included in this process. |
| BAI09-WP6 | Approved asset procurement requests | Part of the IT procurement process and usually linked to the purchase order/invoice matching process |
| BAI09-WP7 | Asset register revisions | Asset registers are usually part of or integrated into the enterprise's accounting software application and not normally found in separate IT registers. However, these systems will allow asset classifications to meet individual functional requirements such as the organisation of IT and information assets. |
| BAI09-WP8 | Authorised asset retirements | Part of the normal assets management process and integrated into the accounting rules for assets retirement. It is not done in isolation of accounting policy and procedures. |
| BAI09-WP9 | Results of cost optimisation reviews | Part of the assets monitoring and reporting process |
| BAI09-WP10 | Opportunities to reduce asset costs or increase value | Part of the assets monitoring and reporting process |
| BAI09-WP11 | Register of software licences | Assessors should verify the existence of a separate register for software licences because it is important for the audit process. |
| BAI09-WP12 | Results of installed licence audits | Part of an audit report, usually annually |
| BAI09-WP13 | Action plan to adjust licence numbers and allocations | Recommendations made for the revision of licence numbers based on audit report or other evidentiary material |
| BAI10-WP1 | Scope of configuration management model | Part of the actual configuration model. This is a detailed model of the IT infrastructure and how it relates to IT services. |
| BAI10-WP2 | Logical configuration model | Self-explanatory; see scope explanation. |
| BAI10-WP3 | Configuration repository | A database that holds the model, definitions, standards, etc. |
| BAI10-WP4 | Configuration baseline | Part of the configuration model and repository. A baseline will be done at the development and planning stages. |
| BAI10-WP5 | Updated repository with configuration items | Part of the maintenance process for configuration management |
| BAI10-WP6 | Approved changes to baseline | Part of the maintenance process |
| BAI10-WP7 | Configuration status reports | Part of the IT monitoring and reporting on configuration management |
| BAI10-WP8 | Results of physical verification of configuration items | Part of the IT monitoring and reporting on configuration management |
| BAI10-WP9 | Licence deviations | Where there are deviations on external licensing agreement, if applicable |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Figure 19 - Level 1 Output Work Products *(cont.)* | | |
|---|---|---|
| **WP ID** | **WP** | **Description** |
| BAI10-WP10 | Results of repository completeness reviews | Part of the IT monitoring and reporting on configuration management |
| DSS01-WP1 | Operational schedule | An IT operational schedule includes all IT services including outsourced, facilities management, infrastructure and environmental factors. |
| DSS01-WP2 | Backup log | Part of data management. Assessors should check for operating practices/standards and/or policies for this. |
| DSS01-WP3 | Independent assurance plans | Plans for independent audit and assurance of operational and health safety and security environmental (HSSE) activities, a critical part of a robust monitoring and reporting process |
| DSS01-WP4 | Asset monitoring rules and event conditions | Event conditions are part of comprehensive incident management, monitoring and reporting. |
| DSS01-WP5 | Event logs | Same as for event conditions |
| DSS01-WP6 | Incident tickets | Part of the incident management and help desk system |
| DSS01-WP7 | Environmental policies | Deals specifically with the management of IT environments, including data centres and storage rooms |
| DSS01-WP8 | Insurance policy reports | Results of comparison of measures and contingency plans against insurance policy requirements |
| DSS01-WP9 | Facilities assessment reports | Part of facilities management and physical risk assessments |
| DSS01-WP10 | Health and safety awareness | Part of HSSE process and policies |
| DSS02-WP1 | Incident and service request classification schemes and models | Part of the incident management process. Classifications schemes classifying the type of events/errors, etc., are a normal part of an incident management model. |
| DSS02-WP2 | Rules for incident escalation | Part of the incident management model and process |
| DSS02-WP3 | Criteria for problem registration | Part of the incident management model and process |
| DSS02-WP4 | Incident and service request log | Part of the incident management model and process |
| DSS02-WP5 | Classified and prioritised incidents and service requests | Part of the incident management model and process |
| DSS02-WP6 | Approved service requests | Part of the incident management model and process |
| DSS02-WP7 | Fulfilled service requests | Part of the incident management model and process |
| DSS02-WP8 | Incident symptoms | Description of the issues that are caused by a certain problem |
| DSS02-WP9 | Problem log | Separate to the incident log, but related |
| DSS02-WP10 | Incident resolutions | Documented in an incident log. Assessors should check for alignment with the problem log. |
| DSS02-WP11 | Closed service requests and incidents | Part of the incident logs |
| DSS02-WP12 | User confirmation of satisfactory fulfilment or resolution | Part of the monitoring and reporting of incidents. Status reports should include user feedback/confirmation. |
| DSS02-WP13 | Incident status and trends report | Part of the monitoring and reporting of incidents |
| DSS02-WP14 | Request fulfilment status and trends report | Part of the monitoring and reporting of incidents |
| DSS03-WP1 | Problem classification scheme | Similar to the incident classification, but specific to problems versus incidents |
| DSS03-WP2 | Problem status reports | Part of the monitoring and reporting of problems and their status |
| DSS03-WP3 | Problem register | Problems and their status are recorded; similar to an incident log or register |
| DSS03-WP4 | Root causes of problems | Part of the problem register and ongoing problem management process |
| DSS03-WP5 | Problem resolution reports | Part of the monitoring and reporting of problems and their status |
| DSS03-WP6 | Known-error records | Source can be from incident logs and should be recorded in the problem register |
| DSS03-WP7 | Proposed solutions to known errors | Found in the problem register |
| DSS03-WP8 | Closed problem records | Found in the problem register |
| DSS03-WP9 | Communication of knowledge learned | Part of the monitoring and reporting of problems and their status |
| DSS03-WP10 | Problem resolution monitoring reports | Part of the monitoring and reporting of problems and their status |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Figure 19 - Level 1 Output Work Products *(cont.)* | | |
|---|---|---|
| **WP ID** | **WP** | **Description** |
| DSS03-WP11 | Identified sustainable solutions | Part of the problem register |
| DSS04-WP1 | Policy and objectives for business continuity | Can be found in an operating practice for business continuity and disaster recovery planning |
| DSS04-WP2 | Disruptive incident scenarios | Part of the IT risk and enterprise risk management process |
| DSS04-WP3 | Assessments of current continuity capabilities and gaps | Part of a comprehensive risk register. Some enterprises will keep a subregister of continuity gaps and capabilities. |
| DSS04-WP4 | Business impact analyses | Part of the enterprise risk management system |
| DSS04-WP5 | Continuity requirements | Specified as part of comprehensive business continuity plans (BCPs)/disaster recovery plans (DRPs) |
| DSS04-WP6 | Approved strategic options | Specified as part of comprehensive BCPs/DRPs |
| DSS04-WP7 | Incident response actions and communications | Specified as part of comprehensive BCPs/DRPs |
| DSS04-WP8 | BCP | Self-explanatory, but will include links to emergency and incident management and IT DRPs |
| DSS04-WP9 | Test objectives | Part of BCPs/DRPs |
| DSS04-WP10 | Test exercises | Part of BCPs/DRPs |
| DSS04-WP11 | Test results and recommendations | Part of the BCP monitoring and reporting process |
| DSS04-WP12 | Results of reviews of plans | Part of the BCP monitoring and reporting process |
| DSS04-WP13 | Recommended changes to plans | Part of the BCP monitoring and reporting process |
| DSS04-WP14 | Training requirements | Part of the BCP monitoring and reporting process |
| DSS04-WP15 | Monitoring results of skills and competencies | Part of the BCP monitoring and reporting process |
| DSS04-WP16 | Test results of backup data | Part of the BCP monitoring and reporting process |
| DSS04-WP17 | Post-resumption review report | Part of the BCP monitoring and reporting process |
| DSS04-WP18 | Approved changes to the plans | Part of the BCP monitoring and reporting process |
| DSS05-WP1 | Malicious software prevention policy | This policy can also be an operating practice, which combines policies, controls required and sometimes standards and will include the need to cover all malicious software, viruses, Trojans, etc. |
| DSS05-WP2 | Evaluations of potential threats | Results from a threat and vulnerability assessment |
| DSS05-WP3 | Connectivity security policy | Found in network security architecture |
| DSS05-WP4 | Results of penetration tests | Part of the periodic monitoring and security reporting |
| DSS05-WP5 | Security policies for endpoint devices | An endpoint device is any piece of hardware or software that is capable of autonomously connecting to, obtaining an IP address on, transmitting data through or processing code for a network. Examples are desktop computers, laptops, servers, printers, digital imaging devices, consumer electronic devices, smartphones, network appliances, routers, hubs, switches and network attached storage. |
| DSS05-WP6 | Approved user access rights | Part of the security identity management and access control process |
| DSS05-WP7 | Results of reviews of user accounts and privileges | Part of the management of user accounts, which can include password policy and requirements |
| DSS05-WP8 | Approved access requests | Part of the security identity management and access controls process |
| DSS05-WP9 | Access logs | Part of the security identity management and access controls process |
| DSS05-WP10 | Inventory of sensitive documents and devices | Important for data privacy and normally part of a comprehensive policy or operating practice on the management of sensitive data |
| DSS05-WP11 | Access privileges | Part of the security identity management and access controls process |
| DSS05-WP12 | Security event logs | Part of the security incident management and reporting process |
| DSS05-WP13 | Security incident characteristics | Part of the security incident management and reporting process |
| DSS05-WP14 | Security incident tickets | Part of the security incident management and reporting process |
| DSS06-WP1 | Results of processing effectiveness reviews | Part of the monthly information security monitoring and reporting process |
| DSS06-WP2 | Root cause analyses and recommendations | Part of the monthly information security monitoring and reporting process, and linked to the security incident management system |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Figure 19 - Level 1 Output Work Products *(cont.)* | | |
|---|---|---|
| **WP ID** | **WP** | **Description** |
| DSS06-WP3 | Processing control reports | Part of the monthly information security monitoring and reporting process |
| DSS06-WP4 | Allocated roles and responsibilities | Part of the security plan and programme |
| DSS06-WP5 | Allocated levels of authority | Part of the security plan and programme. Assessor should check to see if there is a RACI chart. |
| DSS06-WP6 | Allocated access rights | Part of a security identity management and access control process |
| DSS06-WP7 | Evidence of error correction and remediation | Part of the monthly information security monitoring and reporting process, and linked to the security incident management system |
| DSS06-WP8 | Error reports and root cause analysis | Part of the monthly information security monitoring and reporting process, and linked to the security incident management system |
| DSS06-WP9 | Retention requirements | See data retention polices or operating practices. |
| DSS06-WP10 | Record of transactions | Part of the security identity management and access control process |
| DSS06-WP11 | Reports of violations | Part of the monthly information security monitoring and reporting process, and linked to the security incident management system |
| MEA01-WP1 | Monitoring requirements | Part of an IT monitoring approach that includes business requirements |
| MEA01-WP2 | Approved monitoring goals and metrics | Part of an IT monitoring approach that includes business requirements |
| MEA01-WP3 | Monitoring targets | Part of an IT monitoring approach that includes business requirements |
| MEA01-WP4 | Processed monitoring data | Part of the monitoring and reporting process for internal IT performance |
| MEA01-WP5 | Performance reports | Part of the monitoring and reporting process for internal IT performance |
| MEA01-WP6 | Remedial actions and assignments | Part of the monitoring and reporting process for internal IT performance |
| MEA01-WP7 | Status and results of actions | Part of the monitoring and reporting process for internal IT performance |
| MEA02-WP1 | Results of internal control monitoring and reviews | Found in both control narrative reports and control test reports |
| MEA02-WP2 | Results of benchmarking and other evaluations | Found in CMMI assessment reports or COBIT 5 capability process assessment reports |
| MEA02-WP3 | Evidence of control effectiveness | Based on the internal control assessments; will exist as control narratives associated with a remediation log and typically for external regulatory requirements such as US Sarbanes-Oxley, Health Insurance Portability and Accountability Act (HIPAA), EU Data Protection, BASEL III, etc. |
| MEA02-WP4 | Self-assessment plans and criteria | Found in COBIT 5 self-assessment reports |
| MEA02-WP5 | Results of self-assessments | Found in COBIT 5 self-assessment reports |
| MEA02-WP6 | Results of reviews of self-assessments | Found in COBIT 5 self-assessment reports |
| MEA02-WP7 | Control deficiencies | Documentation of observations of deficiencies in control, both in control design and operating effectiveness |
| MEA02-WP8 | Remedial actions | Based on observations of deficiencies, generate recommended course of action to re-design the control, if necessary, or to remedy the cause for operating deficiency |
| MEA02-WP9 | Results of assurance provider evaluations | Statements of independence from assurance providers, noting any connections or relationships to the enterprise, if any, and reviews of individual biographies to determine competency |
| MEA02-WP10 | High-level assessments | Part of audit engagement planning, define assessment universe based on risk-based analyses |
| MEA02-WP11 | Assurance plans | Part of audit engagement planning, assessment plans made consistent with defined scope of engagement |
| MEA02-WP12 | Assessment criteria | Part of audit engagement planning, description of how assessment results will be measured to ensure quality performance of work delivered |
| MEA02-WP13 | Assurance review scope | Part of scoping of an internal control assessment or assurance review plan |
| MEA02-WP14 | Engagement plan | Part of an assurance, audit or assessment plan |
| MEA02-WP15 | Assurance review practices | Part of IT policies or operating practices for the effective monitoring of internal controls and IT process capability |
| MEA02-WP16 | Refined scope | Part of scoping of an internal control assessment or assurance review plan |
| MEA02-WP17 | Assurance review results | Typically found in a control remediation log or a capability assessment report |



Personal Copy of: Mr. Jorge Diab Maluf Filho

| Figure 19 - Level 1 Output Work Products *(cont.)* | | |
|---|---|---|
| **WP ID** | **WP** | **Description** |
| MEA02-WP18 | Assurance review report | Self-explanatory |
| MEA03-WP1 | Compliance requirements register | Not all enterprises will keep a compliance register because it is difficult to maintain. Assessors should be more focused on the evidence of process capability assessments because most controls meet most regulatory and/or compliance requirements. |
| MEA03-WP2 | Log of required compliance actions | Kept by individual or key statutory requirements, e.g., US Sarbanes-Oxley |
| MEA03-WP3 | Updated policies, principles, procedures and standards | All IT policies and procedures should be continuously maintained on an 'as needed' basis. Assessors should check for evidence of a review process. |
| MEA03-WP4 | Communications of changed compliance requirements | Normally undertaken by the business. Assessors should check for evidence that there is such a communication aligned with the IT department. |
| MEA03-WP5 | Identified compliance gaps | Usually found in a control remediation register or log |
| MEA03-WP6 | Compliance confirmations | Usually through audit or external or internal assessment reporting |
| MEA03-WP7 | Compliance assurance reports | Usually through audit or external or internal assessment reporting |
| MEA03-WP8 | Reports of non-compliance issues and root causes | Usually through audit or external or internal assessment reporting |



Personal Copy of: Mr. Jorge Diab Maluf Filho